Основи кібербезпеки

План курсу

1. Предмет кібербезпеки і проблеми захисту інформації.

2. Криптографічні перетворення і протоколи.
3. Автентифікація. Спеціальні криптографічні протоколи. Квантова криптографія. Основи стеганографії.

4. Механізми захисту операційних систем. Засоби захисту ОС Linux.
5. Механізми захисту ОС Windows. Безпека доменів Windows.
6. Безпека СКБД.
7. Вразливості і захист програмного забезпечення.

8. Основи мережної безпеки. Вразливості прикладних сервісів. Безпека Web.
9. Архітектура захищених мереж. Безпека мережної інфраструктури. Мережні екрани та системи виявлення/запобігання атак.

Рекомендована література:

- Грайворонський М.В., Новіков О.М. Безпека інформаційно – комунікаційних систем. – К: Видавнича група BHV, 2009. – 608 с.
- Танненбаум Э. Современные операционные системы. 4-е изд. - СПб.: Питер, 2015. - 1120 с. ISBN 978-5-496-01395-6
- Таненбаум Э., Уэзеролл Д. Компьютерные сети. 5-е изд. - СПб.: Питер, 2012. - 960 с. ISBN 978-5-459-00342-0
- Столлингс В. Основы защиты сетей. Приложения и стандарты. – М.: «Вильямс», 2002. – 432 с.
- Эриксон Дж. Хакинг: искусство эксплойта. 2-е изд. - Пер. с англ. - Спб.: Символ-Плюс, 2010. - 512с.

- https://tools.ietf.org/html/rfc4949 (Internet Security Glossary, Version 2)
- Скляров И.С. Головоломки для хакера. – СПб.: БХВ – Петербург, 2007. – 320 с.
- Козиол Дж., Личфилд Д., Энли К. Искусство взлома и защиты систем. - СПб.: Питер, 2006 – 416 с.сновы
- Шнайер Б. Секреты и ложь. Безопасность данных в цифровом мире. – СПб.: Питер, 2003. – 368с.
- Макнамара Д. Секреты компьютерного шпионажа: Тактика и контрмеры. - М.: БИНОМ, 2004 - 536 с.
- Гриняев С.Н. Поле битвы — киберпространство: Теория, приемы, средства, методы и системы ведения информационной войны. - Мн.: Харвест, 2004. - 448 с. ISBN 985-13-2413-2

ПРЕДМЕТ КІБЕРБЕЗПЕКИ
ЗАГАЛЬНІ ПРОБЛЕМИ ЗАХИСТУ ІНФОРМАЦІЇ

Властивості і класифікація інформації.
Об'єкти і суб'єкти інформаційної безпеки.
Класифікація загроз, вразливостей і атак.

Політика безпеки. Процес розробки політики безпеки.
Модель загроз. Класифікація загроз. Модель порушника.

Рівні безпеки. Напрямки захисту інформаційних систем. Методи, заходи та підсистеми захисту.
Фізична безпека і технічний захист інформації.
Завдання ідентифікації та автентифікації.
Види політик керування доступом.

Кібербезпека являє собою набір засобів, які використовуються для захисту кіберсередовища (кіберпростору).
Кібербезпека передбачає досягнення і збереження властивостей безпеки ресурсів організації або користувачів проти відповідних кіберзагроз.

У чому відмінність *кібербезпеки* від традиційної інформаційної безпеки?

У *корпоративних мережах і системах*, як правило, основний ресурс (об'єкт), що захищається - *інформація*, що обробляється, передається і зберігається в автоматизованих системах, а основна мета захисту - забезпечення її конфіденційності, доступності та цілісності.

Автоматизовані системи управління технологічним процесом (АСУ ТП) мають масу відмінностей від «традиційних» *корпоративних інформаційних систем*: починаючи від призначення, специфічних протоколів передачі даних і використовуваного обладнання, і закінчуючи середовищем, в якому вони функціонують.

В АСУ ТП ресурсом, що захищається,в першу чергу є сам технологічний процес, і основна мета - *забезпечити його безперервність* (доступність усіх вузлів) і цілісність (в т.ч. і інформації, що передається між вузлами АСУ ТП).

Кібербезпека ≈ Безпека АСУ ТП.

Кібербезпека - системна властивість.

В АСУ ТП першорядним є захист технологічного процесу.
(Знергетіка, аеронавтика, навігація, банківські та платіжні системи, документообіг, керування ресурсами ...)

Поле потенційних ризиків і загроз для АСУ ТП, в порівнянні з корпоративними системами, розширюється ризиками потенційних збитків життю і здоров'ю персонала і населення, збитку навколишньому середовищу та інфраструктурі. Саме тому говорити про «інформаційну безпеку» по відношенню до АСУ ТП некоректно. В англомовних джерелах для цього використовується термін *cybersecurity*, прямий переклад якого (кібербезпека) все частіше зустрічається стосовно захисту АСУ ТП.

Говорячи про *кібербезпеку*, в першу чергу розглядаються «комп'ютерні» загрози - загрози, пов'язані з впливом на технологічний процес через *інтелектуальні пристрої АСУ ТП* - контролери, сервери SCADA, АРМ і HMI, телекомунікаційне обладнання, лінії зв'язку і т.д.

SCADA і АСУ ТП - це одне й те саме?
Не зовсім. *SCADA-системи* (Supervisory Control and Data Acquisition, диспетчерське управління і збір даних) - це частина АСУ ТП. Зазвичай, під SCADA-системами мають на увазі централізовані системи контролю та управління (за участю людини) всією системою або комплексом АСУ ТП.

Інформаційна безпека, як галузь знань, включає такі напрямки: технології захисту інформації, криптографія, технічний захист інформації, безпека інформаційно-комунікаційних систем, управління інформаційною безпекою, кібербезпека ...

Кібербезпека - захист інтегрованих керуючих систем / критичної інформаційної інфраструктури.

Мета безпеки - збереження значень деяких параметрів (стану) об'єкта.
Мета інформаційної безпеки - забезпечення стану **конфіденційності, цілісності (достовірності), доступності та спостережності об'єкта.**

Властивості інформації, що захищаються (Information security Objectives, сервіси безпеки):

- Конфіденційність (Confidentiality)
- Цілісність (Integrity)
- Доступність (Availability)
- Спостережність (Accountability)

Класифікація інформації:

Категорії інформації: критична, важлива, корисна, не суттєва ...

Рівні таємності (грифи, шкала цінності):

- відкрита, для службового користування, таємна, цілком таємна
- unclassified, confidential, secret, top secret

Об'єкти інформаційної безпеки - інформаційна система, операційна система, протоколи передачі даних, інформаційні ресурси, інформація.

Суб'єкти інформаційної безпеки - адміністратор, порушник, аудитор, персонал.

Доступ: Суб'єкт - Метод доступу - Об'єкт

Суб'єкт: користувач, процес або пристрій
Метод доступу: читання, запис ...
Об'єкт: записи, блоки, сторінки, сегменти, файли, директорії, біти, байти, слова, термінали, вузли, мережа ...

Суб'єкти порушень безпеки:

- аудитор (дослідник)
- hacker
- cracker (зломщик)
- phreaker
- spammer
- phisher

Загроза (threat) - потенційно можливе порушення безпеки (шляхи реалізації впливів, які вважаються небезпечними)
Вразливість (vulnerability) - слабкість в захисті, здатна привести до компрометації
Атака - спроба реалізації загрози
Експлоіт (exploit) - механізм реалізації вразливості (найчастіше програмний)

Ризик - імовірність, що деяка атака буде успішною

Типи загроз:

- Розкриття (витік інформації, несанкціонований доступ, втрата контролю над системою безпеки)
- Порушення цілісності (цілеспрямована зміна або випадкові помилки; незаконне знищення чи модифікація інформації)
- Відмови служб (порушення доступності)

Трьом типам загроз відповідають три властивості інформації: конфіденційність (таємність), цілісність та доступність.

Конфіденційність інформації - властивість, що дозволяє не давати права на доступ до інформації або не розкривати її неповноважним особам або іншим суб`єктам системи

Цілісність інформації - здатність засобів системи забезпечувати незмінність інформації в умовах випадкового і / або навмисного спотворення (руйнування);

Доступність - властивість бути доступним і використовуватись за запитом з боку уповноваженого суб'єкта.

Загроза обчислювальній системі - це можлива подія (навмисна або ні), яка може негативно впливали на активи і ресурси, пов'язані з обчислювальною системою.

Загроза безпеці комп'ютерної мережі - сукупність умов і факторів, що визначають потенційну або реально існуючу небезпеку порушення конфіденційності, цілісності, доступності інформації та / або зниження надійності (безвідмовності і автентичності) реалізації функцій комп`ютерної мережі.

Загроза безпеці інформації - сукупність умов і факторів, що створюють потенційну або реально існуючу небезпеку, пов'язану з витоком інформації і / або несанкціонованими і / або ненавмисними діями з нею.

Методика класифікації загроз STRIDE
(використовується при побудові моделі загроз)

-Підміна об'єктів (spoofing identity) - в т.ч. особи користувача
-Модифікація даних (tampering with data)
-Відмова від авторства (repudiation of origin)
-Розголошення інформації (information disclosure)
-Відмова в обслуговуванні (denial of service)
-Підвищення привілеїв (elevation of privilege)

Загрозами безпеці інформаційних і комунікаційних засобів і систем можуть бути:

- протиправні збір і використання інформації; порушення технології обробки інформації; порушення законних обмежень на поширення інформації;
- несанкціонований доступ до інформації, що знаходиться в базах даних;
- впровадження електронних пристроїв з метою перехоплення інформації в технічні засоби обробки, зберігання та передачі інформації по каналах зв'язку, а також у службові приміщення органів державної влади, підприємств, установ та організацій;
- впровадження в апаратні і програмні вироби компонентів, що реалізують функції, не передбачені документацією на ці вироби;
- перехоплення інформації в мережах передачі даних і на лініях зв'язку, дешифрування цієї інформації та нав'язування неправдивої інформації;
- витік інформації по технічним каналам;
- вплив на парольно-ключові системи захисту автоматизованих систем обробки і передачі інформації;
- компрометація ключів і засобів криптографічного захисту інформації;
- розробка і поширення програм, що порушують нормальне функціонування інформаційних і інформаційно-телекомунікаційних систем, в тому числі систем захисту інформації;
- знищення, пошкодження, радіоелектронне придушення або руйнування засобів і систем обробки інформації, телекомунікації та зв'язку;
- знищення, пошкодження, руйнування або викрадання комп`ютерних та інших носіїв інформації;

Класифікація вразливостей (vulnerabilities, weaknesses)

У технологіях (Technological weaknesses)
Програмного забезпечення (переповнення буфера, помилки обробки текстових рядків)
Вразливості операційних системи
Вразливості мережних протоколів (HTTP, FTP, ICMP, SNMP, SMTP, ...- не захищені)
Вразливості мережного обладнання (захист паролів, автентифікація, протоколи маршрутизації, мережні екрани)

В налаштуваннях (Configuration weaknesses)
Вразливості конфігурації (вразливість облікових записів - незахищена передача по мережі і слабкі паролі, вразливість мережних сервісів - JavaScript, IIS, FTP, Terminal Service; слабкі налаштування «за-замовчуванням»)
Вразливості мережного обладнання (специфічні)

В політиці безпеки (Security policy weaknesses; людський фактор)
Відсутність документації, слабкі політики облікових записів / паролів, неадекватний моніторинг і аудит (неавторизоване використання сервісів та можливість атаки), неузгодженість (наприклад, в зміні або встановленні ПО), відсутність плану відновлення

«Хакери не генії, вони просто дуже наполегливі»
«Щоб зрозуміти природу атак - потрібно навчитися мислити як хакер»

Типи атак (класифікація)

- Внутрішні (локальні)
- Зовнішні (мережні)
- На потік даних (прослуховування і аналіз, зміна, блокування, повторення)

На конфіденційність (розголошення інформації, підвищення привілеїв)
На цілісність (підміна і модифікація об'єктів, відмова від авторства)
На доступність (відмова в обслуговуванні)

Мережні атаки (атаки на мережу):

- Reconnaissance (розвідка, зондування)
- Access (доступ)
- Denial of Service (відмова в обслуговуванні)
- Worms, Viruses, and Trojan Horses (хробаки (черв`яки), віруси і трояни)

Шкідливе ПО (Worms, Viruses, Trojan Horses)

-В**іруси** (Viruses) - поширюють себе на комп'ютері автоматично (файлові, завантажувальні, макровіруси, скриптові віруси)

-**Черв`яки** (Worms) - мають механізм автоматичного поширення через мережу (використовують уразливості ОС або ПЗ для проникнення)

-**Трояни** (Trojans) - маскуються під корисне ПО, запускаються за згодою користувача, можуть містити небажані функції - вірус або черв'як

-П**рограмні закладки** (шпигунські програми, перехоплювачі клавіатурного введення, логічні бомби, люки; можуть використовувати віруси, черв'яки або трояни)

-**Хакерскіе утиліти** (експлоіти, засоби атаки, та інші технологічні програми)

"Not trust anyone you want to keep secrets" ...

Соціальна інженерія (психологічна атака) - спроба хакера за допомогою обману або хибних порад примусити деякого користувача допомогти йому в проведенні атаки.

- дії від імені вищих інстанцій
- самозванство
- співчуття
- акцент на особисті якості
- лестощі
- непомітне вторгнення
- винагорода

Протидія соціальної інженерії:

- Не довіряйте нікому
- Задавайте більше питань
- Будьте бюрократами
- Перевірка особистості
- Вмійте говорити «ні»
- Навчання користувачів

Політика безпеки - сукупність норм і правил, що регулюють процес забезпечення безпеки.
(***Захист*** - процес забезпечення безпеки)

Політика безпеки визначає правила передачі і зберігання інформації та сфери відповідальності. Політику безпеки обчислювальної системи організації необхідно сформулювати для того, щоб визначити, від яких саме загроз і яким чином захищається інформація в системі. Під політикою безпеки розуміється набір правових, організаційних і технічних заходів захисту інформації, прийнятий в конкретній організації.
Політика безпеки визначає набір вимог, які повинні бути виконані в конкретній системі.
Політика безпеки обчислювальної системи може складатися з багатьох часткових політик, направлених на конкретні аспекти захисту інформації.

Завдання **політики безпеки**:

- Інформування персоналу стосовно їх обов'язків щодо дотримання ІБ
- Визначення механізмів забезпечення безпеки
- Опис базового рівня безпеки (baseline) для подальшого аудиту і модернізації

- Захист персоналу та інформації
- Формулювання посадових інструкцій різних категорій персоналу
- Визначення прав доступу
- Визначення відповідальних за забезпечення і контроль безпеки
- Опис інструкцій на випадок порушення безпеки

Процес розробки політики безпеки

Розробка політики безпеки починається з опису структури цінностей, аналізу ризиків та визначення правил доступу.

Модель безпеки - опис політики безпеки. Використовується при проектуванні системи для визначення механізмів і алгоритмів захисту, а також під час аналізу захищеності системи з метою перевірки і підтвердження коректності та достатності реалізованих механізмів.

План захисту (по НДТЗІ 1.4-001):

- Моделювання та аналіз системи (активи, інформаційні потоки, ролі ...)
- Аналіз загроз (ідентифікація об'єктів, модель загроз, модель порушника)
- Аналіз ризиків (оцінка і обробка)
- Ухвалення рішення про застосування засобів захисту
- Розробка політик керування ресурсами (керування правами доступу, фізична безпека, права і обов'язки)
- Аварійний план (реагування на інциденти, розслідування, відновлення), управління безперервною роботою

Модель інформаційних потоків (системи, документообігу, бізнес-процесу) - опис процесів, що відбуваються в системі з точки зору життєвого циклу оброблюваної інформації (в тому числі і в «паперовому» вигляді).

Модель загроз - структурований опис методів і способів здійснення загроз

- Цілі порушення (властивості інформації або АС, на порушення яких спрямована атака): конфіденційність, цілісність, доступність, спостережність і керованість;
- Джерела виникнення загроз: внутрішні або зовнішні суб'єкти;
- Шляхи реалізації загроз: загроза фізичного або логічного рівня (технічні канали або шляхом дистанційного впливу через канали передачі даних).

"Homo homini lupus est"

Порушник - це особа, що зробила спробу виконання заборонених дій (операцій) помилково, несвідомо або усвідомлено зі злим наміром (можливо, з корисливим) або без такого (заради гри або задоволення, з метою самоствердження, тощо...) і використовує для цього різні можливості, методи і засоби. (Хакер, крекер ...)

Три основні **мотиви порушень**: безвідповідальність, самоствердження і корисливий намір.
При порушеннях, викликаних безвідповідальністю, користувач цілеспрямовано або випадково чинить руйнівні дії, не пов'язані, проте, зі злим наміром.
У більшості випадків це наслідок некомпетентності або недбалості.

Основні **причини порушення** безпеки АС:

-не відповідність моделі безпеки
-неправильне впровадження моделі безпеки
-відсутність ідентифікації / автентифікації
-відсутність контролю цілісності
-помилки в програмній реалізації, наявність люків
-помилки адміністрування

Модель порушника - це абстрактний (формалізований або неформалізований) опис порушника.

При розробці моделі порушника визначаються:

- припущення про категорії осіб, до яких може належати порушник;
- припущення про мотиви дій порушника (переслідуваних порушником цілях);
- припущення про кваліфікацію порушника і його технічну оснащеність (про використовуваних для вчинення порушення методах і засобах);
- обмеження і припущення про характер можливих дій порушника.

- Категорії порушників: внутрішні / зовнішні, користувачі / тех.персонал / керівники.
- Мета і мотиви порушника: отримання і зміна інформації, знищення цінностей або відмова в обслуговуванні.
- Повноваження, теоретичні та практичні можливості порушника (методи і засоби): запуск фіксованого набору програм, створення і запуск власних програм, внесення змін в налаштування системи;
- Рівень знань про автоматизовану систему. Можливість підключення неавторизованих пристроїв;
- Технічне оснащення: апаратні, програмні та інші засоби;
- Кваліфікація порушника: максимально можлива.
- Характер можливих дій. Передбачити можливість змови.

Модель загроз і *модель порушника* - вхідна інформація при розробці політики безпеки і проектуванні систем захисту.

Методи (заходи, засоби, напрямки) захисту:

- Технічні (апаратні, програмні)
- Криптографічні
- Адміністративні (організаційні, законодавчі)

Засоби захисту:

ОС:

-захист адресного простору, керування процесами;
-автентіфікація, призначення прав доступу;
-аудит;
-сканери, антивіруси;
-контроль цілісності об'єктів.

Мережні засоби:

-захист пристроїв;
-захист периметра, фільтрація, спостереження (мережні екрани, IDS/IPS системи);
-захист мережних з'єднань (протоколи SSL, VPN, ...);
-захист сервісів (перевірка синтаксису, керування ресурсами, актуалізація);
-мережна автентифікація (802.1X, RADIUS ...);
-регистрація подій (нотарізація, аудит).

Заходи захисту (Mitigation Techniques):

- Контроль фізичного доступу до системи
- Використовувати сильні паролі та періодично їх змінювати
- Відключити функції або сервіси, що не використовуються
- Антивіруси, актуалізація ПО, карантин
- Актуальні патчі ОС
- Регулярне резервне копіювання і перевірка резервних копій
- Персональні мережні екрани
- Система виявлення атак (мережна)

Підсистеми захисту:

- Ідентифікації і автентифікації
- Керування доступом
- Реєстрації подій (нотаризації, аудиту)
- Забезпечення цілісності
- Криптографічний захист

Загальні напрямки захисту ІС (places of defense)

- мінімізація невикористовуваних функцій і сервісів
- безпеку доступу, облікових записів, паролів
- політика безпеки

"Найнадійніший корабель завжди стоїть на березі і ніколи не виходить в море"

Рівні безпеки інформаційної системи:

- Фізична безпека
- Безпека ОС
- Безпека протоколів передачі даних (канального, мережного, транспортного, прикладного рівня)
- Системна безпеку

Фізична безпека:

- Фізичний доступ (замки, камери, охорона, ...)
- Безпека середовища (температура, обдув, вологість, сигналізація, ...)
- Електробезпека (UPS, надмірність, автономний генератор, система оповіщення)
- Обслуговування (безпека кабельної структури, документація, ...)

Технічний захист інформації:

- Захист від несанкціонованого доступу (порушення прав доступу)
- Захист від витоку інформації технічними каналами (оптичні, акустичні, побічні електромагнітні випромінювання і наведення)

Канали витоку інформації

- Фізичні (електромагнітні, акустичні, оптичні)
- Інформаційні (тимчасові, з пам'яттю)

Ідентифікація: розпізнавання об'єктів і призначення ідентифікаторів
Автентифікація: перевірка справжності

Види автентифікації в АС:

- Парольная система
- За цифровими сертифікатами
- Електронні ключі
- Біометрія (дактилоскопія, за формою долоні, по райдужній оболонці ока, термографія обличча, розпізнавання голосу, розпізнавання підпису, розпізнавання клавіатурного почерку, розпізнавання генетичного коду ...)

Види політик керування доступом

Однозначна ідентифікація суб'єктів і об'єктів!

Дискреційна політика:

- окреме призначення прав доступу кожному суб'єкту на кожний об'єкт (максимально можлива деталізація призначень прав доступу)
- реалізація через списки контролю доступу або списки можливостей

Нормативна (мандатна) політика (модель Белли-Ла-Падули):

- впорядкована шкала міток таємності об'єктів (цінності інформації)
- впорядкована шкала міток рівнів доступу суб`єктів (рівень довіри — максимальний рівень таємності інформації, до якої суб'єкт може отримати доступ)
- керування доступом на основі порівняння міток суб`єктів та об'єктів

Мета нормативної політики: запобігання витоку інформації (інформаційних потоків) від об'єктів з високим рівнем доступу до об'єктів з низьким рівнем доступу

Рольова модель керування доступом:

- роль (умовний суб`єкт) -набір повноважень в системі, необхідний для виконання певних дій або функціональних обов`язків
- призначення прав доступу фізичним суб`єктам опосередковано через набір ролей

"Безпека - це процес, а не результат (« Security is a process, not a product »)"
(Bruce Schneier)

Процес безпеки (security wheel):

- Забезпечення захисту (VPN, політика доступу (хто-що), автентифікація)
- Моніторинг (Монітор трафіку, система обліку)
- Тестування
- Модернізація захисту ....

Захист інформації повинен забезпечуватись на всіх стадіях життєвого циклу інформаційної сиистеми!

Питання по темі 1:

У чому полягає мета забезпечення інформаційної безпеки. Як ви розумієте властивості конфіденційності, цілісності та доступності інформації.
Властивості і категорії інформації.
Суб'єкти і об'єкти доступу до інформації. Об'єкти і суб'єкти інформаційної безпеки.
Суб'єкти порушення інформаційної безпеки.

Що таке загроза, вразливість і атака. Їх відмінність. Що таке ризик з точки зору інформаційної безпеки. Що називається "експлоітом"
Класифікація та приклади типів загроз інформаційній безпеці. Класифікація загроз STRIDE.
Класифікація вразливостей інформаційних систем.
Назвіть основні вразливості ІС кожного типу і відповідні заходи протидії.
Класифікація атак. Види мережних атак.
Класифікація шкідливого ПЗ.
Що називається "соціальною інженерією". Методи соціальної інженерії і способи протидії їм. Як захиститись від атак соціальної інженерії.

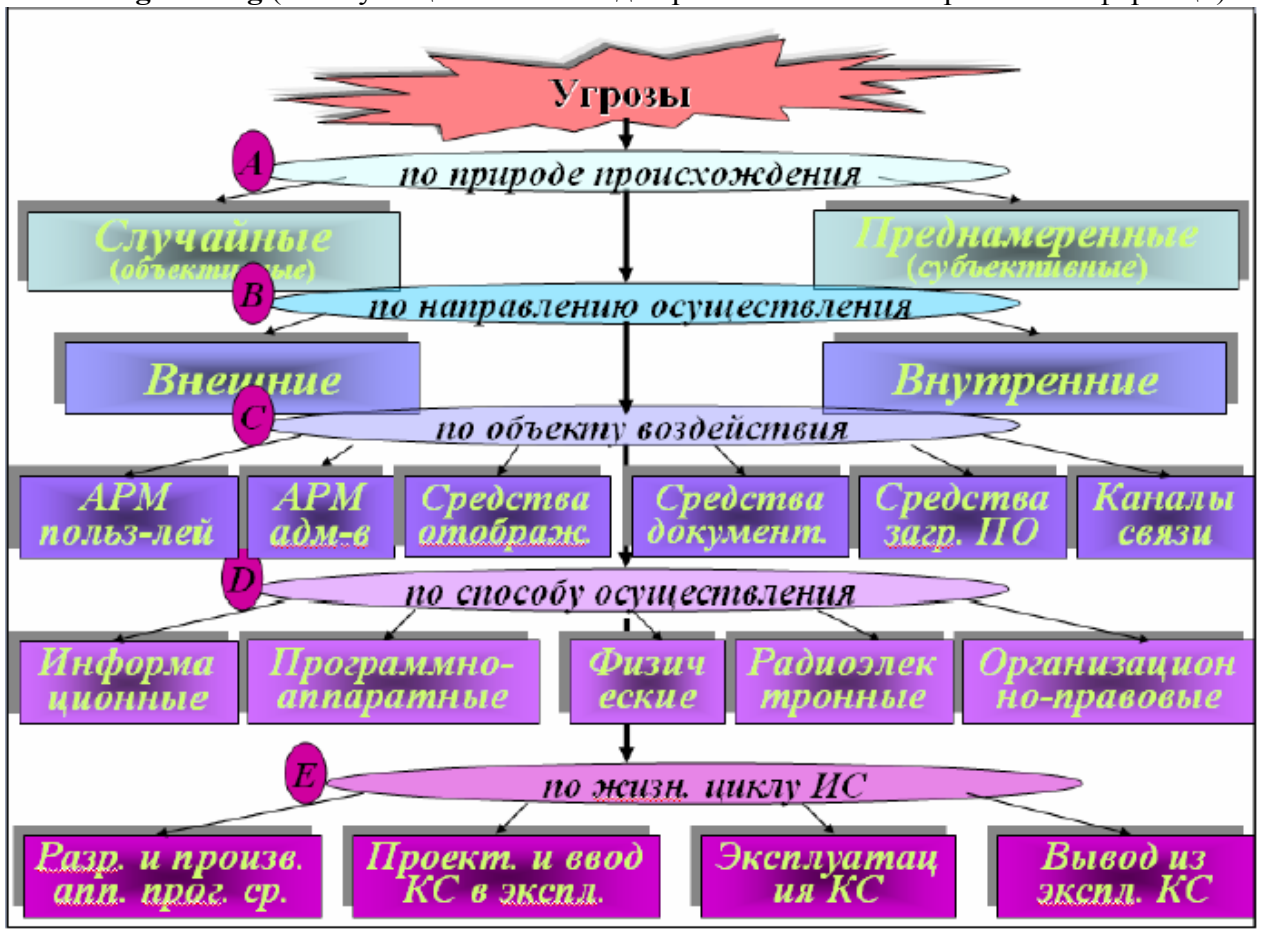
Що таке політика безпеки ІС та її завдання. Послідовність розробки та впровадження системи захисту.
Що таке модель безпеки.
Що таке модель загроз і модель порушника. Для чого вони використовуються і що описують

Напрями забезпечення безпеки (захисту) ІС.
Методи захисту інформації в ІС.
Рівні безпеки в ІС. Підсистеми захисту в ІС.
Напрями забезпечення фізичної безпеки.
Завдання технічного захисту інформації.
Канали витоку інформації.
Завдання ідентифікації і автентифікації. Види автентифікації.
Види політик керування доступом та їх властивості.

Додаток 1. классіфкаціі загроз:

Типи загроз:

- **Неструктуровані** (доступні інструменти)
- **Структуровані** (мотивація і компетенція)
- **Об'єктивні та суб'єктивні** (випадкові і навмисні)
- **Внутрішні і зовнішні**
- **Social Engineering** (експлуатація наївності і довірливості з метою отримання інформації). Людина - сама уразлива ланка в ланцюжку безпеки.



Види загроз (антропогенні, технічні, стихійні):
Помилки, пошкодження, поломки, нещасні випадки
Порушення

Шпигунство
Розголошення (розкриття)
НСД, підключення
Заволодіння, крадіжка, втрата
Копіювання
Модифікація, відмова від істиності
Перехоплення
Нав'язування
Шкідливі програми

Характер походження загроз:
об'єктивні
суб'єктивні (навмисні та ненавмисні)

Джерела загроз:
Люди (хакери, інсайдери)
Технічні пристрої
Алгоритми (схеми) обробки інформації
Зовнішнє середовище

Канали витоку інформації (НСД):
Втрата, читання з екрану, крадіжка носіїв, ПЕМВН, соц інженерія

Електро
Фізичні
Оптичні

Інформаційні

Причини порушення цілісності:
Суб'єктивні:
Навмисні:
Диверсія (фізичне пошкодження обладнання, ліній зв'язку, формування шумів, блокування роботи, DoS, відключення антивірусного ПЗ ...)
Дії над носіями (НСД, підміна / фальсифікація, модифікація, крадіжка, незаконне копіювання або видалення / знищення, витік, встановлення непередбаченого / шкідливого ПО (закладки / віруси / трояни), витік або крадіжка паролів, підбір паролів ...)
Інформаційні впливи (незаконне підключення / доступ, сканування, аналіз трафіка, електромагнітних сигналів, акустично - шумових сигналів, витік технічними каналами ...)
Ненавмисні:
Відмови обслуговуючого персоналу (випадкове пошкодження або знищення даних, ключової інформації, несанкціоноване копіювання, незаконна модифікація, розголошення ...)
Збої і помилки людей (відключення електроживлення, наслідки ремонту, некоректна конфігурація ...)
Об'єктивні, ненавмисні:
Відмови апаратури, програм, системи живлення, мережі
Збої, електромагнітна несумісність (стрибки напруги, короткі замикання ...)
Стихійні лиха, природні катастрофи
Нещасні випадки, пожежі

Зміна, фальсифікація, знищення, втрата, вихід з ладу, відмова від дій, порушення транзакцій, НСД, зараження

Потенційно можливі злочинні дії:

Вивчення відкритої інформації
Вивідування інформації (в межах контрольованої області або поза)
огляд сміття
халатність персоналу
Диверсія, фіз знищення
Дезорганізація (саботаж)

Використання матеріалів в корисливих цілях
Копіювання інформації з носіїв
Крадіжки, розкрадання носіїв
Видалення, пошкодження
зміна
Зняття інформації з пам'яті пристроїв

Введення несанкціонованих програмних продуктів
Установка закладних пристроїв

Вторгнення (проникнення) в ІС, впровадження агентів
Підслуховування, зняття з акустичних каналів
Оптична розвідка, фото- відеозйомка, копіювання з пристроїв відображення
Зняття ПЕМВН, нав'язування ПЕМВН
Підключення до ІС по лініях зв'язку, перехоплення інформації, атаки на протоколи, криптоаналіз

КРИПТОГРАФІЧНІ ПЕРЕТВОРЕННЯ

Завдання і принципи криптографії.
Базові операції шифрування.
Симетричне шифрування.
Стандарти DES, 3DES, ГОСТ 28174-89.
Стандарт AES.
Режими роботи алгоритмів шифрування.
Асиметричне шифрування. Алгоритм RSA.
Алгоритми цифрового підпису.
Управління ключами шифрування. Інфраструктура відкритих ключів.
Авентифікація. Протоколи автентифікації.

Проблеми, що вірішує криптографія:

Конфіденційність - шифрування.
Цілісність - геш функція.
Автентифікація повідомлення (підтвердження джерела) - цифровий підпис.
Автентифікація сторін - протокол автентифікації.
Управління ключами і сертифікатами відкритих ключів.

P – відкритий текст
$C=E_K(P)$; E_K – функція шифрування, C – зашифрований текст
$P=D_K(C)=D_K(E_K(P))$ – розшифрування (відновлення) тексту; зловмисник не знає ключа

Потрібно виключити можливість розшифрування (зробити максимально складним)

- Алгоритми шифрування загальнодоступні, таємні тільки ключі (Правило Керкгоффа)

Таємність - властивість криптографічної системи (протоколу) протистояти атакам розкриття зашифрованої інформації.

- атака на основі тільки зашифрованого тексту
- атака з відомою частиною відкритого тексту
- атака з обраним відкритим текстом (для асиметричних алгоритмів – завжди можлива)

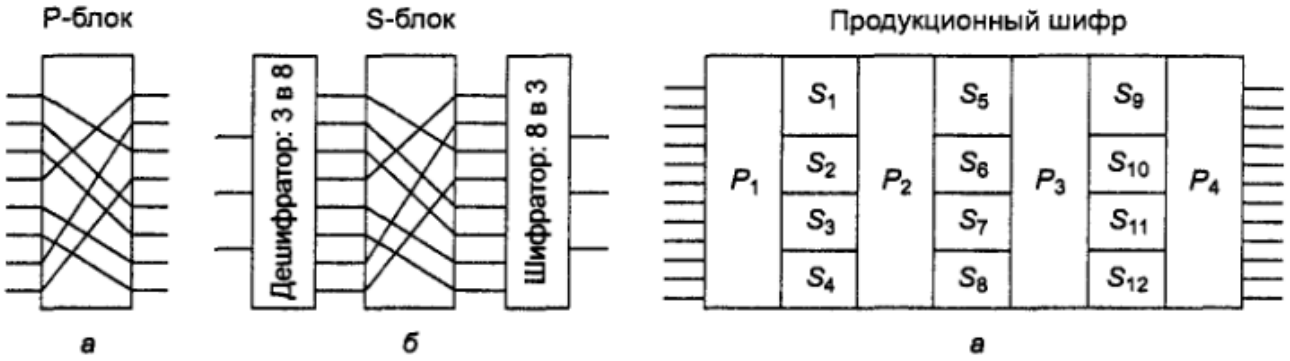
Імітостійкість (imitation resistance) - властивість криптографічної системи (криптографічного протоколу), що характеризує здатність протистояти активним атакам з боку порушника (зловмисника), метою яких є *нав'язування* хибного повідомлення, *підміна* переданого повідомлення або *зміна* даних, що зберігаються.

- Зашифровані повідомлення повинні мати надмірність (та відрізнятися від “сміття”)
- Потрібен спосіб боротьби з повторною відправкою раніше надісланих повідомлень (anty-reply)

Базові операції шифрування

Підстановка (заміна, substitution, S-блок) - кожен символ або група символів замінюється іншим символом або групою символів (моноалфавітні підстановки - шифр Цезаря). Зберігають порядок символів, але змінюють самі символи.

Перестановка (транспозиція, permutation, P-блок) - змінює порядок символів, але не змінює самі символи



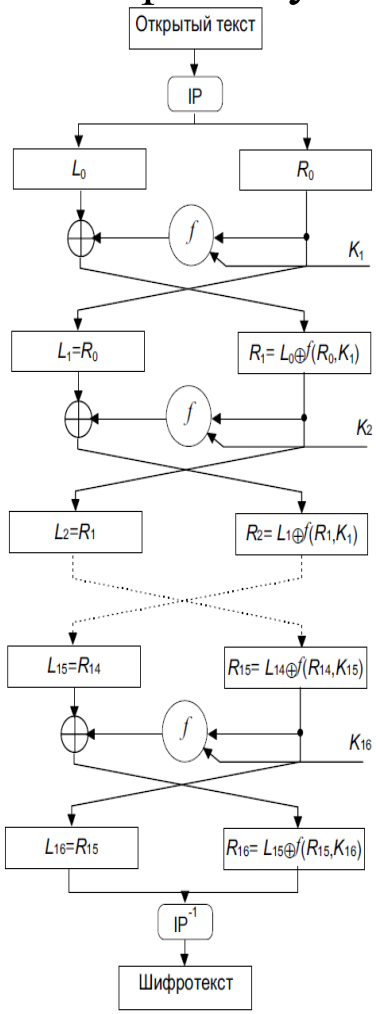
Основные элементы продукционных шифров: P-блок (*а*); S-блок (*б*); продукционный шифр (*в*)

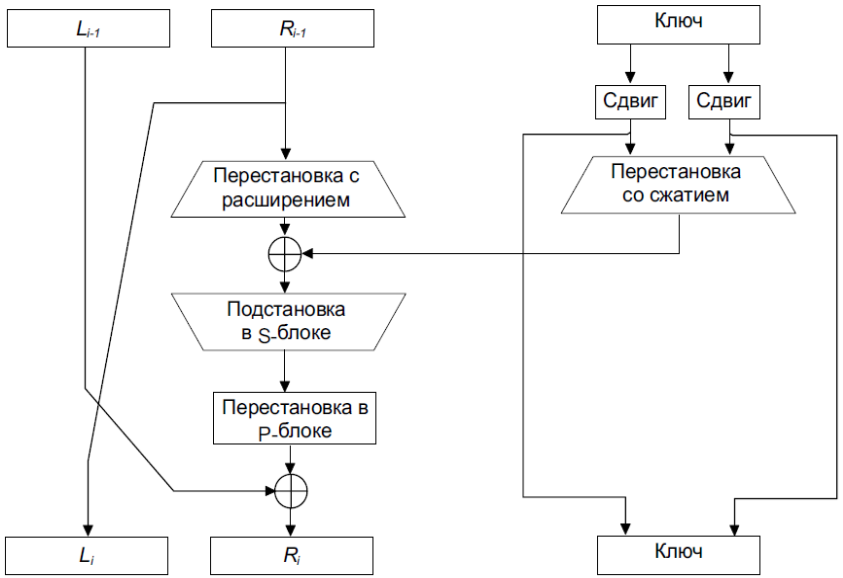
Одноразовий шифроблокнот (гама, шифр Вернама) - випадкова чи псевдовипадкова послідовність, що застосовується для шифрування (гамування). Теоретично потужний засіб, але практично можливе зберігання і передача ключа тільки обмеженого розміру.

Симетричні та асиметричні алгоритми шифрування
Потокові та блокові шифри

Стандарт DES (Data Encryption Standard, 1977 г.)

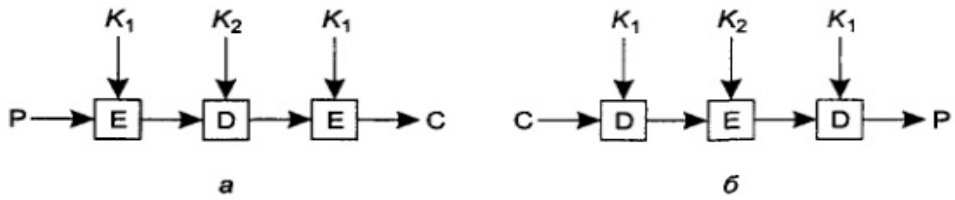
Розмір блоку - 64 біта (вхід - 64 біта, вихід - 64 біта). Довжина ключа - 56 бітів.





Один этап DES.

Потрійне шифрування DES (3DES)



Тройное шифрование с помощью DES (*а*); дешифрация (*б*)

3DES має 2 ключі (ключ подвійної довжини) та 3 етапи шифрування.
Послідовність операцій EDE - для сумісності зі звичайним DES.

ГОСТ 28147-89 «Системи обробки інформації. Захист криптографічний. Алгоритм криптографічного перетворення »

Блоковий шифроалгоритм. При використанні методу шифрування з гамуванням може виконувати функції поточного шифроалгоритма. В основі, як і у DES, - мережа Фейстеля.

Розмір блоку - 64 біта; Довжина ключа - 256 біт; Кількість циклів — 32/16.
Може використовувати різні S-блоки (як додатковий ключ, або ж як параметр схеми).

Недоліки:
Не можна визначити криптостойкость, не знаючи таблиці замін (S- блоків).
Можуть поставлятися навмисно слабкі таблиці замін.
Несумісність при використанні різних таблиць замін.

Стандарт AES (базується на алгоритмі Rijndael, 2001 г.)
Розмір блоку 128 біт. Довжина ключа 128, 192, 256 біт.

Проста алгебраічна структура.
В теорії скінчених полів (полів Галуа) можливо строго довести властивості AES.
Використовуються S та P блоки.
Операції проводяться над цілими байтами (ефективність в програмній реалізації).
Число ітерацій залежить від розміру ключа.
Поріг безпеки – мінімальна кількість однотипних ітерацій (кроків), необхідна для збереження таємності (стійкості алгоритму)

Схематичний алгоритм методу Rijndael

```
#define LENGTH 16 / * Число байтів в блоці даних або ключі * /
#define NROWS 4 / * Число рядків в масиві state * /
#define NCOLS 4 / * Число стовпців в масиві state * /
#define ROUNDS 10 / * Число ітерацій: 10, 12, 14 в залежності від довжини ключа * /
typedef unsigned char byte / 8-розрядне ціле без знака * /

rijndael (byte plaintext [LENGTH], byte ciphertext [LENGTH], byte key [LENGTH])
{
int r; / * Лічильник циклу * /
byte state [NROWS] [NCOLS]; / * Поточний стан — текст, що модифікується * /
struct {byte k [NROWS] [NCOLS];} rk [ROUNDS + 1]; / * Ключі ітерації * /

expand_key (key.rk); / * Сформувати ключі ітерацій * /
copy_plaintext_to_text (state, plaintext); / * Ініціалізація поточного стану; * /
xor_roundkey_into_state (state, rk [0]); / * Скласти по модулю 2 ключ з поточним станом * /

for (r = 1; r <= ROUNDS; r ++) {
substitute (state); / * Пропустити кожен байт через S-блок (підстановка) * /
rotate_rows (state); / * Повернути рядок і на і байт (поворот - зсув рядків) * /
if (r <ROUNDS) mix_columns (state); / * Функція змішування (множення в полі Галуа) * /
xor_roundkey_into_state (state, rk [r]); / * Скласти по модулю 2 ключ з поточним станом * /}
copy_state_to_ciphertext (ciphertext, state); / * Повернути результат * /}
```

ДСТУ 7624:2014 (“Калина”) «Інформаційні технології. Криптографчічний захист інформації. Алгоритм симетричного блокового перетворення».

ДСТУ 7564:2014 (“Купина”) «Інформаційні технології. Криптографчічний захист інформації. Функція гешування».

Розмір блока та ключа 128, 256 та 512 біт. 10-14-18 циклів.

ДСТУ 4145-2002 «Інформаційні технології. Криптографчічний захист інформації. Електронний цифровий підпис, що грунтується на еліптичних кривих. Формування та перевіряння».

Режими роботи алгоритмів шифрування

Блокове шифрування:
Режим електронного шифроблокнота (або електронної книги кодів, ECB - Electronic Codebook Mode).

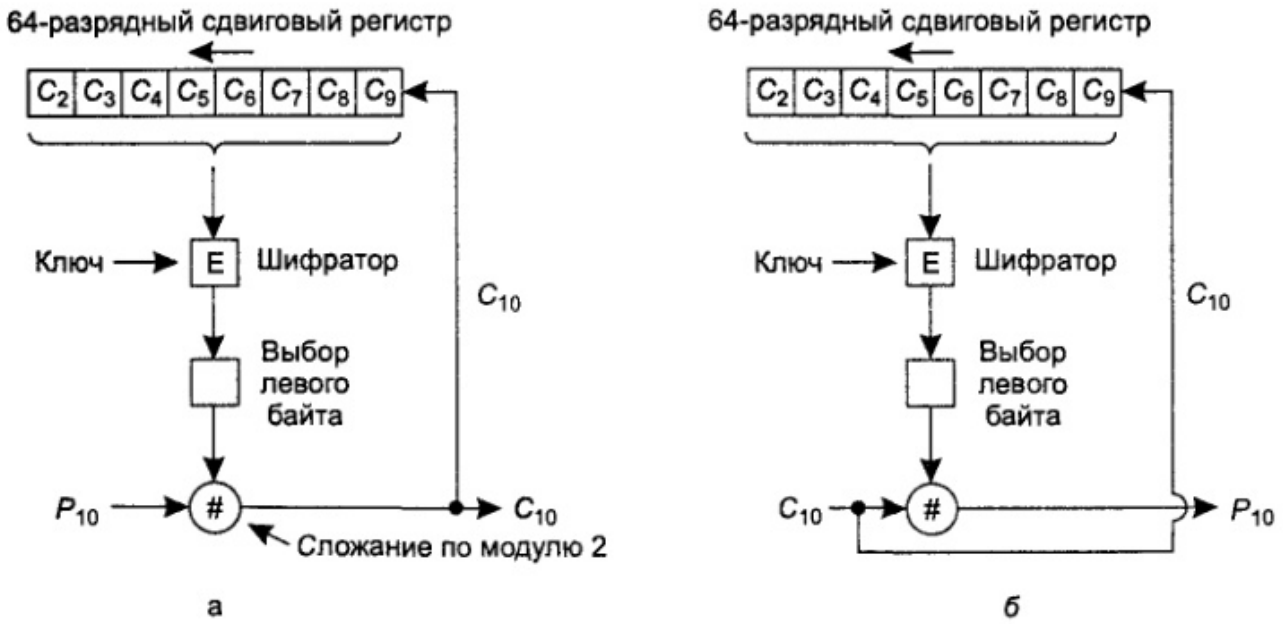
Зчеплення блоків зашифрованого тексту (або ланцюгування шифроблоків, CBC — Cipher-block Chaining)

Сцепление зашифрованных блоков: шифрование (*а*); дешифрация (*б*)

Недолік: розповсюження помилки

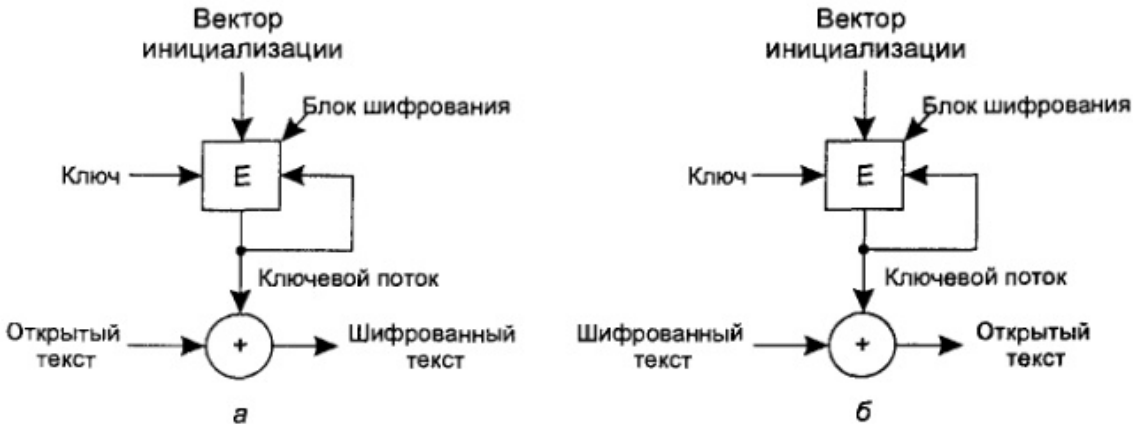
Потокове шифрування:

Режими *шифрованого зворотного зв'язку* (або зі зворотним зв'язком за шифртекстом, CFB - Cipher Feedback)



Режим шифрованной обратной связи (*а*); обратная связь по выходу (*б*)

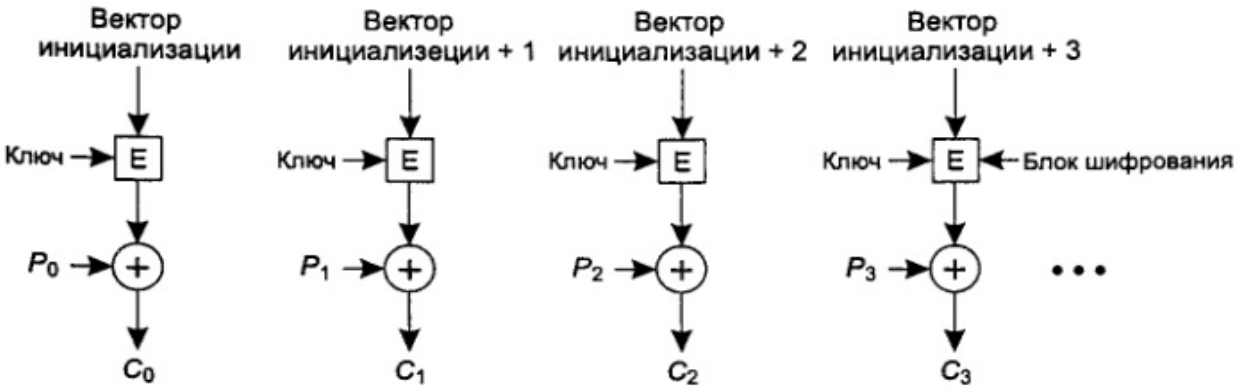
Режим шифрування зі зворотним зв'язком по виходу (OFB - Output Feedback)



Групповой шифр: шифрование (*а*); дешифрация (*б*)

Генерація шифропотока на основі блочного шифру
Ключові блоки складаються із відкритим текстом
Дешифрація - дзеркально
Дозволяє функціонувати кодам з виправленням помилок
Ключовий потік генерується незалежно від тексту

Р*ежим лічильника (*CTR – Counter Mode*)*



Шифрование в режиме счетчика

Режим електронного шифроблокнота - вразливий до атак заміни блоків
Зчеплення блоків шифру — для шифрування повинен з'явитися цілий блок
Шифрування зі зворотним зв'язком - пошкодження одного біта впливає на 8 байт
Режим лічильника - доступ до довільної частини тексту (файлу)

Асиметрична криптографія (шифрування з відкритим ключем)
(передача ключа завжди була слабкою стороною криптосистеми)

1976 р Діффі і Геллман

- D(E(P))=P
- Складно вивести D з E (одностороння функція із «секретом»)
- E неможливо зламати з використанням довільного відкритого тексту

E_A – алгоритм шифрування (відкритий ключ)
D_A – алгоритм дешифрування (таємний ключ)

Асиметричні алгоритми шифрування використовують складність знаходження дільників великих чисел (розкладання на прості множники) (RSA) або обчислення дискретних логарифмів (схема Ель-Гамаля, 1985 г., алгоритм DSS) або операції в групах на еліптичних кривих.

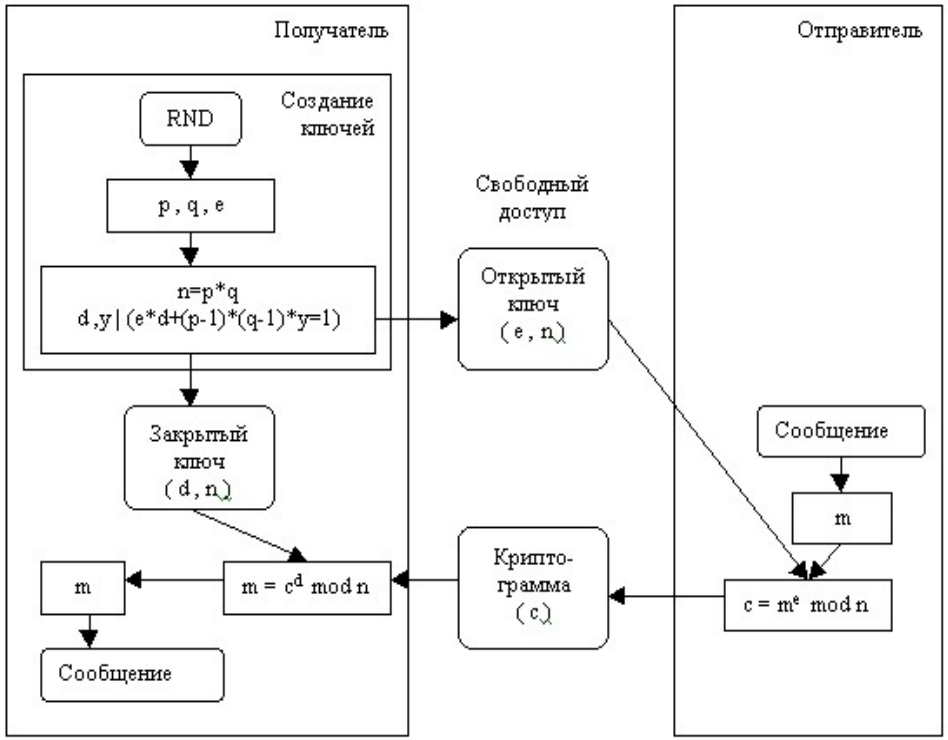
Алгоритм RSA (Rivest, Shamir, Adleman)

1. Оберемо два великих простих числа p и q (довжиною не менше за 1024 біта).
2. Обрахуємо $n=pq$ и $z = (p- 1)(q - 1)$.
3. Оберемо число d, яке є взаємно простим із числом z.
4. Занайдемо таке число e, що остача від ділення добутку ed на число z дорівнює 1.

P – повідомлення; $0 < P < n$
Шифрування: $C = P^e \pmod n$; відкритий ключ - (e, n)
Розшифрування: $P = C^d \pmod n$; таємний ключ - (d, n)

* Розкриття RSA ~ знаходження множників числа
* При еквівалентній таємності ключі асиметричних алгоритмів значно довші за ключі симетричних алгоритмів, а обчислення на кілька порядків складніші.

Алгоритм RSA

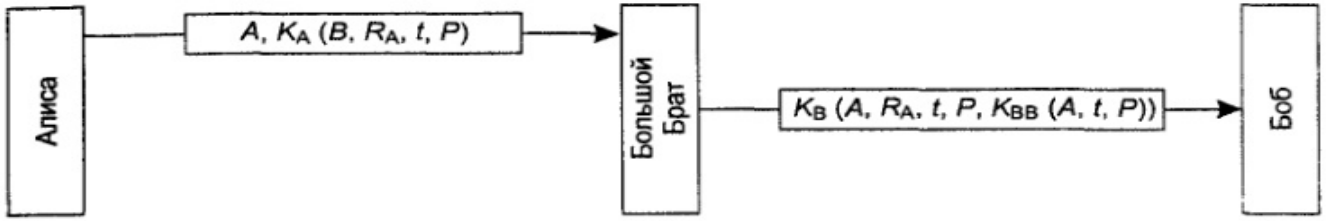


*Не обирайте одне ***n*** для декількох користувачів (пар ключів).
*Більш безпечно підписувати ЕЦП геш повідомлення, а не саме повідомлення.
*Доповнюйте повідомлення випадковими числами.

Цифровий підпис

Функція повідомлення:

- підтвердження автентичності повідомлення
- одержувач в змозі перевірити оголошену особу відправника (автора);
- відправник не в змозі пізніше заперечувати вміст повідомлення;
- одержувач не в змозі пізніше змінити підписане повідомлення.

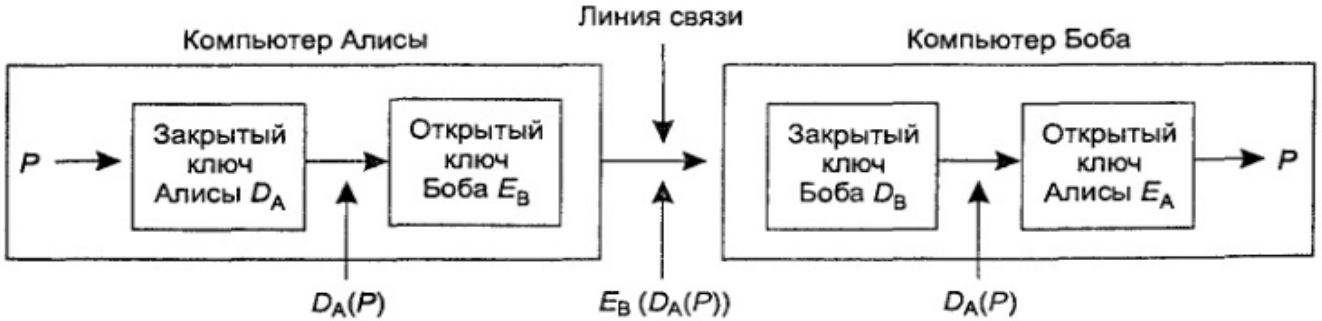


Цифровая подпись Большого Брата

Кожний абонент сам обирає свій ключ та заносить в *підтверджуючу інстанцію*.
Всі абоненти повинні довіряти *підтверджуючій інстанції.*
R_A – випадкове число; t – відмітка часу; P – текст повідомленні; B – адресат
K_A – текст повідомлення, зашифрований ключем A
Випадкове число та відмітка часу – захищають від атак повторення (reply).
Вміст повідомлення передається у відкритому вигляді.

Цифровий підпис с відкритим ключем

Необхідно D(E(P))=P и E(D(P))=P
Для цифрового підпису можливо використовувати будь-який алгоритм шифрування з відкритим ключем
Існують спеціальні алгоритми тільки для цифрового підпису, наприклад DSS (схема Ель Гамаля)



Цифровая подпись, полученная при помощи шифрования с открытым ключом

А знає таємний ключ D_A та відкритий ключ E_B
Система зберігає таємність, допоки таємний ключ D_A.
Проблема змінення ключа.

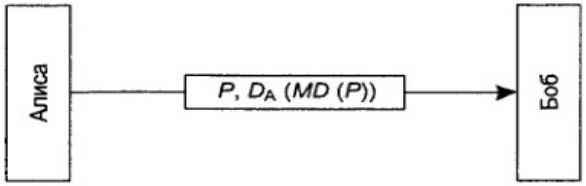
Профілі повідомлень

(Потрібна тільки автентифікація повідомлення, але не шифрування всього повідомлення - незмінність повідомлення без таємності)

Профілі повідомлень грунтуються на односторонній (криптографічній, безпечній) геш-функції (профіль повідомлення, message digest, MD).
Вхід - фрагмент тексту довільної довжини, вихід - рядок бітів фіксованої довжини.

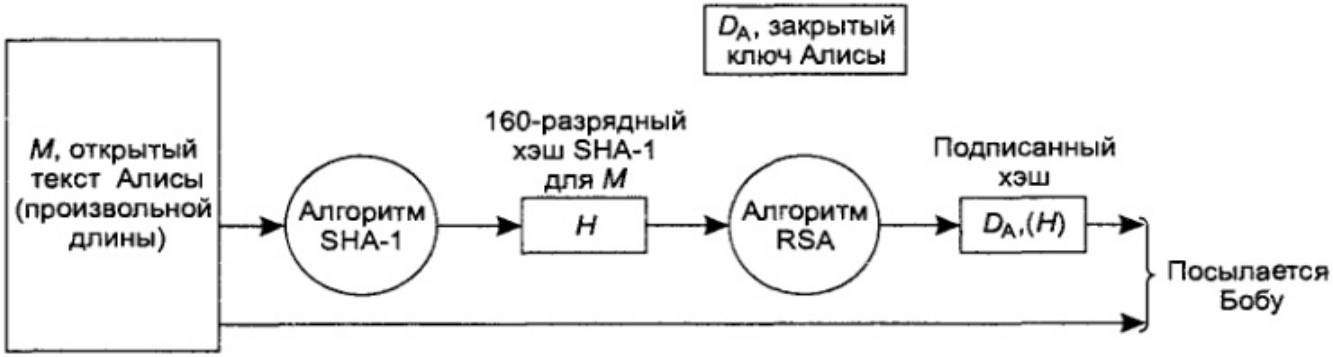
Щоб геш-функція була крипостійкою, має виконуватися:

- По заданому відкритому тексту P легко обрахувати значення геш-функції MD (P).
- Зміна навіть одного біта вхідної послідовності призводить до зовсім не схожого результату (лавиновий ефект).
- По цифровому підпису *MD(P)* практично неможливо відтворити значення відкритого текста *P*.
- Для даного *P* практично неможливо підібрати такий *P',* щоб виконувалось *MD(P') = MD(P)* (стійкість до колізій першого роду).
- Практично неможливо знайти пару (*P, P'*), щоб *MD(P') = MD(P)* (стійкість до колізій другого роду).



Цифровая подпись с использованием профиля сообщения

MD5 (Rivest, 1992) – 128 бітний профіль повідомлення
SHA-1(NIST, 1993) – 160 бітний профіль повідомлення
Розмір вхідного блока в MD5 и SHA-1 – 512 біт.



Применение SHA-1 и RSA для создания подписей несекретных сообщений

(Боб також обчислює хеш повідомлення і перевіряє його ідентичність)

ДСТУ 4145-2002 "Інформаційні технології. Кріптографічній захист інформації. Електронний цифровий підпис, что грунтується на еліптічніх кривих"

Криптографія з відкритим ключем дозволяє передавати дані, перевіряти цілісність і автентичність повідомлень, створювати ЕЦП, не маючи загального (поділюваного) ключа і без участі 3-ї сторони.

Проблема початкового обміну ключами не вирішується в рамках криптосистеми !!!
(Якщо викласти ключ на сайті і т.п. - можлива атака «людина посередині»)

Керування ключами

Центр сертифікації ключів - видає сертифікати, що засвідчують відкриті ключі суб'єктів.
Єдиний центр - не масштабується та є єдиною точкою вразливості (ключ центру) і відмови.

Центр сертифікації (CA - Certification Authority)

Настоящим удостоверяю, что открытый ключ 1SWV35CNK5VD67ER7EWV5SEKJNVCEP…..WK8WFB1FWD принадлежит Пупкину Ивану Иванычу Какая-то там улица 32 Цурюпинск, 21541 1967 род. 30 февраля Электронный адрес: pupkin@no.domain.com
Хэш SHA-1 данного сертификата подписан закрытым ключом Управления сертификации

Сертифікат відкритого ключа пов'язує відкритий ключ суб'єкта-принципала (користувача, сайта, процеса ...) з його атрибутами.
Сертифікат не є секретом. Зловмисник не може підробити ЦП Центру сертифікації.

Формат сертифіката X.509

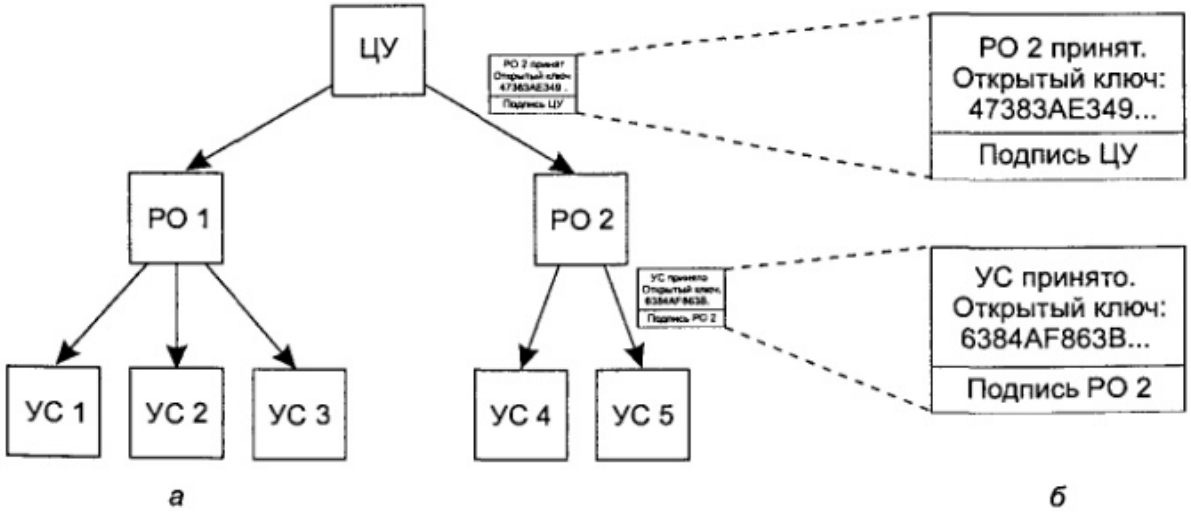
Поле	Значення
Version	Версія X.509 (актуальна версія – 3)
Serial number	Це число та назва Центру сертифікації однозначно ідентифікує сертифікат
Signature algorithm	Алгоритм генерації підпису сертифіката
Issuer	X.500-ім`я Управління
Validity period	Початок та закінчення періоду дійсності
Subject name	Суб`єкт, ключ якого засвідчує цей сертифікат
Public key	Відкритий ключ суб`єкта та ідентифікатор алгоритма генерації ключа
Issuer ID	Необов`язковий унікальний ідентифікатор, що визначає емітента сертификата (Центр сертифікації)
Subject ID	Необов`язковий унікальний ідентифікатор, що визначає власника сертифіката (ключа)
Extensions	Можливі розширення (додаткові дані)
Signature	Підпис сертифіката (генерується за допомогою таємного ключа Центру сертифікації)

X.509 – стандарт сертифікатів

X.500 – стандарт ієрархічного йменування ресурсів

PKI (Public Key Infrastructure) - інфраструктура відкритих ключів

Єдиний всесвітній Центр сертифікації не витримав би навантаження і став би коренем усіх проблем. Якщо використовувати ряд ідентичних Центрів - посилюється проблема витоку ключів. Альтернатива єдиному центру сертифікації - інфраструктура центрів сертифікації (відкритих ключів).



Иерархия PKI (*а*); цепочка сертификатов (*б*)

У прикладі показано 3 рівня ієрархії центрів сертифікації. Кореневий сервер затверджує (підписує) сертифікати центрів (серверів) наступного рівня. Вважаємо, що ключ ЦУ знають усі (наприклад, цей ключ зашитий в Інтернет - браузері).

Центри (сервера) сертифікації можуть завіряти сертифікати суб'єктів або центрів (серверів) наступного рівня.

Для відкриття *захищеного* сеансу з деяким суб'єктом B необхідно:
1. Отримати ключ B, підписаний деяким УС.
2. Отримати сертифікат УС, підписаний деякими РО.
3. Користуючись сертифікатом ЦУ, перевірити підпис РО.

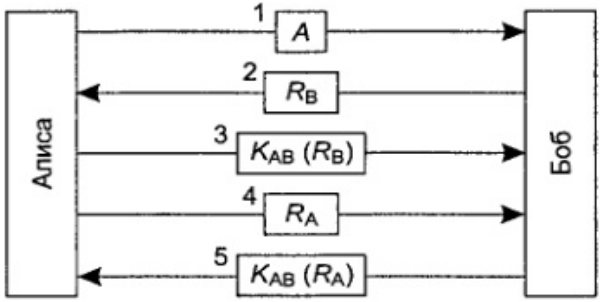
Інший варіант - суб'єкт при відкритті сеансу сам надає ланцюжок сертифікатів, що засвідчують його сертифікат.

Проблема анулювання сертифікатів до закінчення терміну придатності.
CRL (Certificate Revocation List - список відкликаних сертифікатів) - надається і регулярно оновлюється кореневим сервером.
Проблема відновлення сертифікатів.

Зберігати сертифікати найзручніше в ієрархічних каталогах (DNS, LDAP).

Автентифікація - метод, за допомогою якого суб'єкт (процес) засвідчується в тому, що його співрозмовник є саме тим, за кого він себе видає.
Автентифікація - перевірка справжності. Авторизація - дозвіл на деякі дії.
Зазвичай - двостороння (взаємна) автентифікація. У процесі автентифікації, зазвичай, встановлюється *ключ сеансу* (тимчасовий ключ) - основні секретні або відкриті ключі використовуються мінімальну кількість разів.

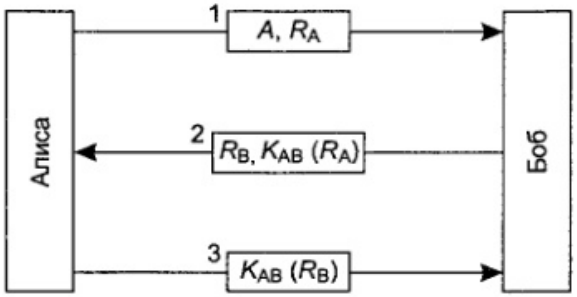
Автентифікація на основі таємного ключа



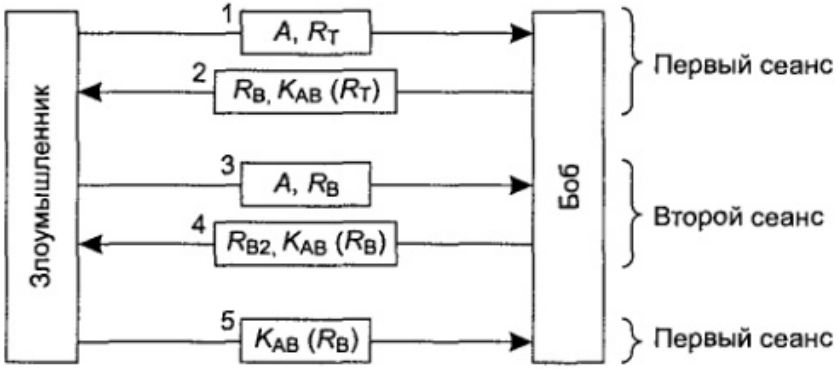
Двусторонняя аутентификация при помощи протокола оклик—отзыв

Нехай у А и В поділюваний таємний ключ шифрування K_{AB} (не передаєтся по мережі, зловмисник не знає ключ).
R_B, R_A – «виклик» - випадкове число. Малоймовірно, що R_A та R_B раніш зустрічались зловмиснику.
Після автентифікації А та В встановлюють ключ сеансу.

Дзеркальна атака



Укороченный двусторонний протокол аутентификации



Зеркальная атака

Якщо спробувати скоротити число кроків в протоколі до 3-х, то зловмисник зможе відкрити декілька сеансів і повторити виклик В і, в результаті, отримати коректне значення K_{AB}.

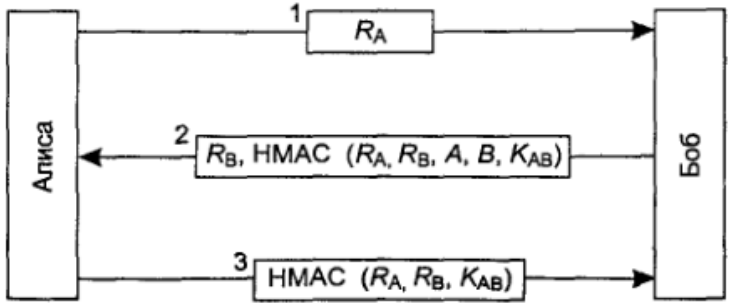
Чотири загальних правила, яким повинні задовольняти протоколи автентифікації:

1. Ініціатор сеансу повинен підтверджувати свою особу перш, ніж це зробить відповідаюча сторона. В цьому випадку зловмисник не зможе отримати цінної для нього інформації перш ніж підтвердить свою особу (надавати якомога менше інформації для можливого аналізу).
2. Слід використовувати два відмінних загальних секретних ключа: один для ініціатора сеансу, а інший для відповідаючої сторони, Kab і Kab '.
3. Ініціатор і відповідаюча сторона повинні обирати виклики з різних множин, що не перетинаються. Наприклад, ініціатор повинен користуватися парними номерами, а відповідаюча сторона - непарними.
4. Протокол повинен вміти протистояти атакам, при яких відкривається другий паралельний сеанс, інформація для якого витягується за допомогою першого сеансу.

Якщо порушується хоча б одне з цих правил - протокол виявляється вразливим. На цих правилах грунтуються методики побудови та доказу коректності протоколів автентифікації.

Протокол автентифікації з використанням функції HMAC

HMAC (Hashed Message Authentication Code) – криптографічна геш-функція.



Аутентификация с применением HMAC

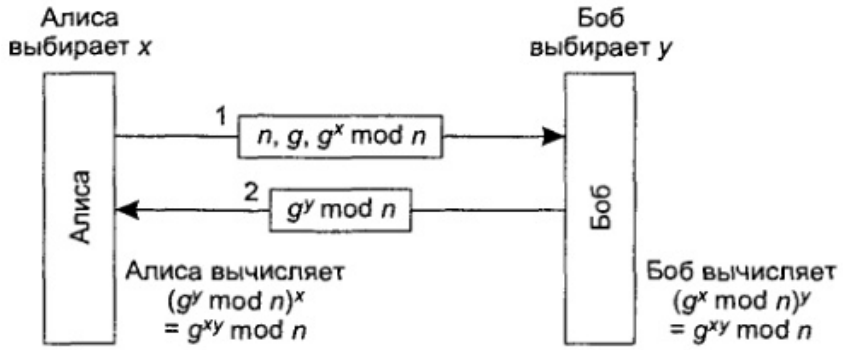
R_A –відмітка часу, K_{AB} – загальний для А та В таємний ключ.

Зловмисник не знає ключ K_{AB} та не в змозі вгадати HMAC і також не може примусити іншу сторону зашифрувати обране повідомлення чи застосувати HMAC.

Обидва HMAC містять значення, які обирає відправник.

Протокол Діффі-Геллмана

(протокол узгодження таємного ключа по відкритим каналам)

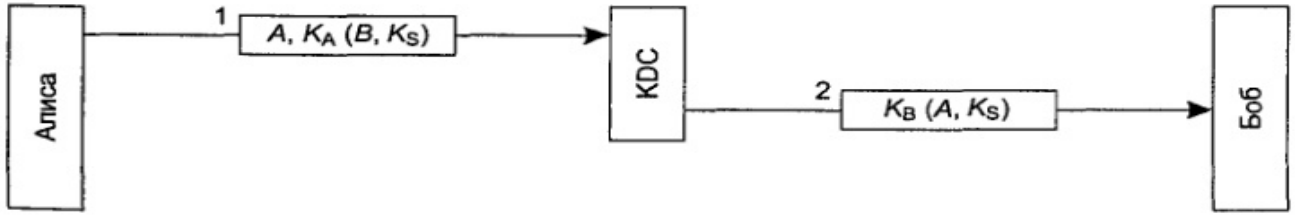


Обмен ключами Диффи—Хеллмана

А та В домовляються про два простих числа n и g; $(n-1)/2$ – також просте
Кожна зі сторін обирає 512-бітне число (x та y)
А надсилає ($n, g, g^X mod\ n$), В відповідає ($g^Y\ mod\ n$)
Обидві сторони обчислюють $g^{XY} mod\ n$ – загальний таємний ключ
В результаті майже вдалось знайти загальний ключ (протокол не стійкий до атаки «людина посередині»).

Складність взлому алгоритма зводиться до задачі обчислення дискретного логарифма великого простого числа.

Якщо організувати центр росповсюдження ключів (KDC – Key Distribution Center) – у кожного користувача має бути один ключ, поділюваний з KDC.

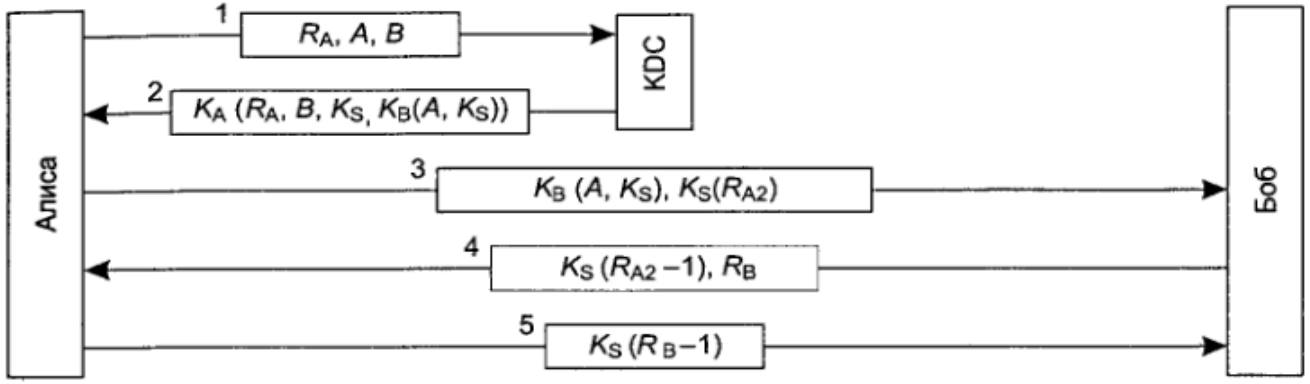


Первая попытка протокола аутентификации с помощью KDC-центра

K_A, K_B – ключі суб`єктів; K_S – ключ сеанса.

Протокол не захищений від атаки повторення.
Якщо ввести в повідомлення часовий штамп (відмітку часу), то виникає проблема синхронізації годинникв (у повідомлень буде термін придатності, протягом якого повідомлення можливо надіслати повторно).
Якщо ввести в повідомлення НОНС (порядковий номер, «nonce» - даний час), то сторони повинні пам'ятати попередні нонси довічно (інакше з'являється можливість атаки повторення), а це ускладнює протокол.
Замість цього в протоколі Нідхема-Шредера використовується багатокроковий виклик - відгук.

Протокол автентифікації Нідхема – Шредера (протокол взаємної автентифікації)



Протокол аутентификации Нидхэма—Шрёдера

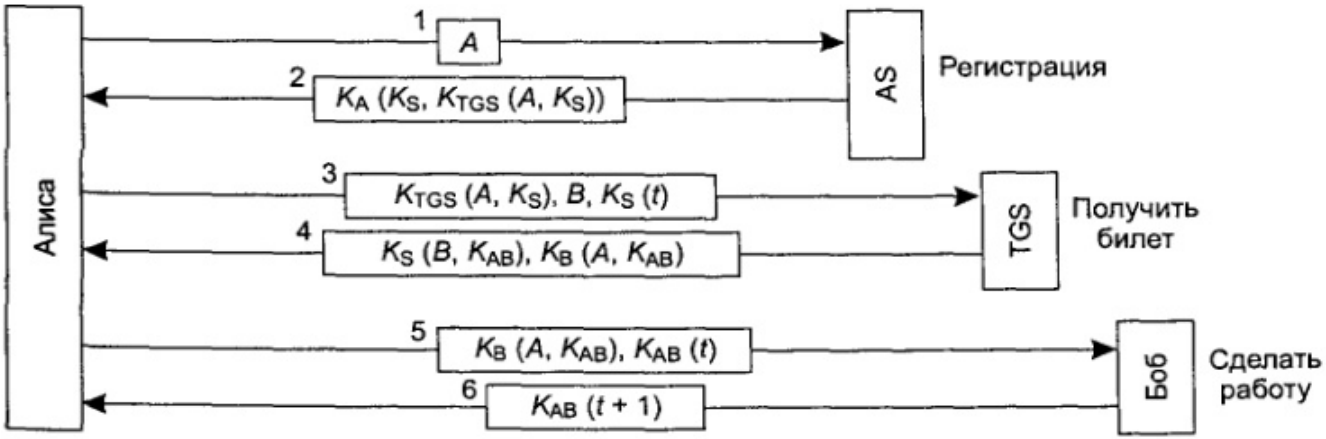
K_S – ключ сеансу; K_B(A, K_S) – білет для B, зашифрований ключем B.
R_A – випадкове число, щоб впевнити A, що повідомлення 2 свіже.
Задача Кроку 4 – довести, що B – справжній.
Задача Кроку 5 – впевнити B, що він размовляє з A.

Захист від атак повторення:

1. Відмітка часу (часовий штамп) t — проблема синхронизації годинників та термін придатності, протягом якого можливе повторення повідомлення
2. Нонс (або порядковий номер) — потрібно пам`ятати довічно (ускладнює протокол)

Протокол автентифікації Керберос

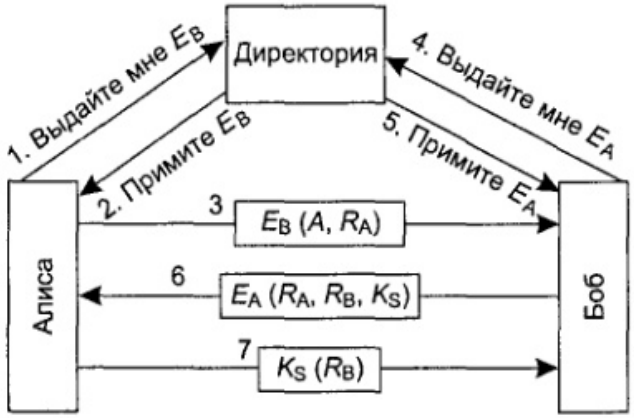
Грунтується на протоколі Нідхема – Шредера. Потребує синхронізації годинників.



Работа протокола Kerberos V4

AS – сервер автентификації; TGS (Ticket Granting Server) – сервер видачі квитків.
Використовується відмітка часу (часовий штамп) t.
1. Запит на реєстрацію
2. K_{tgs}(A, K_S) – квиток для TGS.
Після кроку 2 A на основі пароля формує ключ K_A а пароль знищується.
3. Запит квитка для сеансу с B. K_{tgs}(A, K_S) підтверджує відправника.
4. TGS видає A K_{AB} – ключ для сеансу A-B (одна копія зашифрована для A, інша – для B).
B отримує ключ сеанса K_{AB}
B підтверджує свою справжність.
Права доступу для A визначає B.
Для відкриття нового сеансу з деяким сервером C має знов звернутись до TGS для видачі квитка.
Паролі в мережі не передаються.

Взаємна автентифікація з використанням шифрування з відкритим ключем



Взаимная идентификация с помощью открытого ключа

1. Запит відкритого ключа B в PKI (PKI використовує, наприклад, структуру серверів LDAP).
2. Отримати відкритий ключ B.
3. Запит на встановлення сеансу з B. Містить ім`я A та випадкове R_A, зашифроване ключем B
4. B запитує у сервера каталогу видати ключ A
5. Сервер каталогу видає ключ A
6. A розшифровує повідомлення та бачить своє R_A (підтверджує справжність B та свіжість повідомлення). B формує ключ сеанса A-B.
7. A перевіряє R_A та погоджується на сеанс, надсилає відмітку R_B (сформовану B) та зашифровану ключем сеансу (ключ сеанса зформував B).

Підробити повідомлення 3 заважає R_A.
Підробити повідомлення 7 заважає R_B и K_S (неможливо отримати не знаючи таємний ключ A).

Питання по темі:

Що таке криптографічне перетворення.
Завдання криптографії, криптології та криптоаналізу.
Принцип Керкгоффа.
Основні принципи криптографії.
Що таке імітостойкость шифрування.
Види атак на криптографічні алгоритми.
Напрямки криптоаналіза.

Базові операції шифрування.
Операції підстановки і перестановки.
Як виразити операцію підстановки через перестановку.
Метод гамування. Що таке «досконала безпека»
Що таке одноразовий шифроблокнот. Його властивість.
Відмінності симетричних та асиметричних алгоритмів шифрування.
Відмінності поточного і блочного шифру.

Стандарт DES. Розмір блоку і довжина ключа.
Які перетворення використовує алгоритм DES.
Що розуміється під «лавиновим ефектом» в криптоперетвореннях.
Що таке S-блоки. Принципи вибору S-блоків в алгоритмі DES.
Які методи криптоаналізу можуть використовуватися для прискорення розкриття алгоритму DES.
Які чинники можуть послабити властивості таємності алгоритму DES.
Модифікації алгоритму DES.
Стандарт AES. Розмір блоку і довжина ключа.
Які основні перетворення використовує алгоритм AES.
Який математичний апарат доводить властивості алгоритму AES.
Від чого залежить кількість ітерацій в алгоритмі AES.
Що таке *поріг таємності* криптоалгоритма.

Режими роботи алгоритмів шифрування і їх особливості.

Властивості асиметричних алгоритмів шифрування.
Що таке одностороння (незворотня) функція.
Які математичні проблеми обгрунтовують складність обернення асиметричних криптографічних алгоритмів.
Алгоритм RSA. Опис роботи.

Що таке цифровий підпис. Властивості ЦП.
Цифровий підпис з відкритим ключем. Схема застосування.
Що таке профіль повідомлення. Його властивості. Приклади.
Що таке цифровий сертифікат. Які параметри він містить.
Для чого використовується інфраструктура відкритих ключів.
Принцип делегування і перевірки сертифікатів.
Для чого використовуються «ланцюжки сертифікатів».

Що таке автентифікація. Відомі алгоритми автентифікації.
Приклад алгоритму автентифікації.
Правила, яким повинні задовольняти протоколи автентифікації.
Відомі протоколи автентифікації.
Протокол автентифікації Керберос.
Протокол автентифікації Діффі- Геллмана.
Алгоритм автентифікації з використанням шифрування з відкритим ключем.

Література:

1. Столлингс В. Криптография и защита сетей: принципы и практика. М.: Вильямс, 2001. ISBN 5-8459-0185-5.

2. Шнайер Б. Прикладная криптография. Протоколы, алгоритмы, исходные тексты на языке Си. - М.: Триумф, 2002. — 816 с. ISBN 5-89392-055-4

3. Брассар Ж. Современная криптология. - М.: Полимед, 1999.— 176 с.

4. Мао В. Современная криптография. - М.: Диалектика, 2005.— 768 с.

5. Иванов М.А. Криптографические методы защиты информации в компьютерных системах и сетях. М.: КУДИЦ-ОБРАЗ, 2001 – 368 с.

6. Баричев С.Г., Гончаров В.В., Серов Р.Е. Основы современной криптографии — 3-е изд. - М.: Диалог-МИФИ, 2011. - 176 с. ISBN 978-5-9912-0182-7

Принципи та протоколи ідентифікації і автентифікації

Ідентифікація - іменування та розпізнавання суб'єктів.

Автентифікація - процедура перевірки справжності суб'єктів
Надійність ідентифікації забезпечується унікальністю ознак, що використовуються.
Надійність автентифікації забезпечується труднощами підробки цих ознак.

Авторизація - надання суб'єкту ресурсів і повноважень (визначення сфери дії і доступних ресурсів)

Підтвердження справжності суб'єкта:
-щось знає (пароль, ключ, PIN – код, або ынша таємна інформація)
-чимось володіє (магнітна картка, смарт картка, якійсь пристрій ...)
-чимось є (невід'ємні біометричні характеристики)

Способи автентифікації:
-Пароль (PIN, поділювана інформація) - проста автентифікація
-Разовий пароль (OTP)
-Протокол Запит-Відповідь
-Цифровий підпис (можливо, з використанням Сертифікату відкритого ключа)

Разові (динамічні) паролі:
-Список паролів
-Функція генерації послідовності паролів (Псевдовипадкові числа)
-Паролі, що залежать від функції часу (номера послідовності)
-Апаратні пристрої (в середині — шифрування або геш-функція або ГПВЧ)

Протокол - набір правил, що описують процедуру обміну інформацією

Атаки на протоколи автентифікації:
-Підміна суб'єкта
-Повторення (reply)
-Дзеркальная атака
-Людина посередині (подвійна гра)

Запобігання атак відтворення - механізм Запит-Відповідь з елементом, що ніколи не повторюється:
-Відмітка часу (наприклад, монотонно зростаюча функція)
-Випадкові числа (не допускати повторення ВЧ в рамках сеансу)
* Проблема синхронізації часу

Сувора автентифікація - одна сторона демонструє (доводить) знання секрету, але сам секрет в ході обміну не розголошується.
-Однобічна (одностороння) геш-функція (дайджест) з випадковим числом
-Володіння таємним ключем (цифровий підпис з таємним ключем)

Двостороння (взаємна) автентифікація - обидві сторони обміну автентіфікують одна-іншу.

Тристороння автентифікація - автентифікація із залученням третьої сторони (центру сертифікації ключів, сервера автентифікації, сервера видачі квитків (ключів), ...)

Протоколи суворої автентифікації використовують:
-симетричні алгоритми шифрування
-односторонні (криптографічні) геш-функції
-асиметричниі алгоритми шифрування
-алгоритми цифрового підпису (ЕЦП)

Протоколи автентифікації:

-PAP - проста автентифікація, пароль передається у відкритому вигляді
-CHAP - протокол запит - відповідь
-S/Key - система разових паролів
-TACACS(+), RADIUS - протоколи автентифікації з архітектури NAC
-EAP - розширюваний протокол автентифікації

-Kerberos - протокол автентифікації в службі Microsoft Active Directory
-IKE (Internet Key Exchange) - протокол автентифікації сторін і узгодження поділюваного таємного ключа в архітектурі IPSecurity

Системи єдиної реєстрації:
-Active Directory
-Novell Directory
-NIS
-IBM Tivolly Identity Manager

Біометрична автентифікація

-достовірність і складність фальсифікації
-невід`ємність від суб'єкта

Способи біометричної автентифікації:
-Дактілоскопія (відбитки пальців)
-Геометрична форма долоні
-Форма і розміри обличча, Інфрачервона карта обличча
-Особливості голосу (висота, модуляція і частота звуку)
-Характеристики райдужної оболонки і сітківки ока
-Клавіатурний почерк

Помилки систем ідентифікації з розпізнаванням образів:
-Коефіцієнт помилкових відмов
-Коефіцієнт помилкових підтверджень

Радіочастотна ідентифікація (автентифікація) - RFID

Питання:

Завдання ідентифікації, автентифікації, авторизації
Способи автентифікації
Атаки на протоколи автентифікації
Способи запобігання атаки повторення
Що таке сувора автентифікація, взаємна автентифікація, непряма автентифікація

Література:

Смит Р. Аутентификация: от паролей до открытых ключей.: М. : Изд. дом "Вильямс". 2002. - 432 с.
Дшхунян В.Л., Шаньгин В.Ф. Электронная идентификация. Бесконтактные электронные идентификаторы и смарт - карты. - М.: ООО "Издательство АСТ": Издательство "НТ Пресс", 2004. - 695 с.

Засоби і методи захисту ОС. Засоби захисту в ОС Unix.

"У майбутньому комп'ютери будуть важити не більше за півтори тонни ..."
(З журналу «Популярна механіка», 1949 р ., США)

Історія

Мейнфрейми → Мінікомп'ютери (PDP-11) → Мікрокомп'ютери (PC)

З 1965 - в GE робота над багатозадачною ОС (MULTICS) - поділ часу, багатозадачність, сегментно-сторінкова віртуальна пам'ять, spooling, ієрархічна ФС - Керниган, Рітчі, Томпсон (мова PL/1)
1.01.1970 - UNICS (PDP-7, Assembler, ФС, управління процесами, утиліти)
1973 - ядро на мові С (переносимість на інші платформи) – Д.Рітчі, К.Томпсон із Bell Labs (спочатку була мова В - діалект BCPL)
PDP-7 → PDP-11 (24K RAM, 512K HDD) → PDP-11/20 (32K RAM) → PDP-11/45 (256K RAM) → PDP-11/70 (2MB RAM) (16 розрядні ЕОМ)
1974 - BSD UNIX (Berkeley), переписаний первісний код
1975 - AT & T UNIX (SunOS, Solaris, AIX, HPUIX, IRIX)
1977 - безліч клонів UNIX (в т.ч. Xenix (Microsoft); Xenix 2 - для PC)
СРСР - Демос (UNIX v.7 VAX), УНАС
1980 - стек мережних протоколв TCP / IP
1983 - проект GNU
1987 - Minix (Танненбаум) - мікроядро, висока модульність
1989 - System V Release 4 (SVR4) vs. BSD4.3 (об'єднання ідей для сумісності - POSIX)
5.10.1991 - Linux (UNIX для PC)
з 1992 - ряд безкоштовних клонів 386BSD, NetBSD, OpenBSD, FreeBSD

Архітектура

Рівні ПО ОС (відмінності в рівні привілеїв):

- ядро ОС
- утиліти (компілятори, відладчики, мережне ПО, СКБД, бібліотеки)
- ПО користувача

Ядро ізолює прикладні програми та надає послуги послуговуючись інтерфейсами системних викликів

Підсистеми ядра:

- Файлова: практично всі операції введення / виведення через ФС.
- Введення-виведення: виконує виклики ФС і взаємодіє з драйверами.
- Управління процесами і пам'яттю: розподіл ресурсів, синхронізація, межпроцесорна взаємодія. Підтримка віртуальної пам'яті.

Інтерфейси системних викликів.
Монолітне ядро - недолік з точки зору безпеки.

Загрози безпеці ОС

- Вразливості мережних служб;
- Відмова в обслуговуванні;
- НСД через сканування ФС і збір сміття;
- Підвищення привілеїв і неавторизоване виконання довільного коду;
- Атаки на автентифікацію (перехоплення протоколів, атаки на паролі і геши);
- Віруси;
- Програмні закладки;
- Фізичний доступ, крадіжка комп`ютера, альтернативне завантаження комп`ютера;

- Перевищення повноважень (вразливості або помилки реалізації політики безпеки);
- Викрадення ключової інформації - політика безпеки (паролів);
- Підбір паролів - політика паролів, гешування;
- Доступ до консолі, сканування файлової системи (НСД; атака на політику безпеки) - найчастіше через некоректне налаштування прав доступу;
- Пошук інформації на робочому місці;
- Збір сміття (в звільнених об'єктах ОС - файлах або блоках пам'яті);
- Завантаження альтернативної ОС (зі змінних носіїв);
- Крадіжка портативних комп'ютерів;
- Випадкова втрата даних.

Модель безпеки UNIX

Сервіси і підсистеми захисту ОС:

- Ідентифікація та автентифікація
- Керування доступом
- Реєстрація, облік і аудит (+ захист і аналіз журналів реєстрації)
- Захист оперативної пам`яті, знищення залишкових даних
- Антивірусний захист
- Управління політикою безпеки і параметрами захисту (інтерфейси управління)
- Оповіщення, реагування і відновлення безпеки
- Криптографічні функції (шифрування, цілісність, управління ключами)
- Апаратні засоби

Апаратна підтримка захисту ОС

- Режими користувача і ядра
- Керування процесами
- Захист адресного простору: віртуальна пам'ять, трансляція адрес, захист даних на рівні сегментів

Підсистема автентифікації

- Користувачі розрізняються по UID (унікальний ідентифікатор суб`єкта)
- Звичайні та спеціальні (фіктивні) користувачі
- Процедура login (login -> /etc/passwd -> shell -> UID)
- (/etc/shadow - геш паролів)

- PAM модулі (OTP, openkey, biometric)
- Політика облікових записів (паролів) - /etc/shadow

/etc/passwd:

```
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
mail:x:8:12:mail:/var/spool/mail:/sbin/nologin
ftp:x:14:50:FTP User:/var/ftp:/sbin/nologin
nobody:x:99:99:Nobody:/:/sbin/nologin
named:x:25:25:Named:/var/named:/sbin/nologin
mysql:x:27:27:MySQL Server:/var/lib/mysql:/bin/bash
```

им`я_користувача : ознака_пароля : UID : GID : інформація : домашній_каталог : командна_оболонка

/etc/shadow:

root:1RPUZppmb$BZ/3Q93E7Lw3YChr21g4P.:14871:0:99999:7:::
bin:*:13794:0:99999:7:::
apache:!!:13794:0:99999:7:::

- реєстраційне ім'я користувача
- геш пароля
- число днів з 01.01.1970 до дня останньої зміни пароля
- мінімальне число днів дії пароля з дня його останнього зміни
- максимальне число днів дії пароля
- число днів до видачі попередження про зміну пароля
- число днів з часу обов'язкової зміни пароля до блокування облікового запису
- день блокування облікового запису

Групи (UID), основна група (/etc/passwd), інші (/etc/group)

/etc/group:

root:x:0:root
bin:x:1:root,bin,daemon
ftp:x:50:

Підсистема керування доступом (авторизації)

Суб'єкти доступу - користувачі (ідентифікатор — UID).
Процес виконується від імені деякого користувача і є носієм його повноважень.
Об'єкти доступу - файли (каталоги, посилання(links), канали обміну інформацією (pipes), логічні пристрої)

Root (UID = 0) - операції суперкористувача не обмежені системою керування доступом
Обмеження прав суперкористувача: su, термінал входу (/etc /securetty), sudo (/etc/suduers)

Файлові системи UNIX:
Вся інформація про файли - таблиця індексних дескрипторів (inode).
У каталогах ім'я + посилання на inode (каталог - текстова таблиця)
Монтування (узгодження файлових систем, каталог /mnt)

Модель керування доступом:
RWX for owner, RWX for group, RXW for others (R=4, W=2, X=1) + SUID, SGID, Sticky bit

	[root@localhost test]# ls -l total 4
SGID+Sticky	drwxr-**s**r-**t** 2 root root 4096 Mar 23 13:12 dir1
for Owner	-**rwx**r--r-- 1 root root 0 Mar 23 12:56 file1
for Group	-rw-**rw-**r-- 1 root root 0 Mar 23 12:56 file2
for Others	-rwxrwx**rwx** 1 root root 0 Mar 23 12:56 file3
SUID	-rw**S**r--r-- 1 root root 0 Mar 23 12:56 file4
SGID	-rw-r-**S**r-- 1 root root 0 Mar 23 12:56 file5
	-rw-r--r-T 1 root root 0 Mar 23 12:56 file6

"X" каталогу - надає доступ до таблиці inode (read, write).
Без "X" - не можливо каталог зробити поточним, заходити в підкаталоги, читати і змінювати права доступу до об'єктів.
"R" (без "X") - можливо тільки прочитати список файлів каталогу.
"W" (без "X") - не можна змінити вміст об'єктів каталогу.
"SGID" каталогу - всі файли створюються з групою власника каталогу.
«Sticky bit» каталогу - користувачі можуть записувати в каталог, але не можуть видаляти / перейменовувати файли інших користувачів (наприклад, в /tmp).

Утиліта umask - встановлює инверсную маску створюваних файлів
(777 для виконуваних, 666 - для не виконуваних)

Аатрибути файлів:

- i (immutable) - блокування змін
- a (append) - тільки додавання
- c (compress) - автономне стиснення / декомпресія
- s (shred) - гарантоване затирання секторів

Утиліти: useradd, groupadd, passwd, usermod, userdel, umask, id, chown, chgrp, chmod, chattr, lsattr, shred

Надійність файлової системи (fsck, резервне копіювання):

- Суперечливість - модифіковані блоків не записані.
- Підрахувати, скільки разів блок зустрічається в файлах або списку вільних блоків
- Пошук відсутніх, двічі вільних і блоків, що присутні у 2-х та більше файлах
- Підрахувати, скільки існує жорстких посилань на файл (порівнюється з лічильником в inode).

Підсистема нотаризації Syslog (rsyslog)

/etc/syslog.conf (селектор (рівень.значущість) — отримувач)**:**

```
*.info;mail.none;authpriv.none;cron.none        /var/log/messages
authpriv.*                                      /var/log/secure
mail.*                                          /var/log/maillog
cron.*                                          /var/log/cron
*.emerg                                         *
uucp,news.crit                                  /var/log/spooler
local7.*                                        /var/log/boot.log
```

Системний сервіс (демон) *syslod*
Системний виклик *syslog()*
Мережний протокол *Syslog*

Вразливості:

- в ядрі
- в утилітах і бібліотеках (ldd, libc, glibc ...)

Фактори вразливості UNIX:

- Необмежені можливості суперкористувача
- Багато файлів налаштувань
- SUID/SGID програми (рекомендовано перехід до capabilities)
- Недоліки механізмів керування доступом
- Система реєстрації - відсутність шифрування та забезпечення цілісності даних

Рекомендації:

- Фізичний захист системи: контроль фізичного доступу до системи і безпека мережі
- Захист облікових записів
- Політика паролів (сильні паролі, періодична зміна, не використовувати повторно...)
- Коректне призначення прав доступу і шифрування

- Зібрати ядро тільки з потрібними опціями
- Використовувати засоби захисту ядра: Grsecurity (PaX)...
- Позбутися від непотрібного ПЗ і SUID-програм
- Обмежити можливості запуску програм (noexec в /tmp)
- Вимикайте непотрібні сервіси (сумісність IPv6 та IPv4)
- У використовуваних сервісах відключити непотрібні функції
- Використовувати засоби захисту ОС: SELinux, AppArmor...
- При віддаленому доступі використовувати SSH та унеможливити вхід під root
- Оперативно отримувати інформацію про вразливість і оновлення
- Своєчасно встановлювати оновлення безпеки

Налаштування автентифікації та обмеження можливостей користувачів: PAM модулі

Часткова передача прав суперкористувача: Sudo, Linux Capabilities

Обмеження ресурсів застосунків: SELinux, AppArmor, chroot, ulimit, cpulimit, nice, ionice, quota, trickle, ...

Утиліти захисту:

- John the Ripper, CrackLib, генератори паролей – стійкість паролів
- LUKS, LoopAES, eCryptfs – шифрування файлової системи
- PGP (Pretty Good Privacy) – cryptographic privacy and authentication of data
- Logrotate - automatic log rotation and compression, Logcheck – сканування log-файлів, Swatch (Simple Log Watcher), Logwatch (log paresr and analyser), LogSentry (automated log monitoring)
- AIDE (Advanced Intrusion Detection Environment) – a file and directory integrity checker, Tripwire – file system integrity
- LIDS (Linux Intrusion Detection System) - enhances the kernel's security by implementing mandatory access control (MAC)

Політика безпеки:
Адекватна політика безпеки забезпечує захист ОС від певної множини загроз з достатнім ступенем надійності. Адекватність політики безпеки визначається завданнями інформаційної системи і наявними загрозами безпеці інформації.

Максимальний рівень захисту системи як правило обмежує її функціональність і ускладнює роботу користувачів:

- Правила ідентифікації і автентифікації (отримання доступу)
- Призначення прав доступу;
- Використання апаратних ресурсів;
- Складність адміністрування.

Етапи розробки адекватної політики безпеки:

- Аналіз загроз (модель загроз);
- Формування вимог до політики безпеки (визначаються засоби і методи захисту відповідно загрозам);
- Формальний опис політики безпеки (програм і налаштувань);
- Реалізація політики безпеки;
- Підтримка і модернізація (корекція) політики безпеки.

Адміністративні засоби захисту:
(Не достатньо тільки програмно-апаратних засобів для захисту ОС)

- Постійний контроль коректності функціонування ОС (підсистем захисту) - реєстрація подій, контроль цілісності файлів, тестування компонент ОС;
- Організація і підтримка адекватної політики безпеки - визначено доступ користувачів до компонентів ОС та інших об'єктів, правила ідентифікації (атрибути доступу), правила реєстрації подій, політика реагування на події;
- Навчання користувачів. Правила роботи з критичною інформацією;
- Резервне копіювання;
- Постійний контроль за зміною налаштувань і політик безпеки (контроль змін в системі);

Питання:

Загрози безпеці операційних систем.
Для реалізації яких механізмів захисту ОС потрібна апаратна підтримка.
Перерахуйте адміністративні заходи захисту ОС.
Що таке політика безпеки ОС і що вона визначає.
Життєвий цикл політики безпеки (етапи формування політики безпеки).
Функції (підсистеми) комплексного захисту ОС.
Завдання керування правами доступу в ОС.
Що таке домен захисту в ОС.
Як здійснюється перехід суб'єкта між різними доменами захисту.
Відмінність дискреційного і нормативного (мандатного) кервання доступом в ОС.
Сенс ідентифікації, автентифікації і авторизації в ОС.
Завдання і механізми системи аудиту (нотаризації) в ОС.

Загрози безпеці ОС Unix.
Архітектура ОС UNIX і підсистеми захисту.
Модель захисту ОС UNIX.
Суб'єкти і об'єкти доступу в ОС Unix.
Який користувач в ОС Unix є суперкористувачем.
Які повноваження, недоступні звичайним користувачам, має привілейований користувач UNIX.
Як обмежити права суперкористувача.
Структура і принцип роботи системи автентифікації ОС Unix.
Послідовність дій системи при реєстрації користувачів.
Налаштування політики облікових записів (де знаходиться, що налаштовується).
Механізми захисту облікових записів і повноважень суперкористувача ОС Unix.
Модель кервання доступом ОС Unix (об'єкти та принципи кервання доступом).
Які параметри однозначно визначають домен захисту процесу.

Права доступу до каталогів та файлів ОС Unix.
Що означають атрибути SUID, SGID для файлів або каталогів.
Додаткові атрибути файлів в ОС Unix.
Утиліти і команди керування доступом в ОС Unix.
Що розуміється під цілісністю і надійністю файлової системи ОС Unix.
Механізми, що забезпечують цілісність і відмовостійкість файлових систем UNIX
Архітектура (компоненти) і принципи роботи системи аудиту (нотаризації) UNIX.
Фактори вразливості ОС Unix. Види вразливостей.
Способи підвищення захищеності ОС Unix.

Література:

- Танненбаум Э. Современные операционные системы. 4-е изд. - СПб.: Питер, 2015. - 1120 с.

ЗАСОБИ ЗАХИСТУ ОС WINDOWS

План:

- Архітектура засобів захисту ОС Windows
- Автентифікація
- Привілеї і дозволи
- Керування доступом
- Аудит
- Файлова система
- Домени Active Directory

Способи проникнення в систему:

- Атаки на браузер
- Пошта, повідомлення (троян)
- Вразливості мережних служб (черв`як)
- Підбір паролів
- Перехоплення автентифікації (прослуховування трафіка, фальшивий сервер, MITM)
- Фізичне проникнення

Захищеність ОС Windows забезпечується:

- Безпечна реєстрація
- Дискреційне керування доступом
- Керування привілейованим доступом (привілейовані користувачі)
- UAC (User Account Control) – Служба захисту користувачів (починаючи з Windows Vista/2008)
- Захист адресного простору процесів
- Обнулення сторінок перед виділенням процесам
- Аудит подій ОС

Архітектура мікроядра

Ядро - програмний код, що виконується в привілейованому режимі
Мікроядро - зміна контекстів процесів, планування потоків, підтримка апаратного забезпечення

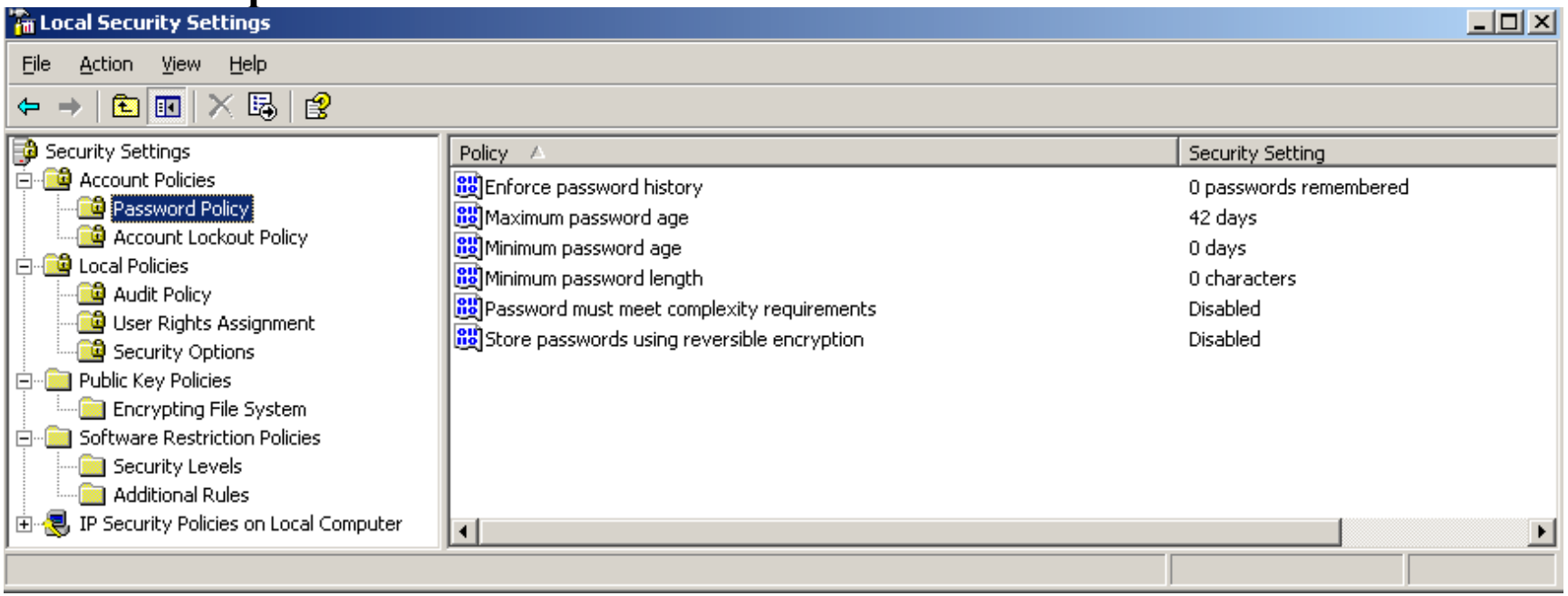
Windows - монолітне “мікроядро”
Linux - модульне ядро

Ідентифікація та автентифікація (задіяні такі об'єкти ОС):

- winlogon.exe та провайдери (бібліотеки) автентифікації (msgina.dll, ...)
- LSA (Local Security Authority, lsass.exe) - підсистема локальної автентифікації
- SAM (Security Account Manager) - диспетчер облікових записів, дані обл. записів - з реєстру
- служба NetLogon (вхід в систему з мережі) і сервер Active Directory (служба каталогу домену)

При вході до системи LSA створює маркер доступу користувача;
UserInit.exe налаштовує середовище користувача (дані з реєстру) і запускає Windows Explorer;
Зберігання гешей паролів в C:\Windows\SYSTEM32\config\SAM — окремо геш DES (LM, для LAN Manager), MD4 (для NTLM) і MD5 (для NTLMv2).
*SYSKEY – шифрування гешей паролів.

Політика паролей:



Керування доступом (підсистема авторизації) у Windows

Керування доступом реалізується моніором безпеки (SRM, Security Reference Monitor, виконується в ядрі ntoskrnl.exe) на основі порівняння інформації *маркера доступу* суб'єкта і *дескриптора захисту* об'єкта
Маркер доступу суб'єкта - носій його повноважень
Дескриптор захисту об'єкта містить ідентифікатори власника, DACL, SACL...

Всі суб'єкти доступу (користувачі, групи, комп'ютери, домени, ...) мають унікальний SID

Ідентифікатор безпеки (**SID**): S-версія-агент_ідентіфікатора-субагент- ... -RID
(Наприклад, S-1-5-21-746385570-2913517877-2667279727-1023)
RID (Relative Identifiers) - відносний ідентифікатор

Групи - стандартні набори прав доступу

Спеціальні SID:

- **Everyone, Authenticated Users** (~ Everyone in WinXP/WinServer2003)
- **Authentication SID** (INTERACTIVE, REMOTE INTERACTIVE, NETWORK, SERVICE, BATCH) – визначають, як і звідки процес потрапив у систему
- **LOGON SID** - для ізоляції між різними сесіями Terminal Service

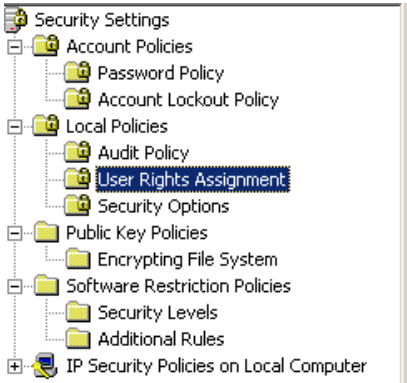
Приклади SID:

Administrator S-1-5-21-*1356627136-380754525-319898065*-1000
(**RID=1000**)

Everyone S-1-1-0
LOCAL S-1-2-0
CONSOLE LOGON S-1-2-1
INTERACTIVE S-1-5-4
Logon SID S-1-5-5-0-*615272*
SERVICE S-1-5-6
Authenticated Users S-1-5-11
SYSTEM S-1-5-18
LOCAL SERVICE S-1-5-19
NETWORK SERVICE S-1-5-20
None S-1-5-21-*1356627136-380754525-319898065*-513
Administrators S-1-5-32-544
Users S-1-5-32-545

"1356627136-380754525-319898065" – залежить від системи

Привілеї (Rights) - права на систему в цілому (напр. входити локально, змінювати системний час, ...), а не конкретний об'єкт.
Дозволи (Permissions) - на окремі об'єкти системи (призначаються через список контролю доступу ACL).



Policy	Security Setting
Access this computer from the network	Everyone,Administrators,Users,Power Users,Backup Operators
Act as part of the operating system	
Add workstations to domain	
Adjust memory quotas for a process	LOCAL SERVICE,NETWORK SERVICE,Administrators
Allow log on locally	__vmware__,Administrators,Users,Power Users,Backup Operators
Allow log on through Terminal Services	Administrators,Remote Desktop Users
Back up files and directories	Administrators,Backup Operators
Bypass traverse checking	Everyone,Administrators,Users,Power Users,Backup Operators
Change the system time	Administrators,Power Users
Create a pagefile	Administrators
Create a token object	
Create global objects	Administrators,SERVICE
Create permanent shared objects	
Debug programs	Administrators
Deny access to this computer from the network	SUPPORT_388945a0
Deny log on as a batch job	
Deny log on as a service	
Deny log on locally	SUPPORT_388945a0
Deny log on through Terminal Services	
Enable computer and user accounts to be trusted for delegation	
Force shutdown from a remote system	Administrators
Generate security audits	LOCAL SERVICE,NETWORK SERVICE
Impersonate a client after authentication	Administrators,SERVICE
Increase scheduling priority	Administrators
Load and unload device drivers	Administrators
Lock pages in memory	
Log on as a batch job	LOCAL SERVICE,SUPPORT_388945a0
Log on as a service	NETWORK SERVICE,Administrator
Manage auditing and security log	Administrators
Modify firmware environment values	Administrators
Perform volume maintenance tasks	Administrators
Profile single process	Administrators,Power Users
Profile system performance	Administrators
Remove computer from docking station	Administrators,Power Users
Replace a process level token	LOCAL SERVICE,NETWORK SERVICE
Restore files and directories	Administrators,Backup Operators
Shut down the system	Administrators,Power Users,Backup Operators
Synchronize directory service data	
Take ownership of files or other objects	Administrators

Суб'єкти доступу:

- Користувачі (звичайні і псевдокористувачі SYSTEM, <pc_name> $)
- Групи користувачів
- Спеціальні (тимчасові) групи (INTERACTIVE, NETWORK, DIAL_UP)
- Відносні суб'єкти (CREATOR_OWNER, CREATOR_GROUP)
- EVERYONE

Автоматично створюються: Administrator, Guest, Administrators, Users, BackupOperators, Replicators, PowerUsers, AccountOperators, PrintOperators, ServerOperators

Computer Management->Local User and Groups:

Administrator	ORION
Administrators	ORION
ANONYMOUS LOGON	
Authenticated Users	
Backup Operators	ORION
BATCH	
CREATOR GROUP	
CREATOR OWNER	
DIALUP	
Everyone	
Guest	ORION
Guests	ORION
HelpServicesGroup	ORION
INTERACTIVE	
LOCAL SERVICE	
NETWORK	
Network Configuration Operators	ORION
NETWORK SERVICE	
Performance Log Users	ORION
Performance Monitor Users	ORION
Power Users	ORION
Print Operators	ORION
Remote Desktop Users	ORION
REMOTE INTERACTIVE LOGON	
Replicator	ORION
SERVICE	
SUPPORT_388945a0	ORION
SYSTEM	
TelnetClients	ORION
TERMINAL SERVER USER	
Users	ORION

Об'єкти доступу:
Всі об'єкти Windows є об'єктами доступу
(В Linux - всі об'єкти доступу відображені в файлову систему)

- Файлові об'єкти: файли, файлові каталоги, пристрої, канали (pipes), поштові скриньки (mailslots)
- Каталоги об'єктів
- Ключі реєстру
- Процеси і нитки
- Диспетчер сервісів і сервіси
- Об'єкти керування вікнами: робочі столи, віконні станції (Window Station)
- Порти
- Секції поділюваної пам'яті
- Символьні посилання (синоніми об'єктів)
- Маркери доступу
- Об'єкти синхронізації: події, пари подій, семафори, м'ютекси

Методи доступу (22)

Стандартні (застосовні до об'єктів всіх типів):

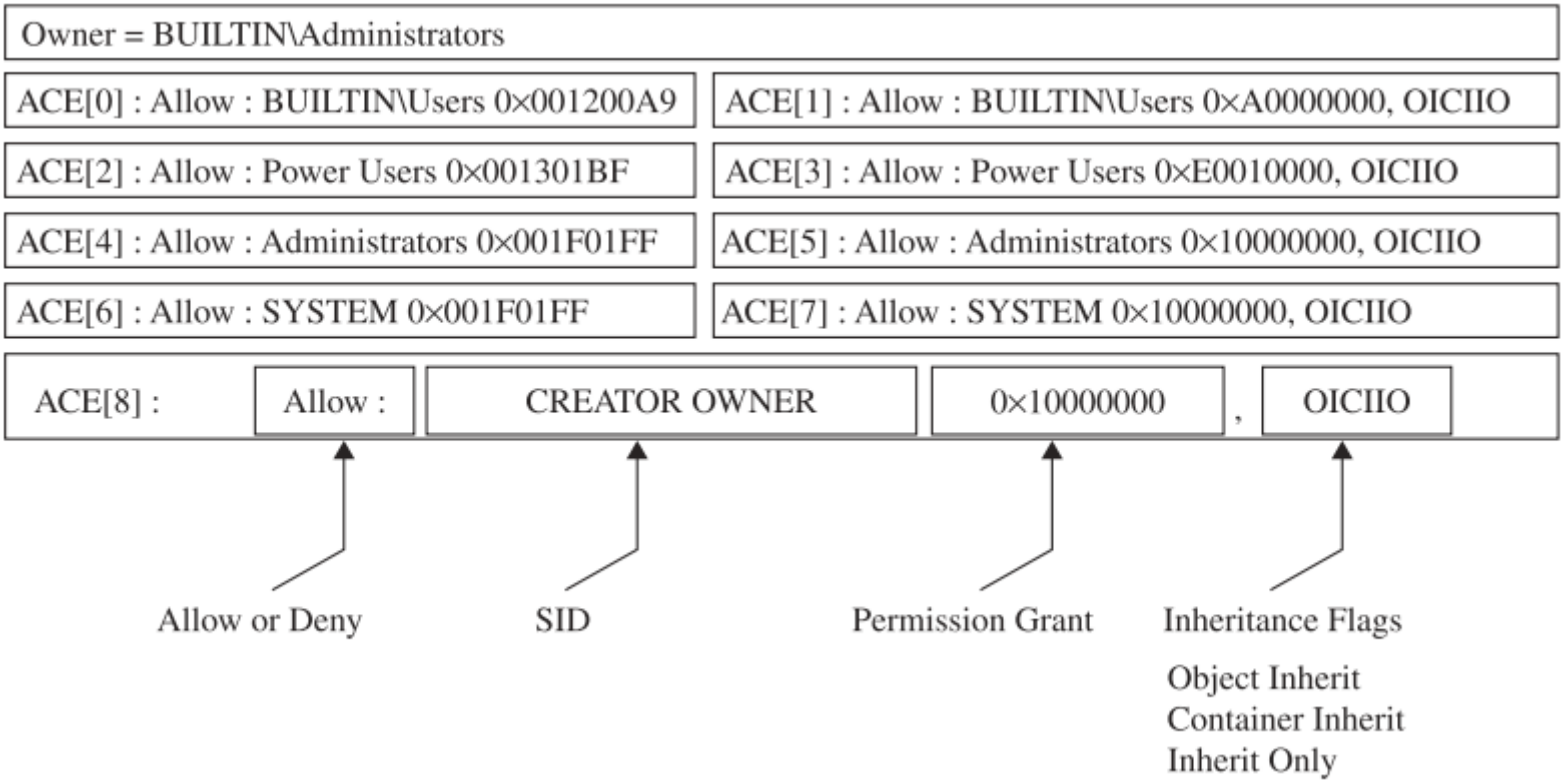
- Видалення об'єкта
- Отримання атрибутів захисту об'єкта
- Зміна атрибутів захисту об'єкта
- Зміна власника об'єкта
- Отримання і зміна параметрів аудиту об'єкта
- Синхронізація

Специфічні :

Файли	**Каталоги файлів**	**Ключі реєстру**	**Процеси**	**Сервіси**
• читання • запис • додавання інф-ї • виконання • читання атрибутів • зміна атрибутів • читання розширених атрибутів • зміна розширених атрибутів	• перегляд • створення файла • створення каталога • звернення до подкаталога • видалення файла / підкаталога • читання атрибутів • зміна атрибутів • читання розширених атрибутів • зміна розширених атрибутів	• читання значень • зміна значень • створення ключа • перерахування підключей • оповіщення у разі доступу • створення символьного посилання	• завершення • створення потоку • зміна атрибутів сторінок адресного простору • читання адресного простору • запис в адресний простір • дублювання дескриптора • отримання пріоритету • зміна пріоритету	• запуск • зупинка • призупинення / відновлення • отримання стану • оновлення стану • перерахування залежних сервісів • отримання конфігурації • зміна конфігурації • специфічний метод доступу сервісу

Дозволи на файлові об'єкти (стандартні та особливі (детальні)):

Full Control	☐	☐	Full Control	☐	Full Control	☐	Full Control	☐
Modify	☐	☐	Traverse Folder / Execute File	☐	Modify	☐	Traverse Folder / Execute File	☑
Read & Execute	☐	☐	List Folder / Read Data	☑	Read & Execute	☐	List Folder / Read Data	☑
Read	☑	☐	Read Attributes	☑	List Folder Contents	☑	Read Attributes	☑
Write	☐	☐	Read Extended Attributes	☑	Read	☐	Read Extended Attributes	☑
Special Permissions	■	■	Create Files / Write Data	☐	Write	☐	Create Files / Write Data	☐
			Create Folders / Append Data	☐	Special Permissions	■	Create Folders / Append Data	☐
			Write Attributes	☐			Write Attributes	☐
			Write Extended Attributes	☐			Write Extended Attributes	☐
			Delete	☐			Delete Subfolders and Files	☐
			Read Permissions	☑			Delete	☐
			Change Permissions	☐			Read Permissions	☑
			Take Ownership	☐			Change Permissions	☐
Full Control	☐	☐	Full Control	☐	Full Control	☐	Full Control	☐
Modify	☐	☐	Traverse Folder / Execute File	☐	Modify	☑	Traverse Folder / Execute File	☑
Read & Execute	☐	☐	List Folder / Read Data	☐	Read & Execute	☑	List Folder / Read Data	☑
Read	☐	☐	Read Attributes	☐	Read	☑	Read Attributes	☑
Write	☑	☐	Read Extended Attributes	☐	Write	☑	Read Extended Attributes	☑
Special Permissions	■	■	Create Files / Write Data	☑	Special Permissions	■	Create Files / Write Data	☑
			Create Folders / Append Data	☑			Create Folders / Append Data	☑
			Write Attributes	☑			Write Attributes	☑
			Write Extended Attributes	☑			Write Extended Attributes	☑
			Delete	☐			Delete	☑
			Read Permissions	☐			Read Permissions	☑
			Change Permissions	☐			Change Permissions	☐
			Take Ownership	☐			Take Ownership	☐
Full Control	☐	☐	Full Control	☐				
Modify	☐	☐	Traverse Folder / Execute File	☑				
Read & Execute	☑	☐	List Folder / Read Data	☑				
Read	☑	☐	Read Attributes	☑				
Write	☐	☐	Read Extended Attributes	☑				
Special Permissions	■	■	Create Files / Write Data	☐				
			Create Folders / Append Data	☐				
			Write Attributes	☐				
			Write Extended Attributes	☐				
			Delete	☐				
			Read Permissions	☑				
			Change Permissions	☐				
			Take Ownership	☐				



DACL в дескрипторі зхисту

31	30	29	28	27	26	25	24	23	22	21	20	19	18	17	16	15	14	13	12	11	10	9	8	7	6	5	4	3	2	1	0
GR	GW	GE	GA	Reserved			AS	Standard access rights								Object-specific access rights															

GR → Generic_Read
GW → Generic_Write
GE → Generic_Execute
GA → Generic_All
AS → Right to access SACL

Маска доступу

Маркер доступу - ідентифікатор контекста захисту процеса або потока

Впливає на можливість виконання дій, дозволених потоку або процесу
Початковий маркер доступу користувача процеса створюється WinLogon
Маркер доступу використовується SRM при визначенні ефективних прав доступу

Містить:

- Заголовок (ідентифікатор, термін дії)
- Групи POSIX
- DACL (шаблон ACL для створюваних потоком / процесом об'єктів)
- Ідентифікатор (SID) користувача
- Ідентифікатори (SID) груп
- Обмежені ідентифікатори SID
- Привілеї

Дескриптор захисту об'єкта:

Список користувачів і груп, що мають доступ до даного об'єкта:

- Ідентифікатор (SID) власника
- Ідентифікатори (SID) груп
- DACL (набір ACE - Access Control Entry) - складається із заборонних та дозвільних елементів. Спочатку обробляються заборонні елементи.
- SACL (системний список контролю доступу) – для реєстрації дій над об`єктом

Перевірка прав доступу
Потік ще до відкриття об'єкта повинен вказати бажані операції (методи доступу).
При відкритті процес отримує вказівник на об'єкт

Механізми, що впливають на права доступу:

- Володіння об'єктами доступу (файлами, ...) - права власника
- Передача прав володіння (Take Ownership)
- Явно встановлені дозволи (permissions) на доступ до об'єктів. Стандартн та детальні дозволи
- Спадкування дозволів (від групи / контейнера)
- Адитивність дозволів (заборона має більш високий пріоритет)
- Ефективні дозволи (дійсні дозволи, безпосередньо призначені, або отримані спадкуванням / через групу)

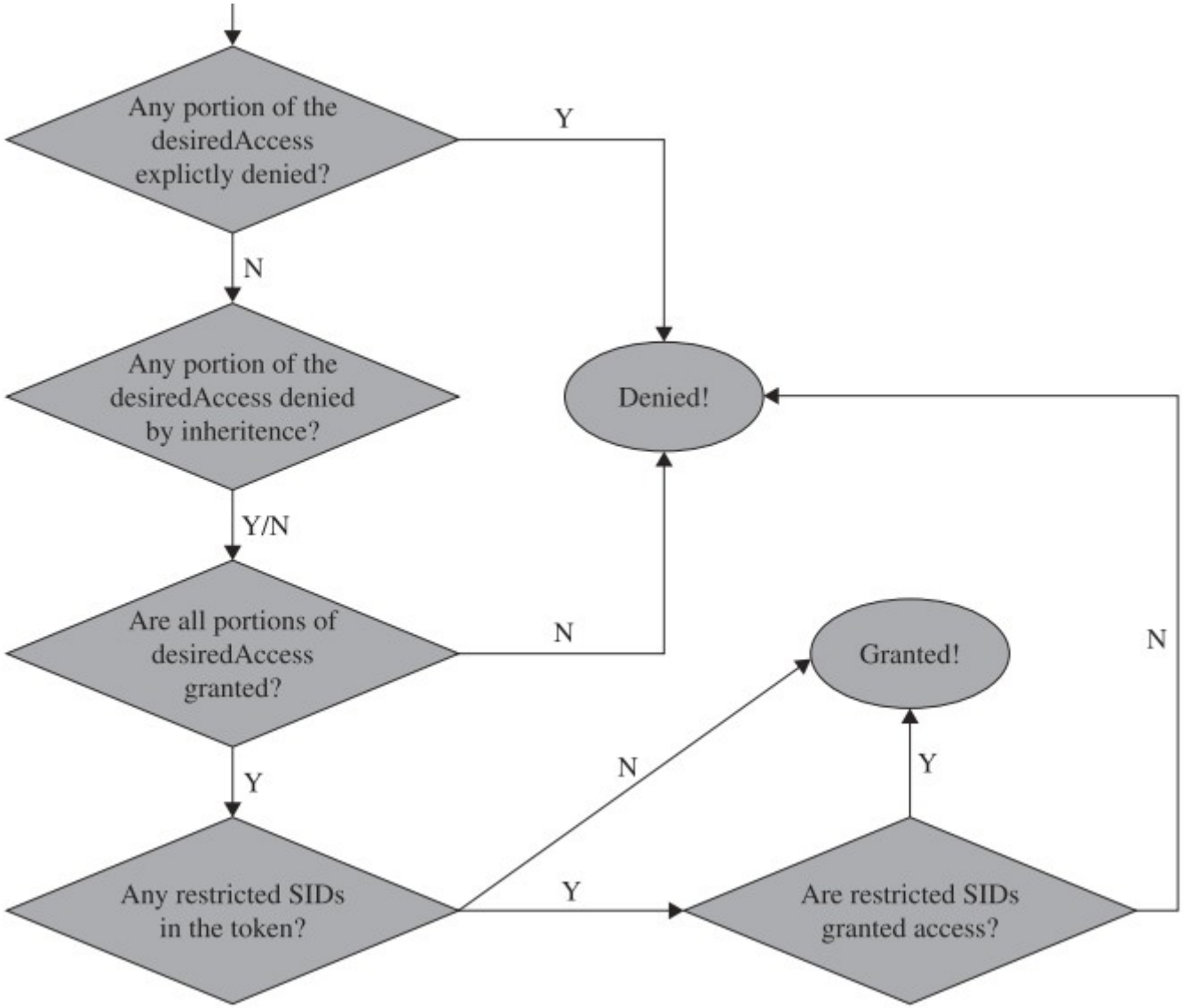
Процедура AccessCheck
0. Відсутність DAC або NULL DAC. Захоплення власника або права власника.
1. Привілеї.
2. Явні заборонні ACE
3. Успадковані заборонні ACE (явні дозволяючі ACE превалюють успадковані)
4. Явні дозволяючі ACE
5. Окрема перевірка тільки для обмежених SID (все що дозволено явно або спадкується також має бути дозволено для обмежених SID — дозволи не можуть бути «розширені» за допомогою обмежених SID).

Прапори спадкування:

- OI (Object Inheritance) - вкладені файли явно успадковують даний ACE, каталоги успадковують як «Inherit Only».
- CI (Container Inheritance) - ACE успадковується каталогами і не діє на файли.
- IO (Inherit Only) - тільки для спадкування (ACE не діє на каталог, до якого застосовано).

Права власника (також для права WriteOwner і для привілеї SeTakeOwnership) - власник об'єкта завжди може відкрити об'єкт для READ_CONTROL і WRITE_DAC і отримати повний доступ.

NULL DACL — DACL що явно призначається і дає всім повний доступ (~ Full control for Everyone)



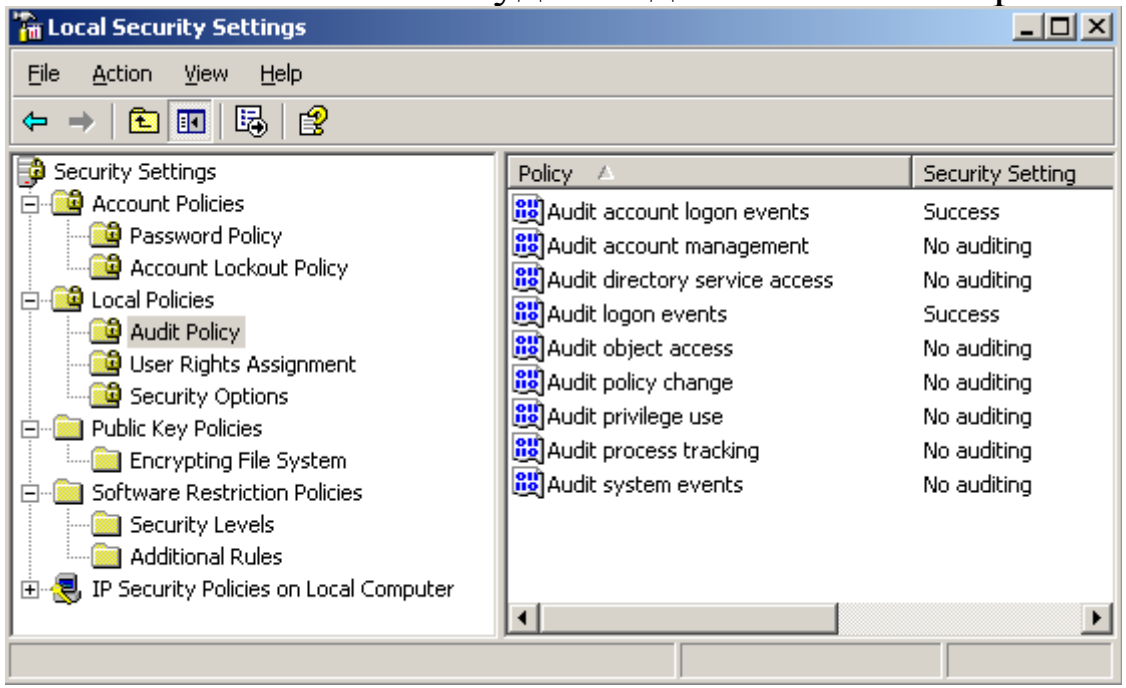
Процедура обчислення ефективних дозволів

Аудит

Журнали реєстрації:

- Системний
- Прикладного ПО
- Безпеки

Події аудиту генерує диспетчер об'єктів за результатами перевірки прав доступу (список SACL)
Політика аудиту локальної системи визначає аудит подій безпеки конкретного типу.



Властивості файлової системи NTFS

- Дозволи на доступ до файлів і файлових каталогів
- Стиснення (або шифрування) файлів і каталогів
- Шифрування файлів EFS - надбудова над NTFS
- Журналювання (журнал змін) - реєстрація операцій доступу
- Розподілене відстеження посилань на файли при переміщенні в межах домену
- Дискові квоти - обсяг простору тому, що виділено користувачу. Відстеження файлів користувача при видаленні облікового запису.
- Жорсткі посилання — можливо безліч імен файла / каталога в межах тома
- Розріджені (sparse) файли
- Автономні файли - дозволяють працювати з документами в загальному каталозі навіть при відсутності з'єднання з мережею (автоматична регулярна синхронізація)

Розподілена файлова система (DFS, Distributed File System)

Дозволяє об'єднати файлові ресурси на різних комп'ютерах (різних файлових системах) у єдиний логічний простір імен. Автоматичне перемикання на альтернативний ресурс при відмові і збалансованість навантаження.

EFS (Encrypted File System)

- Прозоре шифрування файлів
- 2-х рівневе шифрування (симетричний 128 - розрядний ключ зберігається разом з файлом і захищений асиметричним шифруванням).
- Блокове шифрування файлів: 3DES, AES256, DESX (Windows 2000 / XP)
- Можлива спільна робота декількох користувачів над об'єктом (вимагає декількох ключів до симетричного ключа)
- Агент відновлення (відключений за замовчуванням)
- При перевстановлення системи необхідний експорт сертифікатів!

Починаючи з Windows Vista/7 доданий компонент BitLocker - шифрування всього тому

Механізми надійності файлової системи

- Журнал змін
- RAID (Redundant Array of Independent Disks)
- Дзеркалювання (надмірність)
- Чергування (розщеплення) - прискорення доступу і балансування навантаження (без відмовостійкості)
- RAID-5 - розщеплення блоків даних+ надмірність (XOR)

Local Security Settings -> Local Policies ->Security Options

(налаштування системи захисту в цілому)

Accounts: Administrator account status	Enabled
Accounts: Guest account status	Disabled
Accounts: Limit local account use of blank passwords to console logon only	Enabled
Accounts: Rename administrator account	Administrator
Accounts: Rename guest account	Guest
Audit: Audit the access of global system objects	Disabled
Audit: Audit the use of Backup and Restore privilege	Disabled
Audit: Shut down system immediately if unable to log security audits	Disabled
Devices: Allow undock without having to log on	Enabled
Devices: Allowed to format and eject removable media	Administrators
Devices: Prevent users from installing printer drivers	Enabled
Devices: Restrict CD-ROM access to locally logged-on user only	Disabled
Devices: Restrict floppy access to locally logged-on user only	Disabled
Devices: Unsigned driver installation behavior	Warn but allow installal
Domain controller: Allow server operators to schedule tasks	Not Defined
Domain controller: LDAP server signing requirements	Not Defined
Domain controller: Refuse machine account password changes	Not Defined
Domain member: Digitally encrypt or sign secure channel data (always)	Enabled
Domain member: Digitally encrypt secure channel data (when possible)	Enabled
Domain member: Digitally sign secure channel data (when possible)	Enabled
Domain member: Disable machine account password changes	Disabled
Domain member: Maximum machine account password age	30 days
Domain member: Require strong (Windows 2000 or later) session key	Disabled
Interactive logon: Do not display last user name	Disabled
Interactive logon: Do not require CTRL+ALT+DEL	Disabled
Interactive logon: Message text for users attempting to log on	
Interactive logon: Message title for users attempting to log on	Not Defined
Interactive logon: Number of previous logons to cache (in case domain controller i...	10 logons
Interactive logon: Prompt user to change password before expiration	14 days
Interactive logon: Require Domain Controller authentication to unlock workstation	Disabled
Interactive logon: Require smart card	Disabled
Interactive logon: Smart card removal behavior	No Action
Microsoft network client: Digitally sign communications (always)	Disabled
Microsoft network client: Digitally sign communications (if server agrees)	Enabled
Microsoft network client: Send unencrypted password to third-party SMB servers	Disabled

Microsoft network server: Amount of idle time required before suspending session	15 minutes
Microsoft network server: Digitally sign communications (always)	Disabled
Microsoft network server: Digitally sign communications (if client agrees)	Disabled
Microsoft network server: Disconnect clients when logon hours expire	Enabled
Network access: Allow anonymous SID/Name translation	Disabled
Network access: Do not allow anonymous enumeration of SAM accounts	Enabled
Network access: Do not allow anonymous enumeration of SAM accounts and shares	Disabled
Network access: Do not allow storage of credentials or .NET Passports for netwo...	Disabled
Network access: Let Everyone permissions apply to anonymous users	Disabled
Network access: Named Pipes that can be accessed anonymously	COMNAP,COMNODE,SQL\QUERY,SPO
Network access: Remotely accessible registry paths	System\CurrentControlSet\Control\Pr
Network access: Remotely accessible registry paths and sub-paths	System\CurrentControlSet\Control\Pri
Network access: Restrict anonymous access to Named Pipes and Shares	Enabled
Network access: Shares that can be accessed anonymously	COMCFG,DFS$
Network access: Sharing and security model for local accounts	Classic - local users authenticate as th
Network security: Do not store LAN Manager hash value on next password change	Disabled
Network security: Force logoff when logon hours expire	Disabled
Network security: LAN Manager authentication level	Send NTLM response only
Network security: LDAP client signing requirements	Negotiate signing
Network security: Minimum session security for NTLM SSP based (including secure...	No minimum
Network security: Minimum session security for NTLM SSP based (including secure...	No minimum
Recovery console: Allow automatic administrative logon	Disabled
Recovery console: Allow floppy copy and access to all drives and all folders	Disabled
Shutdown: Allow system to be shut down without having to log on	Disabled
Shutdown: Clear virtual memory pagefile	Disabled
System cryptography: Force strong key protection for user keys stored on the co...	Not Defined
System cryptography: Use FIPS compliant algorithms for encryption, hashing, an...	Disabled
System objects: Default owner for objects created by members of the Administra...	Administrators group
System objects: Require case insensitivity for non-Windows subsystems	Enabled
System objects: Strengthen default permissions of internal system objects (e.g. ...	Enabled
System settings: Optional subsystems	Posix
System settings: Use Certificate Rules on Windows Executables for Software Res...	Disabled

Фактори вразливості Windows:

- Сервери (виконання коду незареєстрованим користувачем)
- Системні процеси і виклики (отримання прав адміністратора)
- Непередбачені ситуації (переповнення буфера, некоректна обробка сигналів і переривань, непередбачені вхідні дані)
- Люки (недокументовані виклики, режим відлагодження)
- Підміна об'єктів (підміна даних або програм в кеші, підміна парметрів керування, підміна файлів через посилання або синоніми)
- Наявність анонімного користувача
- Людський фактор (помилки користувачів або адміністраторів: слабкі паролі, помилки адміністрування)
- Сумісність з іншими ОС (підтримка застарілих технологій: не стійкі криптоалгоритми, наявність двох геш-функцій (RC4 і DES разом, наявність діалектів протоколів)

Заходи захисту:

- Політика облікових записів \ паролів
- Відключення (блокування мережним екраном) непотрібних сервісів
- Аудит і аналіз журналів реєстрації, політика реагування на події

Домени Windows

Властивості:

- Єдина реєстрація в мережі з можливістю доступу до всіх ресурсів
- Автентифікація Kerberos
- Єдиний каталог ресурсів домена (Active Directory)
- LDAP (Lightweight Directory Access Protocol) - протокол доступу до каталогів
- Інтеграція з системою DNS (іменування ресурсів за схемою DNS)
- Централізоване керування
- Групові політики
- Масштабованість (дерево або ліс доменів)
- Реплікація між контролерами (автоматичне поширення налаштувань)

Моделі організації доменів:

- Мережа з одним доменом
- Мережа з одним основним (адміністративним) доменом і декількома ресурсними доменами
- Мережа з декількома рівноправними доменами

Користувацькі домени - керування обліковими записами
Ресурсні домени - домени управління ресурсами мережі (ПК, ноутбуки, сервери, сервіси ..)

Структура *сайтів* повинна відтворювати географічну топологію.
WAN-канали - між сайтами. В межах однієї локації - один сайт.
Структура сайтів впливає на трафік реплікації (оновлень) AD по WAN.
Щоб трафік реплікації не передавався по WAN декілька разів, в кожному сайті визначається один DC - bridgehead server, який приймає оновлення AD по WAN і поширює на інші DC сайту.
Тобто, структура сайтів дозволяє контролювати трафік реплікації в межах лісу доменів.

Довірчі відносини:
Рефлексивність і транзитивність довірчих відносин -
маючи обліковий запис в одному домені, можливо отримати повноваження в іншому

Межа безпеки доменів — Ліс доменів!

Групи доменів:

- Глобальні - можуть включати облікові записи користувачів (і комп'ютерів) домену та інші глобальні групи свого домену (Domain Admins, Domain Users, Domain Guests)
- Локальні - облікові записи користувачів і інші локальні групи сого домену, а також універсальні і глобальні групи з будь-яких доменів
- Універсальні групи - облікові записи користувачів і інші універсальні групи, а також глобальні групи з інших доменів

Account Operators	
Cert Publishers	Members of this group are permitted to publish certificates to the Active Directory
Digest Authentication	
DnsAdmins	DNS Administrators Group
DnsUpdateProxy	DNS clients who are permitted to perform dynamic updates on behalf of some other clients
Domain Admins	Designated administrators of the domain
Domain Computers	All workstations and servers joined to the domain
Domain Controllers	All domain controllers in the domain
Domain Guests	All domain guests
Domain Users	All domain users
Enterprise Admins	Designated administrators of the enterprise
ENTERPRISE DOMAIN CONTROLLERS	
Group Policy Creator Owners	Members in this group can modify group policy for the domain
Incoming Forest Trust Builders	
krbtgt	Key Distribution Center Service Account
NTLM Authentication	
Other Organization	
Pre-Windows 2000 Compatible Access	
PROXY	
RAS and IAS Servers	Servers in this group can access remote access properties of users
RESTRICTED	
SChannel Authentication	
Schema Admins	Designated administrators of the schema
SELF	
Server Operators	
Terminal Server License Servers	
This Organization	
Windows Authorization Access Group	

Групові політики (об'єкт GPO - Group Policy Object)

Централізований механізм налаштування великої кількості робочих станцій і обмеження можливостей користувачів і додатків.
Дозволяють налаштовувати параметри комп'ютера або середовища користувача.
Об'єкт GPO прив'язується (застосовується) до контейнера каталогу

Керування об'єктами GPO:

- Ієрархія об'єктів GPO
- Блокування спадкування / обмеження дії
- Результуючі політики

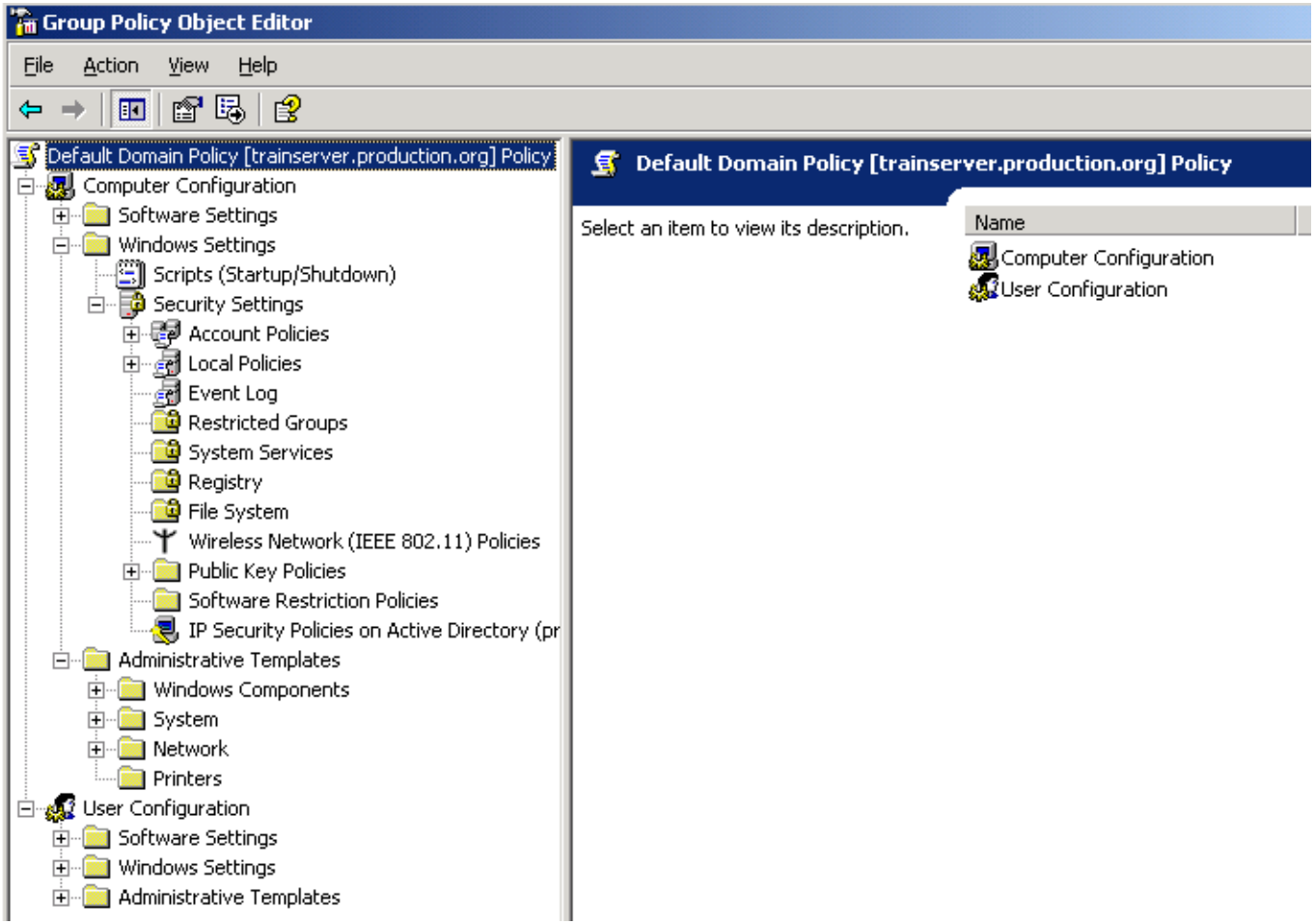
Сценарії користувача - послідовність команд, які виконуються в автоматичному режимі)

- ініціалізація системи (startup script)
- реєстрація користувача (logon script)
- вихід користувача (logoff script)
- вимикання комп'ютера (shutdown script)

Інтерпретація сценаріїв здійснюється сервером сценаріїв Windows Script Host

Структура об'єкта GPO:

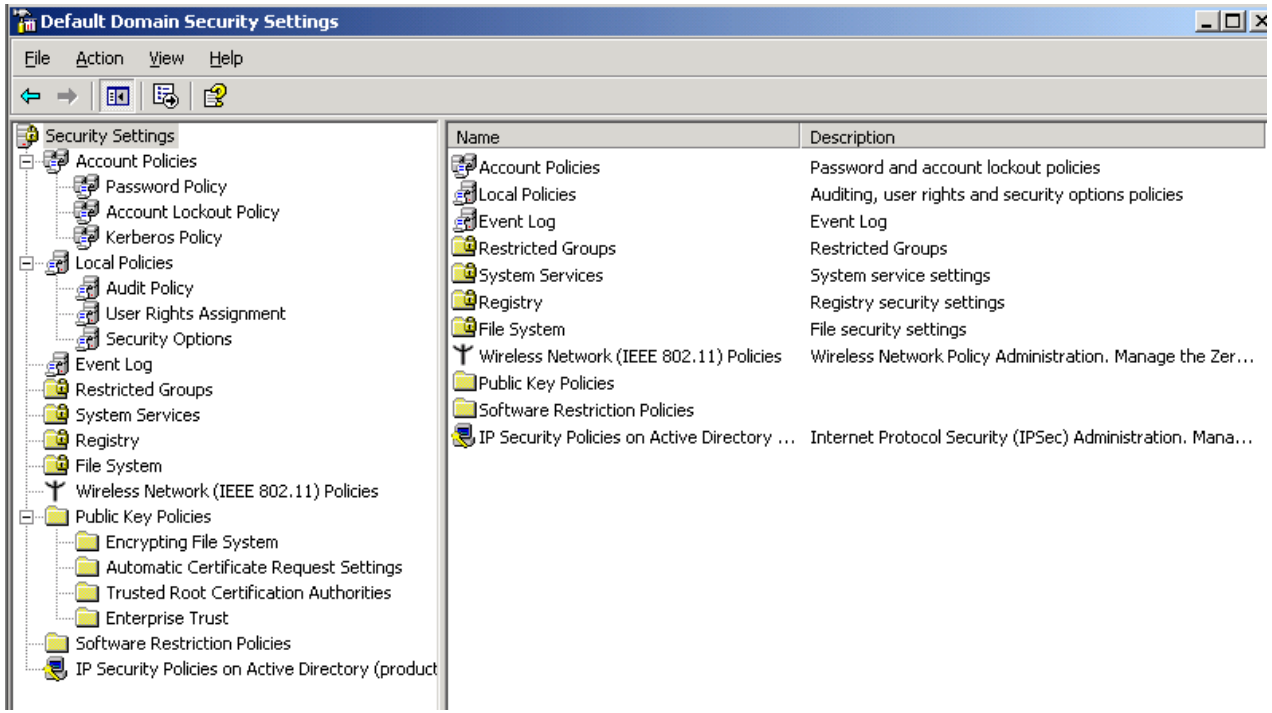
- Налаштування комп'ютера
- Налаштування середовища користувача
- Software settings - додатки, доступні користувачеві
- Windows settings - налаштування ОС
- Admin Templates - керування вмістом реєстру клієнтських комп'ютерів



Засоби захисту доменів Windows

- Автентифікація Kerberos v5 (RFC 1510), раніше була NTLM (Lan Manager)
- Цілісність даних - цифровий підпис
- Конфіденційність (шифрування IP Security)
- Запобігання повторного використання даних (блоків пам'яті, диска)

Автентифікація Kerberos - єдина система взаємної автентифікація на рівні доменів при доступі до всіх ресурсів доменів
Контролер домену виконує служби Active Directory і Kerberos
Клієнти встановлюють довірений шлях (trust path) до контролера домену (NetLogon)
При довірчих відносинах з іншим доменом встановлюється захищений канал



Питання по темі:

Механізми захисту ОС Windows
Архітектура ОС Windows
Компоненти системи захисту ОС Windows.
Послідовність дій системи при ідентифікації і автентифікації користувачів
Архітектура управління доступом в ОС Windows.
Об'єкти, суб'єкти та методи доступу в ОС Windows.
Алгоритм перевірки прав доступу в ОС Windows.
Основні групи користувачів в ОС Windows.
Відмінності привілеїв і дозволів в ОС Windows.
Основні дозволи на доступ до файлової системи ОС Windows.
Що таке маркер доступу і дескриптор захисту об'єкта в ОС Windows. Яку інформацію вони містять.
Архітектура системи аудиту ОС Windows.
Системні журнали Windows.
Властивості файлової системи NTFS.
Що таке ефективні дозволи в ОС Windows. Алгоритм їх обчислення.
Механізми забезпечення надійності файлової системи.
Основні вразливості ОС Windows.
Архітектура (моделі) доменів Windows. Властивості доменів.
Різновиди груп доменів ОС Windows.
Призначення об'єктів групових політик в ОС Windows.
Які технології забезпечують безпеку доменів Windows.

Способи проникнення в систему Windows (компрометації).
Процедура авторизації при операціях доступу.
Сопосби зберігання паролів користувачів.
Механізми шифрування файлової системи.
Способи підвищення захищеності ОС Windows.

Література:

- Танненбаум Э. Современные операционные системы. 4-е изд. - СПб.: Питер, 2015. - 1120 с.

Додатки:

Де зберігаються геші паролів:

- локальна база SAM - LM/NTLM- геші паролей локальних користувачів;
- кеш LSA - LM/NTLM- геші доменних користувачів, стираються після перезавантаження;
- MSCache- геші паролів 10 останніх користувачів, які авторизуватися на даному хості;
- AD-сховище (NTDS.DIT, ключ у файлі SYSTEM)

Способи вилучення гешів паролів:

- Утиліти pwdump/fgdump (вимагають привілеїв NT AUTHORITY\SYSTEM)
- Volume Shadow Copy Service (тіньове копіювання тому)
- Сніффінг (прослуховування мережного трафіка)
- Фізичний доступ (завантаження альтернативної системи)

Використання гешей паролів:

Техніка PATH-the-HASH дозволяє використати геш в якості пароля при мережній автентифікації.

Рекомендації:

Відключити кешування гешей паролів доменних користувачів
Використовувати стійкі паролі

Можливості групових політик:
Обмеження списку виконуваних програм
Заборона виклику диспетчера задач або редактора реєстру, доступу до меню «пуск»

Прийоми обходу групових політик:
Якщо політики не отримані при вході користувача в систему, то оновлюватися вони не будуть.
У безпечному режимі політики не діють.
Немає механізму, що змусить додаток дотримуватися політики (якщо додаток запущено :).
Перехоплення запиту додатка на перевірку політик SRP (Software Restriction Policy).
Дії політик не поширюються на програми, що запущені від імені SYSTEM, драйвери та додатки рівня ядра, макроси документів Microsoft Office.
Змінні середовища як шляхи для обмеження SRP.
Запуск програми від імені іншого користувача.
Виконання довільного коду з програми HTA (HTML Application)

Критичні служби Windows:

- Internet Information Serer (IIS)
- Terminal Services, Remote Desktop Services (RDS) -в Windows Server 2008 R2
- Microsoft SQL Server

Приклади критичних вразливостей:

- MS08-067 - вразливість в службі сервера з виконанням довільного коду (вик-ся Conficker)
- CVE 2010-0249 - виконання довільного коду в Internet Explorer (Aurora)
- CVE 2010-2729 - виконання довільного коду в службі друку (вик-ся Stuxnet)
- CVE 2010-3962 - виконання довільного коду в Internet Explorer
- Вразливість в обробці .lnk файлів - зараження ч-з USB носії (вик-ся Stuxnet)
- Підміна адресного рядка в Internet Explorer
- Переповнення стеку в HTML HELP з виконанням довільного коду
- CVE 2011-3402 — виконання довільного коду при обробці True Type шрифтів (вик-ся хробаком Duqu)
- CVE 2017-0144 – виконання довільного коду ч-з протокол Windows SMB (експлоіт EternalBlue, що використовувася вірусами-вимагачами (ransomware) WannaCry/WannaCrypt/WNCRY та NotPetya)
- CVE 2017-0263 – виконання довільного коду в kernel-mode та отримання максимальних привілеїв
- CVE 2017-11826 - виконання довільного коду в контексті поточного користувача ч-з файл MS Office
- CVE 2018-8174 - виконання довільного коду ч-з VBScript в контексті поточного користувача
- CVE 2018-8440 - виконання довільного коду в контексті local system
- CVE 2018-8475 - виконання довільного коду ч-з спеціально сформований файл зображення

Посилення захищеності Windows Vista, 2008

- Механізм підвищення прав процесу
- Віртуалізація прав адміністратора (файлової системи і реєстру)
- SMB 2.0

- Довірене завантаження (контроль цілісності системи, ланцюжок перевірок BIOS, MBR, завантажувач ...)
- Перевірка цілісності коду ядра (цифровий підпис)
- Захист стека (Stack Guard)
- Рандомизація адресного простору (ASLR) - адрес завантаження бібліотек, інтерфейсів ...
- Позначення коду як не виконуваного
- Контроль купи
- Зниження привілеїв служб

Windows Integrity Levels (Win Vista, Server 2008 ...) - рівні доступу додатків.

Обмеження взаємовпливу додатків з різним рівнем доступу
(До об'єкта з рівнем N можуть звертатися тільки об'єкти з рівнем N і вище)
Три мітки довіри: Low, Medium, High
Windows Integrity Levels дозволяє організувати додатковий захист файлів (розмежування доступу)

БЕЗПЕКА СКБД

Класи СКБД:

- Реляційні
- Ієрархічні
- Об'єктно-орієнтовані

Відмінності СКБД від ОС:

- Більша кількість об'єктів
- Більше рівнів представленя
- Захист логічної структури (відносин, представлень ...)

Особливості реляційних СКБД:

- Відносини, що встановлюються через ключі (унікальність, мінімальність)
  * Правила цілісності - ніяке поле первинного ключа не може бути NULL
- Представлення (View) - «віртуальна таблиця»
- Обмеження - обмеження на дані
- Тригери - вбудовані процедури, які спрацьовують за певних умов

Технології «представлень» і дозволених процедур (нейтралізація прихованих каналів витоку інформації)

- Представлення - віртуальна СКБД, користувач бачить «своє» представлення
  Не перекривають приховані канали на основі аналізу часових і статистичних параметрів процесів системи
- Дозволені процедури - користувачеві доступний тільки інтерфейс у вигляді набору параметризованих запитів

ЗАГРОЗЫ СКБД

Атаки на файлову систему і фізичні атаки

Мережного рівня:

маніпулювання параметрами пакетів (ім'я користувача, пароль, сигнатура ...) і заміна даних в стеку (переповнення буфера) з метою перехоплення управління, передача даних у відкритому вигляді, вибірка даних БД без SQL (HTTP, JDBC Applet Server, …), обхід автентифікації.

Прикладного рівня:

- Виконання команд ОС (в контексті облікового запису БД):
  -xp_cmdshell() в MS-SQL
  -модуль Oracle TNS Listener: extproc (завантаження і виконання бібліотек) - виклик system() в збережених процедурах PL-SQL (Oracle); підбір імен користувачів або ідентифікаторів БД; **DOS**;
  -створення і виконання процедур в IBM DB2 (вимагає привілеїв на процедури)
  -Remote Command Server в DB2 - віддалене виконання команд від імені сервера
- SQL атаки - вразливості переповнення буфера у функціях і розширеннях збережених процедур, що дозволяють виконати деякий програмний код.
- SQL-ін'єкції - помилки перевірки синтаксису запитів і зміна логіки SQL-запитів. Отримання або зміна інформації БД, підвищення привілеїв, доступ до команд ОС або ФС через SQL-ін`єкції.
- Логічний висновок та узагальнення (агрегування)

Види НСД:

- Читання / запис полів БД
- Видалення полів або таблиць (DoS)
- Визначення (не-) існування об'єкта
- Визначення діапазону статистичної величини
- Порушення цілісності БД

КЕРУВАННЯ ДОСТУПОМ

Стратегії авторизації:

- Позитивна авторизація (deny за замовчуванням, явні дозволи)
- Негативна авторизація (явні заборони)
- Неявна авторизація (правила Суб'єкт-Об'єкт-Привілеї)
- Тематична авторизація (булеві вирази або зумовлені запити - представлення)

* Можуть використовуватися суб'єкти ОС (Windows) або власна система суб'єктів СКБД

Права доступу:

- SQL-statements
- DB, Tables, Columns, Rows, Views, Procedures
- Content-based (predicates)
- History-based

Стратегії адміністрування:

- Централізовано
- Від власника БД або таблиці
- Від власника з можливістю розповсюдження
  (децентралізована модель)

МЕХАНІЗМИ ЗАХИСТУ ORACLE

Права (на об'єкти даних) і системні привілеї (на дії - з'єднання, створення таблиць, ...)
Права і привілеї призначаються через GRANT і за допомогою ролей

Багаторівневі реляційні СКБД

- Мітки доступу (БД, Відносини, Кортеж, Елемент)
  User> Attribute> Tuple> Key> Relation> DB
- Правила консистентності: Attribute> Relation> DB
- Правила цілісності: Data> Pr.Key ...
- Правила видимості: User> Relation User> Key View> All Relation
- NoWriteDown Rule і наявність довіреного суб'єкта для обходу правил
- Механізм часткової видимості
- Правила цілісності (ключі)

В **Trusted Oracle** - механізм захисту від прихованих часових каналів в процедурах забезпечення конкурентного доступу **2PL** (Two-phase Locking) коли Суб`єкт вмикає блокування по *читанню* або *запису* та модулює дані (створює прихований канал по часу).

Специфічні загрози розкриття інформації:

- *інференція;*
- *агрегування;*
- *комбінування* дозволених запитів для отримання закритих даних.

Під *інференцією* розуміють отримання конфіденційної інформації з відомостей з меншим ступенем конфіденційності шляхом логічного виведення. Тобто отримання конфіденційної інформації з джерел з більш низьким рівнем доступу.

Під *агрегуванням* розуміють спосіб отримання більш важливих відомостей у порівнянні з важливістю тих окремо взятих даних, на основі яких і виходять ці відомості. Так, відомості про діяльність одного відділення або філії корпорації мають певну вагу. Дані ж за всю корпорацію куди більш значущі.

Комбінування запитів - використання складних, а також послідовності простих логічно пов'язаних запитів дозволяє отримувати дані, до яких доступ користувачеві закритий. Така можливість є, перш за все, в базах даних, що дозволяють отримувати статистичні дані. При цьому окремі записи, поля (індивідуальні дані) є закритими. В результаті запиту, в якому можуть використовуватися логічні операції AND, OR, NOT, користувач може отримати такі величини як кількість записів, сума, максимальне або мінімальне значення. Використовуючи складні перехресні запити і наявну в його розпорядженні додаткову інформацію про особливості записів (полів), що його цікавлять, зловмисник шляхом послідовної фільтрації записів може отримати доступ до потрібного запису (поля) тобто розкрити значення.

Зловмисник отримує доступ до полів записів СКБД, що містять тільки статистичну інформацію. Завдання зловмисника - сформулювати запит таким чином, щоб множина записів, по якій збирається статистика, складалася тільки з одного запису.

Статистична безпека СКБД

Заборона розкриття окремих полів при зборі статистик (SUM, AVG, MIN, MAX ...)
(Статистика по одному запису завжди розкриває значення)
Природне обмеження - мінімальний набір записів в статистиці
Додаткові знання можуть зменшувати ефективний набір записів до 1
* При наявності необмеженого набору статистик все статистичні БД можуть бути скомпрометовані

Статистичні атаки:

- Прямі (агрегування по малому набору записів)
- Непрямі (комбінування запитів)
- Tracker - різновид непрямої атаки, де ідентифікується існування окремого кортежу
- Лінійні - на алгебраїчні залежності

Методи протидії статистичними атакам:

- Представлення і параметризовані запити;
- Блокування відповіді при неправильній кількості запитів;
- Перемішування даних та анонімізація;
- Спотворення відповіді шляхом округлення та іншої навмисної корекції даних;
- Випадковий вибір записів для обробки;
- Поділ бази даних;
- Контекстно-орієнтований захист;
- Контроль запитів, що надходять.

Метод *блокування відповіді* при неправильному числі запитів передбачає відмову у виконанні запиту, якщо в ньому міститься більше за певну кількість співпадаючих записів з попередніх запитів. Таким чином, даний метод забезпечує виконання принципу мінімального взаємозв'язку запитів. Цей метод складний в реалізації, бо необхідно запам'ятовувати і порівнювати всі попередні запити.

Метод *корекції* полягає в незначній зміні точної відповіді на запит користувача. Для того, щоб зберегти прийнятну точність статистичної інформації, застосовується так званий свопинг даних. Сутність його полягає у взаємному обміні значень полів запису, в результаті чого всі статистики *i*-го порядку, що включають *i* атрибутів, виявляються захищеними для всіх *i*, менших або рівних певному числу. Якщо зловмисник зможе виявити деякі дані, то він не зможе визначити, до якого конкретно запису вони відносяться.

Ефективним методом протидії дослідженню баз даних є метод *випадкового вибору записів* для статистичної обробки. Така організація вибору записів не дозволяє зловмисникові простежити множину запитів.

Застосовується також метод *поділу* бази даних на групи. У кожну групу може бути включено не більше певної кількості записів. Запити дозволені до будь-якої множини груп, але забороняються до підмножини записів з однієї групи. Застосування цього методу обмежує можливості виділення даних зловмисником на рівні не нижче групи записів. Метод не знайшов широкого застосування через складність отримання статистичних даних, оновлення та реструктуризації даних.

Сутність *контекстно-орієнтованого захисту* полягає в призначенні атрибутів доступу (читання, вставка, видалення, оновлення, керування тощо) елементів бази даних (записів, полів, груп полів) в залежності від попередніх запитів користувача. Наприклад, нехай користувачеві в окремих запитах доступні поля: "ідентифікаційні номери" і "прізвища співробітників", а також "ідентифікаційні номери" і "розмір заробітної плати". Зпівставивши відповіді по цих запитах, користувач може отримати закриту інформацію про заробітну плату конкретних працівників. Для виключення такої можливості користувачеві слід заборонити доступ до поля "ідентифікатор співробітника" в другому запиті, якщо він вже виконав перший запит.

Одним з найбільш ефективних методів захисту інформації в базах даних є *контроль запитів*, що надходять, на наявність "підозрілих" запитів або комбінації таких запитів. Аналіз подібних спроб дозволяє виявити можливі канали отримання несанкціонованого доступу до закритих даних.

Приклад: Система безпеки СКБД MySQL

Керування доступом в MySQL (scope + privilege)

User	**Db**	**Host**	**Tables_priv**	**Columns_priv**
Host User Password Select_priv Insert_priv Update_priv Delete_priv Create_priv Drop_priv Grant_priv Reference_priv Index_priv Alter_priv Reload_priv Shutdown_priv Process_priv File_priv	Host User Db Select_priv Insert_priv Update_priv Delete_priv Create_priv Drop_priv Grant_priv Reference_priv Index_priv Alter_priv	Host Db Select_priv Insert_priv Update_priv Delete_priv Create_priv Drop_priv Grant_priv Reference_priv Index_priv Alter_priv	Host User Db Table_name Grantor Timestamp Table_priv (…) Column_priv: Select, Insert, Update, Reference	Host User Db Table_name Column_name Timestamp Column_priv: Select, Insert, Update, Reference

Эфективні права: **User** or (**Db** and **Host**) or **Tables_priv** or **Columns_priv**

- Не можна явно заборонити доступ
- Не можна дозволити видалення таблиць, але не БД

- **SELECT, INSERT, UPDATE, DELETE** - операції над елементами таблиць
- **FILE** - створення (читання) файлів в контексті облікового запису mysql_user (LOAD DATA INFILE, SELECT ... ONTO OUTFILE)
- **INDEX**
- **ALTER** - перейменування таблиці mysql (службові дані)
- **CREATE** - створення (видалення) баз даних і таблиць
- **GRANT** - надання прав
- **RELOAD, SHUTDOWN, PROCESS, SUPER** (kill) - адміністрування БД
- **PROCESS** - перегляд виконуваних запитів (~ аргументи командного рядка в команді 'ps')

- Запускати демон mysql як mysql_user (а не під root)
- Обмежені привілеї на таблицю mysql
- Політика паролів: паролі для всіх, шифрування паролів в БД (не MD5))
- Захист від SQL - ін'єкцій: (спеціальні та escape-символи в Web -формах і URL) - перевіряти розмір даних і екрануючі символи

Захист мережного з'єднання:

- передавання паролів по мережі (compress protocol, слабке шифрування PASSWD)
- не покладатися на DNS при керуванні доступом (використовувати IP в явному вигляді)
- SSH тунель
- SSL-шифрування і застосування сертифікатів X.509 для автентифікації
- не застосовувати порти (тільки сокети UNIX) при локальному підключенні

Керування ресурсами (підвищення продуктивності):

- max_user_connections
- max_connections_per_hour
- max_queries_per_hour
- max_updates_per_hour

SQL - ін'єкції

При помилках синтаксичного аналізу використання екрануючих символів (; '-) дозволяє сформувати і виконати запит до БД (змінити логіку запиту) з метою:

- Отримання та модифікації даних
- Доступ до ФС, створення і виконання файлів
- Виконання коду і команд ОС
- DoS атаки на сервер

Несанкціонований доступ до використовуваних сервером баз даних, до файлів на сервері і виконання команд завдяки використанню некоректних параметрів і особливостей синтаксису.

Причина: пряма конкатенація нефільтрованих (неприводимих до потрібного типу) строкових значень (Приклад введення: 'or 1 = 1 - -'), дані користувача складають частину запиту.

Класи SQL-ін'єкцій:

- UNION query SQL-injection (UNION ALL SELECT ...)
- Stacked queries SQL-injection (послідовні запити)
- ERROR-based SQL-injection
- Boolean-based blind SQL-injection
- Time-based blind SQL-injection

Можливе посимвольне отримання даних (версія СКБД, логіни, паролі,...)

Заходи захисту: перевірка безпеки синтаксису, фільтрація і приведення типів, вбудовані (параметризовані) запити, налаштування прав доступу.

Технології паралельного виконання транзакцій в СКБД
Механізми забезпечення цілісності, квазіпараллельне виконання транзакцій

Проблеми псевдо-паралельного виконання:

Втрачені зміни - дві транзакції одночасно змінюють той-же об'єкт даних.
Якщо відбувається відкат однієї з транзакцій, то разом з цим скасовуються зміни, зроблені іншою транзакцією. Рішення - блокування даних

«Брудні» дані - одна транзакція змінює дані, а інша в цей момент читає і отримує неузгоджені дані.
Рішення - заборона читання іншою транзакцією

Неповторюване читання - одна транзакція читає об'єкт даних, а інша до заврешенія першої його змінює і успішно фіксується. Якщо першій транзакції потрібно повторно провести читання - вона бачить дані в іншому стані (читання не повторюється).
Рішення - заборона змін поки читання не завершено.

Ізоляція транзакцій грунтується на техніці сериализации транзакцій.

Підходи до сериалізації транзакцій:
- Блокування об'єктів БД
- Тимчасові місця об'єктів БД

Режими захоплення:

- Поділюваний (спільний) режим, поділюване захоплення по читанню.
- Монопольний (ексклюзивний) режим, неподілюване захоплення при оновленні даних, захоплення по запису.

Реалізація захоплення з читання - двофазний протокол синхронних захоплень (блокувань) об'єктів БД
Перша фаза - накопичуються захоплення необхідних об'єктів
Друга фаза - фіксація змін і звільнення захоплених об`єктів.

Допускається суміщення тільки захоплень з читання!
Решта транзакції очікують розблокування об'єктів даних.

Недолік - можливість виникнення тупикових ситуацій.

- Автоматичне виявлення тупикових ситуацій і їх руйнування - аналіз графа очікування транзакцій.
- Алгоритм руйнування тупиків - сама «дешева» транзакція або транзакція з найменшим пріоритетом.

Техніка часових міток - транзакції приписується тимчасова мітка початку виконання.
При виконанні операції об'єкт позначається міткою і типом операції (читання, зміна).

Якщо інша транзакція вимагає операції над позначеним об'єктом:
-Перевіряється, чи не закінчилася перша транзакіця.
-Якщо закінчилася - об'єкт позначається міткою другий транзакції.
-Якщо перша транзакція не закінчилася - перевіряється конфліктність ситуації (конфліктною будь-яка комбінація, окрім «читання - читання».)
-Якщо операції неконфліктні - вони виконуються для обох транзакцій, а об'єкт до завершення позначається міткою більш пізньої транзакції.
-Якщо операції конфліктні - відбувається відкат більш пізньої транзакції і виконується рання транзакція, а потім виконується пізня транзакція.

Конфліктність транзакцій вирішується більш грубо і викликає більш часті відкати, проте відсутні тупики та відповідні накладні витрати.

Заходи захисту СКБД:

- Захист файлів СУБД
- Обмеження повноважень облікового запису БД - принцип найменших привілеїв
- Розмежування доступу до об'єктів СКБД (таблиць, системних таблиць, стовпців, процедур, триггерів); обмеження операцій користувача; захист системної таблиці БД
- Захист від SQL-ін'єкцій - перевірка синтаксису даних, що вводяться
- Криптографічний захист даних (на рівні ФС, СКБД, або на прикладному рівні)
- Впровадження нормативної (мандатної) політики доступу
- Керування ресурсами (пам'ять, процесор, дискові квоти, підключення / транзакції)
- Захист з'єднань з мережі
- Захист системи і мережний екран
- SQL-сканери (SQL-map, Acunetix WVS, модулі metasploit ...) - визначення СКБД, вилучення інформації, визначення вразливостей, модулі атак
- Засоби аудиту, налаштування нотаризації запитів за ключовими словами
- Політика встановлення оновлень

Питання:

в курсі «Кібербезпека-1»

Різновиди СКБД.
Особливості реляційних СКБД.
Загрози і вразливості СКБД мережного і прикладного рівнів.
Напрями та заходи захисту СКБД.
Які підсистеми захисту можуть бути в складі СКБД.
Види авторизації в СКБД.
Архітектура керування доступом MySQL.
Засоби захисту MySQL на рівні операційної системи.
Засоби захисту MySQL на рівні мережі.
Способи криптографічного захисту даних СКБД.
Принцип дії SQL-ін'єкції. Різновиди і загрози SQL- ін'єкцій.

в курсі «Кібербезпека-2»

У чому полягає діскреційне, нормативне та рольове керування доступом в СКБД.
Нормативне керування доступом в СКБД.
Приклади правил нормативного керування доступом в СКБД.
Що розуміється під статистичної безпекою СКБД і напрямки її забезпечення.
Технології «представлень» і параметричних процедур.
Механізми цілісності та відмовостійкості в СКБД.
Механізми розпаралелювання транзакцій.

ВРАЗЛИВОСТІ ОПЕРАЦІЙНИХ СИСТЕМ І ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ

Види помилок ПЗ:

- контроль допустимих значень параметрів (кількість, тип, розмір ...)
- помилки перевірки границь об'єктів (рядків, масивів, файлів ...) - можуть призводити до переповнення буфера
- помилки послідовності дій (підміна результату між двома послідовними функціями ...)
- помилки ідентифікації і автентифікації
- помилки визначення доменів (областей) пам`яті: неконтрольований доступ в захищені області пам'яті, диску. Збереження інформації після видалення об'єкта. Можливий доступ на фізичному рівні
- інші помилки в логіці програм

Переповнення буфера (буфер - масив для проміжного зберігання даних)
Локальні буфери (стек), статичні (сегмент dss), динамічні (сегмент bss).

Вихід вмісту однієї області пам'яті за встановлену межу і перехід в іншу область пам'яті через відсутність перевірки. За межею буфера може бути інший буфер (дані), скалярні змінні (індекси, прапори...), вказівники (рідше) …. або нічого:) .
Переповнення може призводити до заміни (модифікації) даних, що знаходяться за буфером і навіть викликати незаплановане виконання команд.

- У стеку (Smaching the stack)

Стек зростає «вниз». Переповнення чергового елемента стека замінює дані, які були внесені раніше (наприклад, адресу повернення - покажчик EIP).

- Якщо програма приймає рядки введення і має великі привілеї (напр. SETUID / SETGID), то переповнення стека дозволяє вставити код і передати йому управління (якщо дані в стеку можуть бути інтерпретовані як команди).
- Шеллкод (Shellcode) - виконуваний код - навантаження експлоїта (запуск командної оболонки, відкриття з'єднання на заданом порту ...)
- NOP-ланцюжок і багаторазове дублювання адреси повернення спрощує передачу управління.

Модифікація змінних в стеку зустрічалася частіше за інших. Помилки переповнення в стеку-критичні.
Запобігання - заборона виконання даних (DEP), рандомізація адресного простору (ASLR)...

- У статичній обо динамічній пам'яті

Відсутня можливість змінити адресу повернення, але можливо змінити інші суміжні дані в адресному просторі програми (наприклад, вказівники на функції, які змінюють хід програми, імена файлів, паролі, UID, GID, PID ...)

- Переповнення на 1 байт (помилка на 1)

Стає можливим через особливості форматів представлення рядків (зберігається на 1 байт більше, ніж оголошена довжина рядка). Може бути змінений лише один байт даних, який, тим не менш, може *непередбачувано* вплинути на виконання програми.
Таке переповнення виникає не рідше за інші типи, але шукати його потрібно спеціально. Може проявлятися тільки іноді.

В тому числі — *індексне переповнення* (доступ до комірки пам`яті за буфером).

Переповнення може відкривати можливість зловмиснику читання “таємних” змінних (паролі, дескриптори...) або їх модифиікації (паролі, індекси, вказівники...), передачі керування на таємну функцію (зміна логіки програми або підміна вказівника) або на шеллкод.

Помилки обробки форматних рядків

Некоректна обробка неочікуваних даних.
Може існувати в програмах явно або неявно (через бібліотеки).
Небезпека виникає в програмах з високими привілеями.

- Читання / запис деякої адреси пам'яті в *printf* ()
- Конвеєри (|*prog*, *prog*|)

Якщо програма обробляє рядки самостійно, не використовуючи інтерпретатор, то при помилках синтаксичного аналізу буде оброблений результат роботи конвеєра (виконання коду від імені програми).
Наприклад:
open (*prog*|) - буде запущений файл prog і програма обробить результати його роботи*;*
open (|*prog*) - буде запущений файл prog і результати будуть направлені в стандартний потік виведення (термінал);

- Перенаправлення введення/виведення

Якщо *file* - ім'я файлу, то <*file* може бути оброблено як вміст файлу.
При цьому будуть використані права поточної програми, а не користувача, що її запустив.

- Спеціальні символи і шаблони (?, *, . (крапка), .. (дві крапки))

Небезпечно використовувати шаблони в програмах з високими привілеями.
Дана помилка частіше зустрічається в серверному ПО (виведення тексту сценарію, вихід за межі «файлової системи сервера», обхід обмежень доступу.)

Методи аналізу безпеки ПЗ:

-Контрольно-випробувальний (тестування)

Запуск у віртуальному середовищі з контролем взаємодій;
Програми-сторожа (контроль виконання/нелегітимною доступу або контроль стану системи).

-Логіко-аналітичний

* Література: Зегжда. Інформаційна безпека. (П. 2.3.2.3, стор 116)

Пошук вразливостей:

-Кмітливість
-Аналіз коду (шаблони)
-Фаззінг - випадкове формування вхідних даних (стрес-тест) та аналіз аварійного завершення (перебір вхідних даних, мутація, графові, генетичні та евристичні алгоритми)

Шкідливе програмне забезпечення (malware)

Всі програми, що порушують політику безпеки системи.
Можуть виконувати деструктивні функції або ж не виконувати.
Можуть залишати закладки або не залишати.
Розрізняються за способом поширення і шкідливій дії.

- Віруси (Viruses) - автоматично відтворюються (поширюють себе на комп'ютері) і несуть програмний код (паразитують на коді, використовують програму як носій): файлові, завантажувальні, макровіруси, скриптові віруси.

- Черв`яки (Worms, Хробаки) - мають механізм поширення через мережу автоматично (мережні віруси, *можуть не мати файлу*). Використовують вразливості ОС або ПЗ для проникнення (запуску). Не потребують «допомоги» користувача. Як правило, не використовують код інших програм. Розрізняють поштові, instant messenger, IRC, P2P, та ін. Напів-хробаки доставляються на PC як хробаки, а надалі діють як троянці.

- Троянці (Trojans) - маскуються під корисне ПО, запускаються за допомогою користувача (не запускаються автоматично), можуть містити небажані функції - вірус або черв`як.

- Програмні закладки (шпигунські програми, перехоплювачі клавіатурного введення, логічні бомби, люки). Можуть встановлюватися вірусами, хробаками або троянцями.

- Хакерські утиліти - експлойти (засоби атаки - програми, які експлуатують вразливості системи), технологічні програми (утиліти фрагментації, форматування, зміни BIOS або редагування реєстру ...).
  Хакерські утиліти не мають засобів розмноження. Можуть бути запущені виключно користувачем.
  Хакерські утіліти можуть порушувати політику безпеки системи.

Програмні закладки

На відміну від легальних, відсутнє попередження про виконувані функції, приховують своє існування.
Мета: шпигунство, backdoor / proxy, агент BotNet, знищення інформації / DoS.
Можуть встановлюватися безкоштовним або умовно - безкоштовним ПЗ, вірусами, троянами, хробаками або користувачами - зловмисниками (можлива наявність адміністративного інтерфейсу для віддаленого управління і збору інформації).

- Шпигунські програми (перехоплення і передача інформації, пошук у файловій системі): крадіжка паролів, програми - шпигуни (Spyware). Збір інформації для виробника. Можливий витік інформації через приховані канали.

Шпигунські програми порушують конфіденційність інформації.

- Логічні бомби (або часові міни; порушують функціонування системи при певних умовах) - знищують або модифікують інформацію або блокують систему.

Приклад: CHIN - модифікація flash-bios.

Логічні бомби порушують цілісність або доступність інформації.

- Модифікатори ПЗ:
  - утиліти віддаленого адміністрування (віддалений помічник у Windows, троянці: BackOrifice (1998), NetBus, ...)
  - інтернет - клікери (для збільшення відвідуваності сайтів або проведення DoS)
  - проксі-сервери (посередники, анонімайзери)
  - дзвонилки на платні ресурси (телефонні номери; існують для ОС мобільних телефонів)
  - організатори DoS і DDoS атак
  - інсталятори з мережі (без попередження)

Модифікатори ПО порушують спостережність і керованість системи.

- Психоделічне ПО: реклама або жарти

Поводяться як віруси, чіпляються до web- браузеру і борються з конкурентами. Можуть встановлюватися з використанням вразливостей і проявляти риси троянців і вірусів. Adware-віруси - чіпляються до браузерів.

* Примітка: BotNet (перші BotNet - 2002 р.) - армія заражених і централізовано керованих комп'ютерів. BotNet може використовуватися для DDoS атак, розсилки спаму, розподілених обчислень (підбору паролів, обчислення гешів, майнінг), поширення нових версій свого ПЗ. Управління - через канали IRC, web-сайти, P2P мережу.

Люки

Недокументовані можливості програм для тестування/відладки або в троянських програмах. Наприклад, режим debug демона sendmail давав можливість вказувати програму для обробки вмісту повідомлення. Обробка виконувалася з правами поштового демона.

Прихований процес на аткованій системі, що дозволяє її контролювати.

Приклади: Netcat (nc), Cryptcat, Netbus, ...

Руткіти - закладки в ПЗ ядра (і навіть в апаратному забезпеченні!), що дозволяють приховувати від користувача і операційної системи сліди злому: процеси, програми, файли, порти, ключі реєстру …
Раніше руткітів існували Stealth-віруси, що перехоплювали деякі функції ОС з метою маскування.
Заходи захисту: не допустити (контроль цілісності коду, TPM), виявити, видалити.
Буткіт - закладка (віртуалізатор), впроваджений до завантаження ОС.

Заходи захисту: мінімальні необхідні привілеї користувачів, налаштування антивіруса, мережних екранів і системи запобігання атак, моніторинг інформаційних потоків з Інтернет, встановлення оновлень і латок.

Віруси

- Файлові (паразити) - можуть заражати модулі, бібліотеки, інсталятори, тексти програм, архіви. Запускаються з повноваженнями користувача, що їх запустив.
- Завантажувальні. Завантажуються до захищеного режиму ОС. З метою маскування можуть створювати віртуальне середовище для ОС. Autorun - віруси.
- Макровіруси (програми в документах: графічні редактори, Excel, Word, САПР). Макроси мають доступ до файлової системи комп`ютера. Зараження шаблону документа призводить до автоматичного виконання і розповсюдження в інших документах. Зазвичай мають доступ не тільки до документів.
- Скриптові (в виконуваних сценаріях): ActiveX, Java, JS, VBS, BAT, Perl, PHP, Python ...

Віруси та троянці поширюються:

- Заражені файли;
- Сервіси спільного доступу до файлів;
- Носії інформації;
- Електронна пошта.

Прийоми вірусів:

- Маскування - ім'я схоже на ім'я існуючої програми;
- Морфінг - модифікація коду або шифрування з різними ключами;
- Приховування факту модифікації файлу або розміру файлу (Stealth віруси);
- Механізми протидії запуску в режимі відлагодження або логічна бомба, що спрацьовує при спробі видалення вірусу (анти-емуляція, перевірка пісочниці);
- Винос (вбивство) GUI.

Захист від вірусів:

- пошук сигнатур;
- еврістичний аналіз (характерного для вірусів набору операцій, нетипового доступу);
- запуск в замкнутому програмному середовищі з контролем взаємодій;
- контроль цілісності об'єктів;
- комплексний аналіз пам'яті.

Сигнатура - формальний опис ознак (фрагмент коду з метасимволами, статистики, експертні бали ...)

Пошук сигнатур і евристичний аналіз визначають статус файлу до його запуску.
Контроль цілісності об'єктів і аналіз пам'яті - пост-реагування.

Режими роботи антивірусів:

- сканери (сигнатури, ознаки)
- монітори (контроль поточних операцій)
- фільтри (контроль потоків даних)

-А-а, черв`яки. Я маю якось побачити одного з них.
-Може бути, ви і побачите його сьогодні.
(Френк Херберт, «Дюна»)

Черв`яки (Worms)

- поштові - використовують список контактів (список адрес) для розсилки свого коду або посилання в листі і можуть «відповідати» на листи. Використовують вразливості поштових клієнтів або чекають запуску (троян);
- в системах обміну повідомленнями (Instant Messengers) і IRC каналах - розсилають посилання (URL) на шкідливий код;
- в файлообмінних (P2P) системах - записують себе з популярним ім'ям в каталог роздачі;
- NetWorms (інші) - проникнення і копіювання на відкриті мережні ресурси, проникнення в ОС за допомогою вразливостей, пошук цілей, використання люків (закладок) на хостах-жертвах.

-Черв`як прийде обов'язково?
Обов'язково.
(Френк Херберт, «Дюна»)

Перший відомий вірус Морріса (листопад 1988р.) був черв`яком.

- Автоматичний пошук цілей атаки;
- Набір засобів проникнення (debug в sendmail, переповнення стеку, підбір паролів, використання довіри між хостами в службі Rlogin);
- Завантаження решти коду, компіляція та виконання;
- Повідомлення про зараження;
- Прикриття (модифікація коду XOR 81H);
- Перевірка на зараження (не заражають системи повторно) - прослуховував порт 23357;
- Деструктивні функції були відсутні.

Через помилку в системі перевірки на зараження став заражати системи багаторазово та викликав перевантаження мережі.
Заразив 6200 хостів. Довелося зупинити і протестувати 42700 хостів.
$32млн - прямого збитку, $98млн - непрямих збитків.

В результаті був підвищений рівень безпеки систем.
Р. Морріс - старший - один з провідних експертів з комп'ютерної безпеки в США.

-Це знак черв`яка?
-Черв`як. І великий.
(Френк Херберт, «Дюна»)

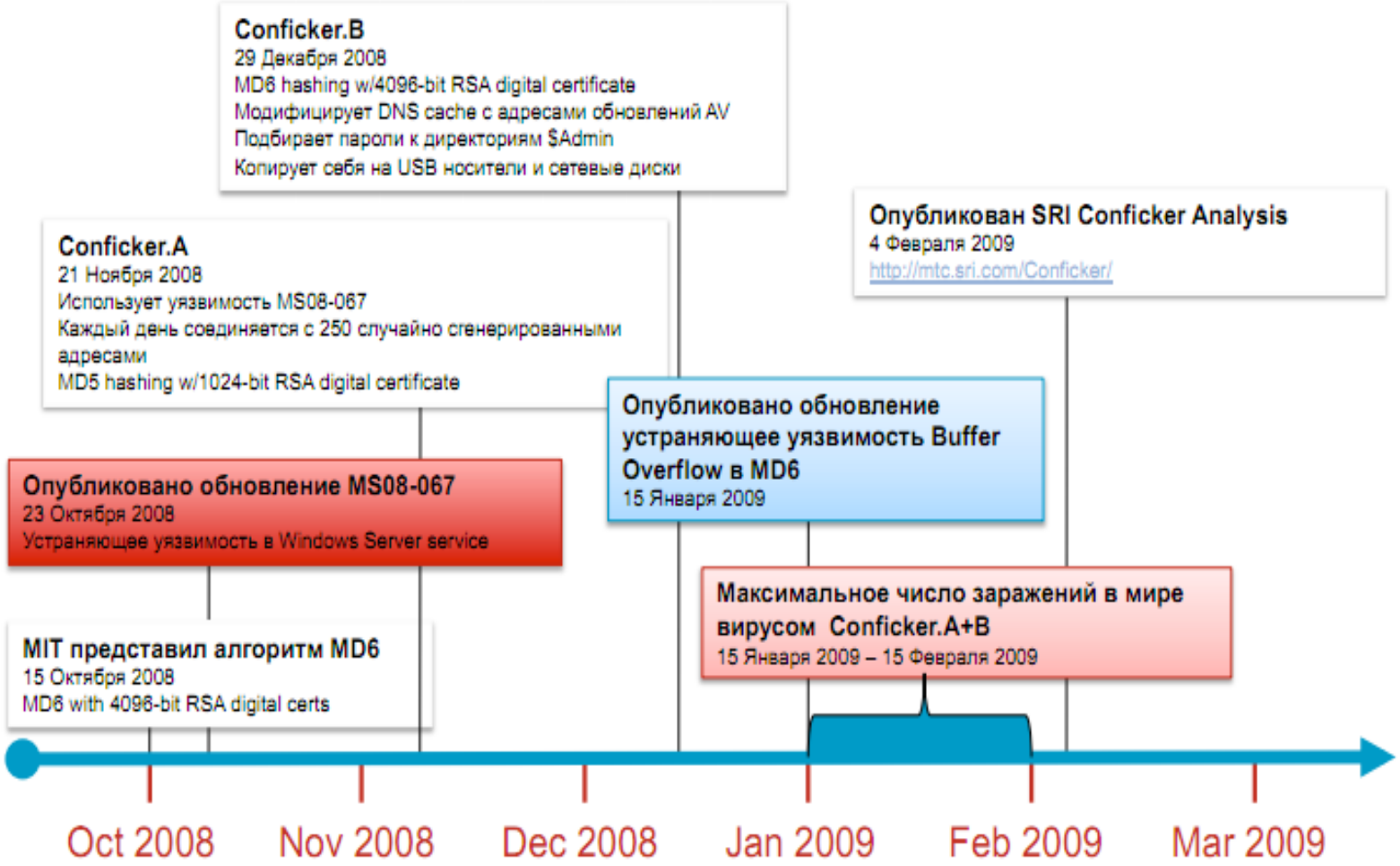
Conficker:

-MS08-067 - вразливість в службі сервера - виконання довільного коду ч-з RPC запит (Win 2000 / XP / 2003 / Vista / 7/2008);
-MS08-068 - виконання коду в службі SMB
-MS09-01 - переповнення в протоколі SMB (виконання коду, DoS).

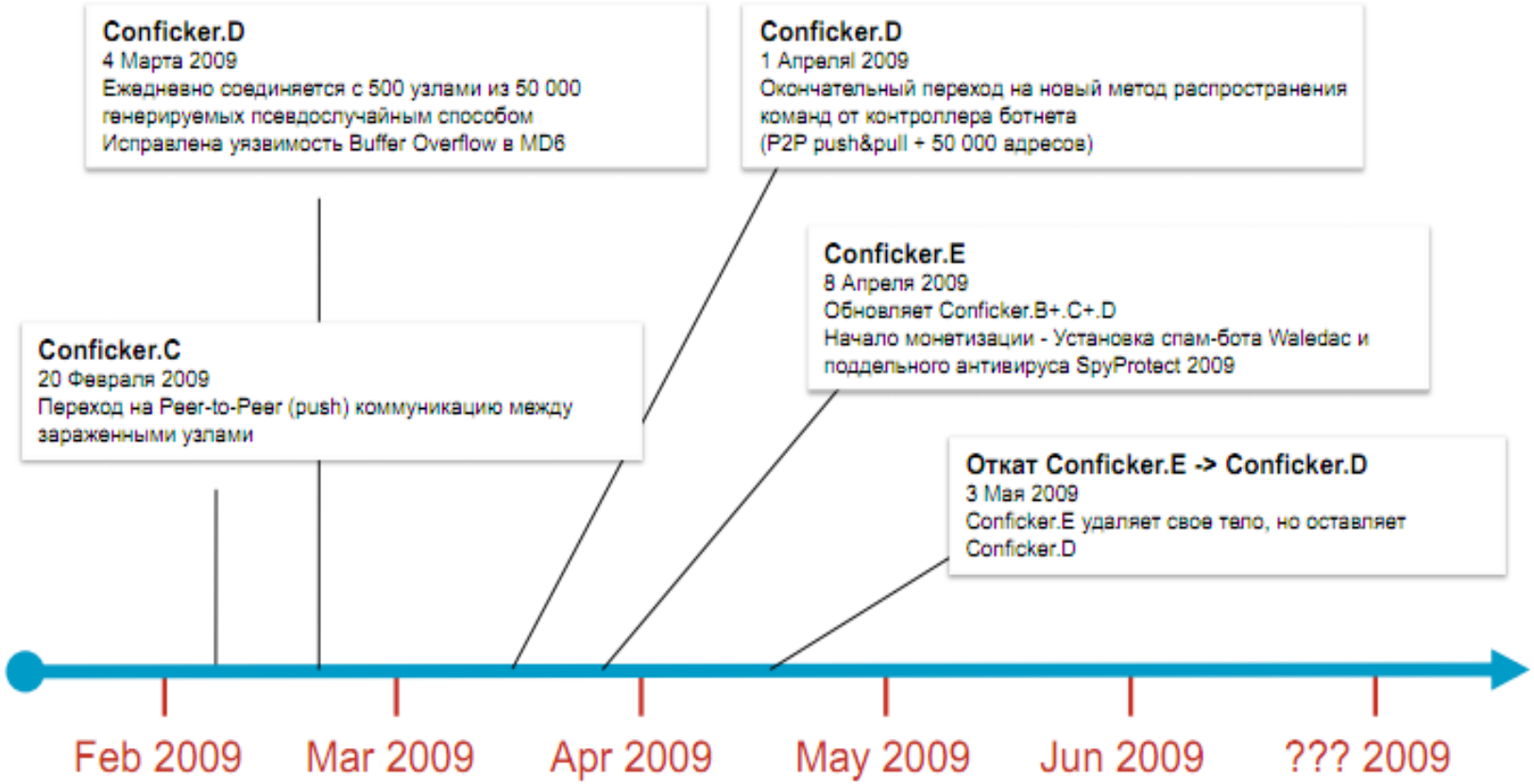
-Поширення ч-з USB
-Відключення служб захисту, блокування оновлень антивірусів
-Централізоване управління через пірінгову (P2P) мережу
-Мутації
-Монетизація

Збиток Conficker - 3-е місце в історії після MyDoom і I Love You.

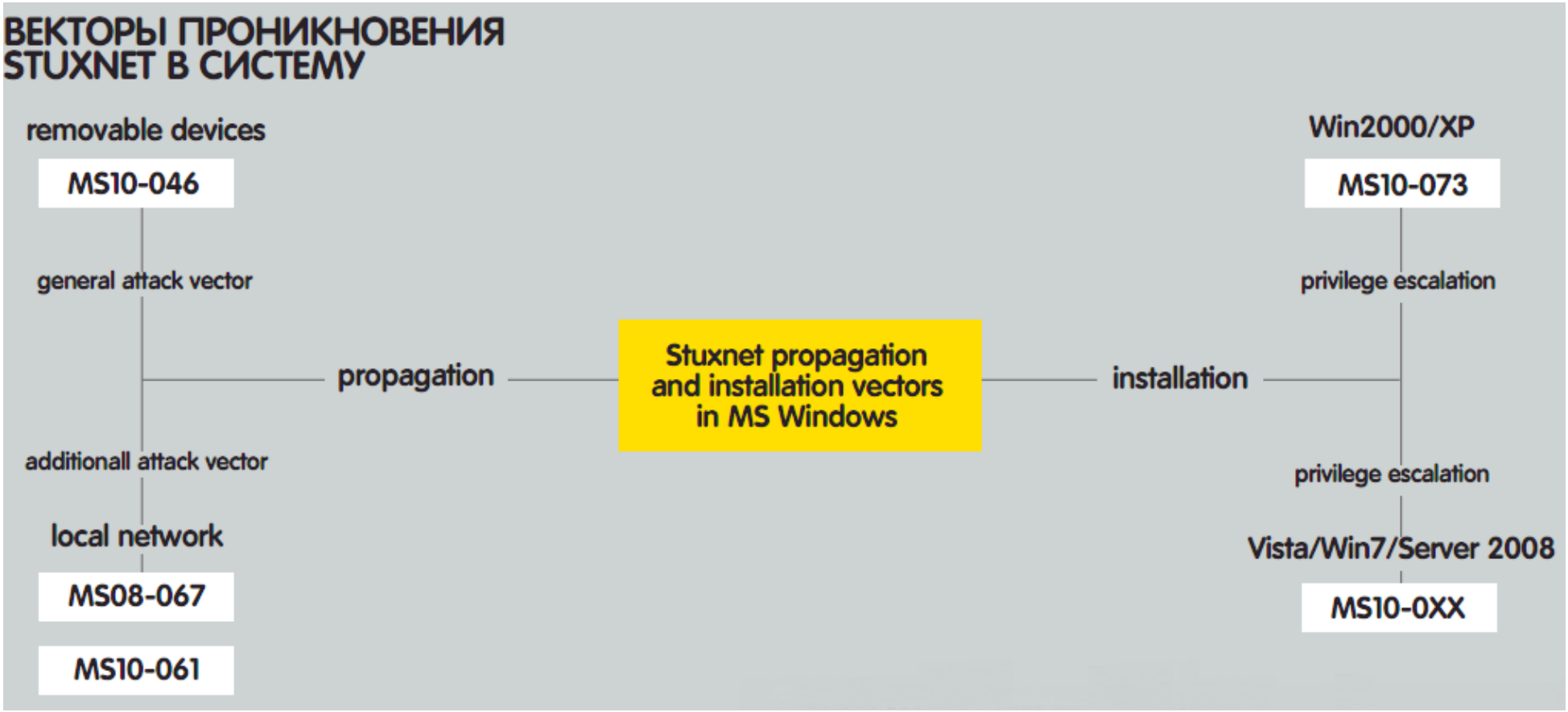
Conficker: Развитие событий



Conficker: Развитие событий (прод.)



-Якої величини територію повинен контролювати кожен черв'як?
-Це залежить від розмірів черв`яка.
(Френк Херберт, «Дюна»)



Stuxnet (17 Jun 2010):

-MS08-067 - вразливість часів Conficker;
-MS10-046 - вразливість обробки .lnk файлів;
-MS10-061 - виконання коду в Print Spooler;
-MS10-073 - підвищення привілеїв і виконання коду в ядрі (win32k.sys, Win2000 / XP)
-Підвищення привілеїв до System в Task Sheduler (Vista / Win7 / Win2008)
-CVE-2010-2772 - вразливість SCADA-систем (фіксований пароль до MS-SQL з WinCC)

-розповсюдження через зовнішні носії;
-використання легальних сертифікатів Realtek та JMicron;
-встановлення драйверів з руткітом;
-пошук цілей в LAN, поширення через мережні файлові каталоги (дроппер);
-власний протокол обміну з контролером та обмін по P2P мережі.

WIN32 / DUQU (1 Spt 2011):

-CVE-2011-3402 - помилка парсеру TrueType шрифтів, виконання довільного коду в .doc файлах

-проникнення ч-з .doc файли;
-завантаження шелл-коду в win32k і ядро;
-"встановлення" драйвера, легальний цифровий підпис C-Media;
-проникнення в services.exe;
-встановлення keylogger;
-протокол розповсюдження – RPC.

-Як же тоді впоратися з черв`яками?
-Мені невідомо зброї, окрім атомної, вибухової сили якої було б достатньо для знищення черв`яка цілком.
(Френк Херберт, «Дюна»)

Функциональность	Stuxnet	Duqu
Легальные цифровые подписи	да	да
Модульная архитектура	да	да
Внедрение в SCADA-системы	да	нет
Модуль-кейлоггер	нет	да
Обход антивирусной защиты	да	да
Использование уязвимостей 1-day	да	нет
Использование уязвимостей 0-day	5	1
Внедрение в системные процессы	да	да
Использование RPC-протокола	remote	local
Хранение модулей в секции ресурсов	да	да
Использование методологии ООП	да	да
Обработка ошибок (в том числе и в шеллкоде)	да	да
Высокая стабильность кода	да	да
Использование компилятора Visual C++	да	да
Использование библиотеки шаблонов ATL	да	да
Использование упаковщика UPX	да	да

Троянці

Зазвичай привертають увагу користувача корисним вмістом («шарою») і виконують (розміщують) шкідливий код (або потаємний хід). Деякі троянці можуть запускати черв'яка.
Троянці можуть поширюватися у вигляді вихідного коду.
EliteWrap — інструмент пакування троянців в будь-який виконуваний файл

Види троянців (класифікація Касперського - за дією):

- Шпигунські програми (Spy, Notifier);
- Парольні злодії;
- Крадіжка кодів доступу (AOL, ICQ, Skype …);
- Backdoor (таємний хід, утиліти віддаленого адміністрування);
- Проксі (Proxy) - приховування адреси, атака через скомпрометовану систему;
- Клікери (Clickers) - автоматично заходять на сайти, розсилають себе через MMS або Bluetooth (на мобільній платформі);
- Архівні бомби (ArcBomb) - невеликий файл при розархівації займає забагато простору на диску;
- Інсталятори шкідливих програм (Downloaders - скачують з мережі; Droppers - мають код при собі).

Приклад: програми для скачування аудіо- та відеофайлів vkontakte.ru - крадіжка паролів.
Скрипти адміністрування - завуальований (наприклад, через XOR) запуск шкідливого коду.
Архіви, що саморозпаковуються, з книгами, архіви які розпаковують файли в інші папки, не виконувані файли (doc, rpm, Power point, Photoshop), що виконують шкідливий код ...

Найбільш відомі троянські порти: Doom - 666, Snipernet – 667, Tini – 7777, WinHole – 1080-81, RAT – 1095, 1097-8, SpySender – 1807, Deep Throat – 2140, 3150, NetBus – 12345,12346, Whack a Mole – 12362, 12363, Back Orifice – 31337, 31338.

Джерела доставки:

- Оновлення існуючих програм;
- Перевірка системи безпеки;
- Програми атаки (злому систем безпеки);
- Друзі;
- Групи новин;
- Реклама по електронній пошті.

Заходи захисту:

- Не запускайте програми, отримані з ненадійних джерел;
- Точно дізнайтеся, що ви збираєтеся запустити;
- Перевіряйте сповіщення постачальників програми, MD5sum, PGP підпис;
- Запускати програми в замкнутому віртуальному середовищі (VMWare, chroot, ...);
- Не запускайте програми з правами адміністратора;
- Перевіряйте вихідний код (напр. утіліта diff, md5sum, ...);
- Не впевнений - не запускай.

"Зброя як зброя ...."

Хакерські утиліти

- Засоби проникнення, DoS атак, експлойти (exploits) – програмні засоби реалізації атак, Nukes - фатальні мережні атаки, що призводять до краху системи, генератори сміття;
- Утиліти адміністрування (дебагери, дизасемблери та ін. аналізатори …);
- Засоби створення шкідливого ПЗ (конструктори, генератори, шифрувальники...).

Metasploit Framework (MSF) - найбільш розвинена система з відкритим кодом і зручним інтерфейсом для створення і тестування експлойтів.

MSF містить набір бібліотек модулів передачі управління на код зловмисника і набір модулів «корисного навантаження» (шкідливий код).

- Сканери (Scanners): information gathering, vulnearability scanning;
- Есплоіти (Exploits): windows, linux, solaris, MS-SQL, cisco, Wi-Fi;
- Навантаження (Payloads): shell, reverse shell, user create …;
  Meterpreter:
  - information gathering, traffic capture;
  - migrate to another process, kill antivirus;
  - SAM dump => pass-the-hash;
  - AD tocken impersonation;
  - Pivoting to another system;
- Прослуховувачі портів (Listeners);
- Кодувальники (Encoders);
- Скрипти та модулі (Scripts, Modules);
- Атаки зі сторони клієнта (Client-size attacks): privilege escalation, file format attacks (.doc, .rtf, .pdf etc …).

Питання по темі:

Фактори вразливості програмного забезпечення.
За якими ознаками класифікуються вразливості операційних систем і програмного забезпечення.
Описати причини появи і можливі наслідки помилок ПЗ кожного виду.
Причини виникнення переповнення в стеку.
Можливі наслідки переповнення в динамічній пам'яті.
Можливі наслідки переповнення в 1 байт.
Можливі наслідки помилок обробки форматних рядків.
Методи аналізу безпеки ПЗ.

Що називається «шкідливим ПЗ».
Класифікація шкідливого програмного забезпечення (троянських програм, різновиди програмних закладок, різновиди мережних черв'яків і вірусів).
Описати принцип дії шкідливого ПЗ кожного виду і перерахувати можливі різновиди.

Різновиди програмних закладок і їх властивості.
Що в ПЗ називається «люками».
Що називається «руткітом».
У чому небезпека руткітів / буткітів. Механізми захисту.
Різновиди вірусів.
Методи виявлення вірусів.
Що в антивірусах називається «сигнатурою».
Способи маскування і самозахисту вірусів.
Режими роботи антивірусів.
У чому особливості шкідливого ПО названого «черв`яком».
Різновиди «черв'яків».
Способи проникнення троянських програм в систему.
Різновиди троянців.
У чому небезпека троянських програм.
Заходи захисту від троянських програм.
Яке ПЗ відноситься до “хакерських утиліт”.

- Таненбаум Э., Бос Х. Современные операционные системы. 4-е изд. - СПб.: Питер, 2015. - 1120 с.
- Эриксон Дж. Хакинг: искусство эксплойта. 2-е изд. - Пер. с англ. - Спб.: Символ-Плюс, 2010. - 512с.
- Козиол Дж., Личфилд Д., Энли К. Искусство взлома и защиты систем. - СПб.: Питер, 2006 - 416 с.

ОСНОВИ МЕРЕЖНОЇ БЕЗПЕКИ

Загрози роботі мереж:

- Сканування
- Підміна (spoofing) адреси відправника або підміна суб'єкта (impersonating)

- Прослуховування трафіку
- Перехоплення сесії (*MITM* – Man-in-the-Middle)

- Відмова в обслуговуванні (DoS, *DDoS*):
  -аварійне завершення служб (програмний експлойт, переповнення)
  або стоворення надмірного навантаження на службу
- Приховані канали передачі інформації

- концептуальні вразливості протоколів (SMTP, FTP, Telnet) або вразливості реалізації
- атаки з використанням протоколу або атаки на реалізацію протоколу

Прикладний рівень: вразливості ПЗ, передавання даних у незахищеному вигляді
Транспортний рівень (TCP, UDP): сканування, DoS, угон TCP - сеансу
Мережний рівень (IP, ICMP...): підміна IP адреси, сканування, DoS, фальсифікація маршрутизації
Канальний рівень (технології фізичних мереж): несанкціонований доступ, підміна MAC, ARP, DHCP сервера, фальсифікація STP-root, вихід за межі VLAN

Мережні атаки (атаки на мережу):

- **Reconnaissance** (розвідка, зондування)

Сбір інформації (Web, dig, nslookup, whois …), сканування мереж, хостів (IP адрес), портів, сервісів, вразливостей.

- **Access** (доступ)

Отримання данних, доступу до системи, підвищення привілеїв...
Наприклад: Отримання паролів, обхід автентифікації, використання довіри, перенаправлення портів, MITM, підміна IP, MAC або DHCP

- **Denial of Service** (відмова в обслуговуванні)

Перевантаження або використання вразливостей, що призводять до збою або сповільнення роботи.
DDoS (розподілений DoS) – використання багатьох зомбі-ботів та/або з використанням «підсилення» (*Amplification and Reflection*).

- **Worms, Viruses, Trojan Horses** (хробаки (черв`яки), віруси і трояни)

- **Соціальна інженерія:** введення в оману з метою отримання даних або спонукання до дій, спам, фішинг.

Фішинг: масовий або зфокусований, по пошті, телефону, sms ...

Атаки канального рівня

- Неавторизований доступ
- Атаки підміни (Spoofing): ARP-spoofing, MAC address spoofing, DHCP spoofing. Підміна (модифікація) інформації ARP, підміна DHCP сервера (Rouge DHCP) - перенаправлення трафіка, MITM, DoS
- Атаки на MAC рівень (MAC layer attacks): MAC address flooding
- Атаки на VLAN (VLAN hopping): Switch spoofing, Double-tagging
- Атаки на протокол STP: підміна комутатора (Switch spoofing)
- Атаки на комутатори (Switch device attacks) - ч-з Telnet, SSH, SNMP, CDP, Web-інтерфейс

Пристрої, впроваджені зловмисником (Rouge devices): Wireless Access Points, Switches

- Перехоплення трафіка (Traffic sniffing)
- Манипуляції із STP (STP manipulation)
- VLAN hopping
- Підміна комутатора (Switch spoofing) – PC виконує роль комутатора

Протокол IP

Підміна адреси відправника (**ip-spoofing**):

- підроблена адреса дає певні переваги (використання моделі довіри)
- мережні екрани (фільтри) не фільтрують сфальшовану адресу
- дії від імені іншого хоста
- можлива підміна адреси “наосліп” (відправник не отримує відповідь)
- Протидія: RPF (*Reverse Path Forwarding* - перевірка зворотного маршруту)

Приклади **DoS** атак:

- LAND- атака (1997 г.) - пакети з підробленими адресою відправника = адресою одержувача змушують хост відповідати «самому собі». Можливий шторм (DoS).
- Помилка обробки фрагментованих пакетів викликає зависання або перезавантаження хоста (DoS). Атаки *Teardrop, Bonk* ...

Фрагментація як засіб проникнення через мережний екран (з підміною портів призначення), атака використовує відмінність стеків

- Протидія: дефрагментація і перевірка на проміжних пристроях (маршрутизаторах / мережних екранах)

Протокол ICMP (ICMP-атаки)

- Розвідка (сканування) за допомогою icmp

Приклади **DoS** атак:

- *Ping-of-Death* - перевищення максимального розміру отримуваного ICMP - пакета викликає зависання системи (DoS атака: немає перевірки одержуваних пакетів)
- *Win Freeze* (DoS) — шторм (шквал) icmp-повідомлень Redirect (нібито від маршрутизатора), що змушують хост постійно змінювати свою таблицю маршрутизації і приводить до DoS (в старих версіях Windows).

- *ICMP flood (Ping flood)* - затоплення ICMP - трафіком (DoS атака)
- Підсилювальна мережа (DDoS атаки):
    - Атака *Smurf* - широкомовний icmp - запит з підміною адреси джерела викликає шквал віддзеркалених повідомлень (DDoS). Аналогічно - ч-з UDP — (атака fragle).
    - Захист: заборонити широкомовні пакети на вході в мережу.

- *Tribe Flood Network (TFN), Stacheldracht* - атаки за допомогою керованої бот - мережі (різні види DDoS: ICMP, UDP, SYN, smurf ...; розвинені функції управління і шифрування)
- *Loki* - icmp використовується як тунель (прихований канал)

Протидія ICMP атакам:

- блокування всього icmp трафіку, окрім ping
- заборона функції traceroute

* Блокування функцій icmp ускладнює діагностику мережі і визначення оптимального розміру MTU.
* Потік «необумовлених» icmp-повідомлень може бути викликаний підміною IP-адреси.

Вразливості системи маршрутизації

Неавторизовані зміни політики маршрутизації системи можуть використовуватися для активного прослуховування (відведення) трафіку або як DoS - атаки.

Протокол TCP

- *SYN Flood* - переповнення вхідної черги сервера напіввідкритими сеансами (DoS)
- Захоплення *RST* прапора - ін'єкція RST + Source IP spoofing (DoS атака)
- *TCP hijacking* - десинхронізація TCP і відключення сеансу (DoS)

- *Угон TCP сеансу* - передбачення номерів послідовностей (Sequence Number) TCP -сеансу і підміна суб'єкта з'єднання (алгоритми зміни номерів послідовностей відомі)

- *TCP сканування* - SYN, FIN, NULL, X-MASS (FIN + URG + PUSH) ...
  - *Spoofing decoys* - сфальшовані джерела сканування (підміна адреси відправника на іншу існуючу адресу)
  - *Idle Scan* - Сканування через неактивний вузол (непряме визначення результатів сканування за даними зміни номерів послідовностей недіючого вузла)

- Атака Митника - встановлення TCP з'єднання від імені іншого хоста (використання моделі довіри) не маючи можливості отримувати відповіді (в сліпу).

Для чого: наприклад, виконання R-команди, що відкриває доступ.

1. Зловмисник відкриває TCP- з'єднання на будь-який порт атакованого хоста B і дізнається поточний номер послідовності TCP.
2. Зловмисник DoS атакою блокує хост A (скомпрометований IP)
3. Зловмисник передбачає (вгадує) номер послідовності, що використовується B (за кілька спроб) і «наосліп» відкриває з'єднання від імені A і виконує цільову команду.

Протокол UDP

- Повністю покладається на ідентифікацію суб'єктів засобами мережного рівня (IP- адреса).

Приклади:

- *UDP flood* - затоплення UDP - трафіком
- *trin00* - розподілена UDP - flood атака

Вразливості прикладних служб

- Web + Web-застосунки (OWASP Top10)
- Служби електронної пошти (Sendmail, ...)
- Бази даних (SQL, noSQL, ...)
- Клієнти Web
- DNS
- FTP
- SSH
- Xwindow

- Передавання даних у відкритому вигляді (прослуховування), проста автентифікація (Telnet, FTP, ...)
- Вразливості в серверному і клієнтському ПЗ
- У службі Web: вразливості клієнтів (браузерів), вразливості в серверних сценаріях
- Command Injections: SQL - ін'єкції, Міжсайтовий скриптинг (XSS - Cross Site Scripting)
- Загрози використання електронної пошти (зловживання: розсилка спаму, троянів, анонімні розсилки, підміна адреси відправника; експлуатація вразливостей серверного процесу і клієнтських програм)

Безпека WEB

Вразливості серверного програмного забезпечення:
(викликані помилками програмної реалізації, наприклад, помилками обробки параметрів запитів)

- несанкціонований доступ до інформації та програмного коду
- відмова в обслуговуванні
- виконання неавторизованого програмного коду на сервері

Приклади атак на web-сервер:

- Обхід каталогу (directory traversal, dot-dot-slash attack):
  http://www.example.com/../../../../Windows\system32\cmd.exe
- Фальсифікація URL або параметрів запиту (URL or parameters tampering)
- Заплутування URL (URL obfuscation):

Найбільш популярні CMS: Wordpress, Joomla, Drupal.

Вразливості в сценаріях (Perl, PHP ...):
(залежать від налаштувань прав виконуваних програм)

- модифікація параметрів
- читання і перехоплення cookies дає можливість стеження за діями користувача - помилки перевірки синтаксису (змінних, вставок коду, використання конвеєрів)
- ін'єкція коду (виконання довільного сценарію, в т.ч. SQL-ін'єкція) - за рахунок помилок перевірки синтаксіса (змінних, вставок коду, використання конвеєрів)
- доступ до БД
- переповнення

SQL — ін'єкції

При помилках синтаксичного аналізу використання екрануючих символів (; '-) дозволяє сформувати і виконати запит до БД (змінити логіку запиту) з метою:

- Отримання та модифікації даних
- Доступ до ФС, створення і виконання файлів
- Виконання коду і команд ОС
- DoS атаки на сервер

Несанкціонований доступ до використовуваних сервером баз даних, до файлів на сервері і виконання команд завдяки використанню некоректних параметрів і особливостей синтаксису.
Причина: пряма конкатенація нефільтрованих (неприводимих до потрібного типу) строкових значень (Приклад введення: 'or 1 = 1 - -'), дані користувача складають частину запиту.

Класи SQL-ін'єкцій:

- UNION query SQL-injection (UNION ALL SELECT ...)
- Stacked queries SQL-injection (послідовні запити)
- ERROR-based SQL-injection
- Boolean-based blind SQL-injection
- Time-based blind SQL-injection

Можливе посимвольне отримання даних (версія СКБД, логіни, паролі,...)

Заходи захисту: перевірка безпеки синтаксису, фільтрація і приведення типів, вбудовані (параметризовані) запити, налаштування прав доступу.

Міжсайтовий скриптинг (XSS, Cross-Site Scripting**)**

Використання вразливостей фільтрації введення в CGI - модулях з метою зміни вмісту динамічних web - сторінок (впровадження коду - сценаріїв, посилань, вкладених об'єктів по посиланнях на сервері з метою виконання клієнтами, вразливість нав`язування JScript)

- Deface - зміна виду або підміна сторінок (маніпуляція з шарами (прозорий вихідний документ), підключення сторінок за допомогою JavaScript (URL залишається незмінним)
- отримання параметрів сесій клієнтів або cookie-об'єктів шляхом передачі запиту POST на контрольований ресурс (викрадення облікових записів), збір статистики користувачів (історія, закладки, поштове листування), моніторинг переходів на сайти, додавання контактів
- підміна банерів, накрутка відвідувань або голосувань, anti-captcha

Приклад: <script> alert (1); </ script>

- Активні (stored) XSS - зберігаються на сервері
- Пасивні (reflected) XSS - перехід по посиланню, код в якому буде виконано

XSS зустрічається в форумах, чатах, системах обміну повідомленнями ч-з web, коментарях.
* Безпечний для сервера об'єкт цілком може викликати для користувача підміну об'єктів
* Впроваджуваний об'єкт - прозора картинка (банер) в 1 pixel

Захист від XSS: фільтрація введених користувачем даних (htmlspecialchars (), strip_tags (), регулярні вирази, контроль регістрів), Framebusting, HTTP-Only

Захист сервера від атак:

- актуалізація ПЗ сервера
- коректне адміністрування сервера і ОС (налаштування прав доступу до сервера)

Атаки на ПЗ клієнтів:

- помилки переповнення буфера
- помилки, що дозволяють несанкціонований доступ до ФС
- помилки контролю коректності сторінок
- перенаправлення на сторінку зі зловмисним контентом

Протидія:

- актуалізація ПЗ браузера, відстеження повідомлень про вразливіості
- налаштуванння безпеки браузера (наприклад, завантажувані об'єкти повинні мати можливість звертатися тільки до домену, звідки вони завантажені)
- не відвідувати сумнівні сайти
- перевіряти завантажений контент антивірусами
- безпека розширень Chrome, Opera, Firefox (більше можливостей)

Безпека системи DNS

Атака на систему DNS може полягати в фальшуванні відповіді DNS сервера (отруєння DSN - кеша, DNS-spoofing) і перенаправлення запитів на зфальшований мережний ресурс (різновид атаки «людина посередині»).

- DNS Cache Poisoning - отруєння DSN – кеша та перенаправлення на сайт зловмисника
- DNS Amplification and Reflection — підсилення атаки та сокриття джерела атаки (DoS, DDoS)
- Resource Utilizatiion – атака на ресурси DNS-сервера
- Fast Flux – сокриття адреси сервера зловмисника завдяки частій зміні інформації DNS
- Doble IP Flux – як Fast Flux + часта зміна авторизованих DNS-серверів
- Domain Generation Algorithm – випадкова генерація серверів зловмисника
- DNS Tunneling - тунелювання трафіку через запити та відповіді DNS
- Domain Shadowing – багато піддоменів у зкомпрометованому домені

DNS Security:

- Автентифікація відповідей системи DSN (цифровий підпис ресурсних записів системи). Кожна зона DNS має пару відкритий/таємний ключ.
  (Використовуються додаткові записи в БД DNS: RRSet, Key, SIG, CERT).
- Зберігання ланцюжка сертифікатів відкритих ключів в системі DNS.

Питання по темі «**Основи мережної безпеки**»**:**

Загрози мережній безпеці. Класифікація мережних атак.
У чому небезпека підміни адрес.
Загрози і атаки мережного рівня. Відповідні заходи протидії.
Загрози і атаки, пов'язані з протоколом ICMP. Відповідні заходи протидії.
Загрози стстемі маршрутизації. У чому небезпека компрометації системи маршрутизації.
Загрози, пов'язані з протоколом TCP.
У чому полягають мережні атаки Land, Teardrop, WinFreeze, Ping-of-Death, Smurf, Tribe Flood Network, Loki, SYN Flood, TCP hijacking, trin00, fragle. До якого класу належить кожна з цих атак.
Що називається DoS і DDoS атакою. Їх відмінності.
Способи сканування доступності хостів.
Способи сканування мережних портів. Їх відмінні риси.
Основні вразливості прикладних служб і протоколів.
Вразливості серверного ПЗ (на прикладі Web-серверів). Вразливості Web-браузерів.
Класифікація вразливостей і загроз Web. Приклади атак. Відповідні заходи протидії.
У чому полягають загрози SQL-ін'єкції і міжсайтового скриптинга. Які фактори роблять можливими такого роду атаки.
Способи захисту від SQL-ін'єкцій та XSS. Різновиди SQL-ін'єкцій.
У чому небезпека атаки на сервера DNS. Можливі наслідки атак на систему DNS. Заходи захисту системи DNS.

Література:

- Грайворонський М.В., Новіков О.М. Безпека інформаційно – комунікаційних систем. – К: Видавнича група BHV, 2009. – 608 с.
- Таненбаум Э., Уэзеролл Д. Компьютерные сети. 5-е изд. - СПб.: Питер, 2012. - 960 с.
- Столлингс В. Основы защиты сетей. Приложения и стандарты. – М.: «Вильямс», 2002. – 432 с.

Архітектура мережних засобів захисту
Безпека мережної інфраструктури

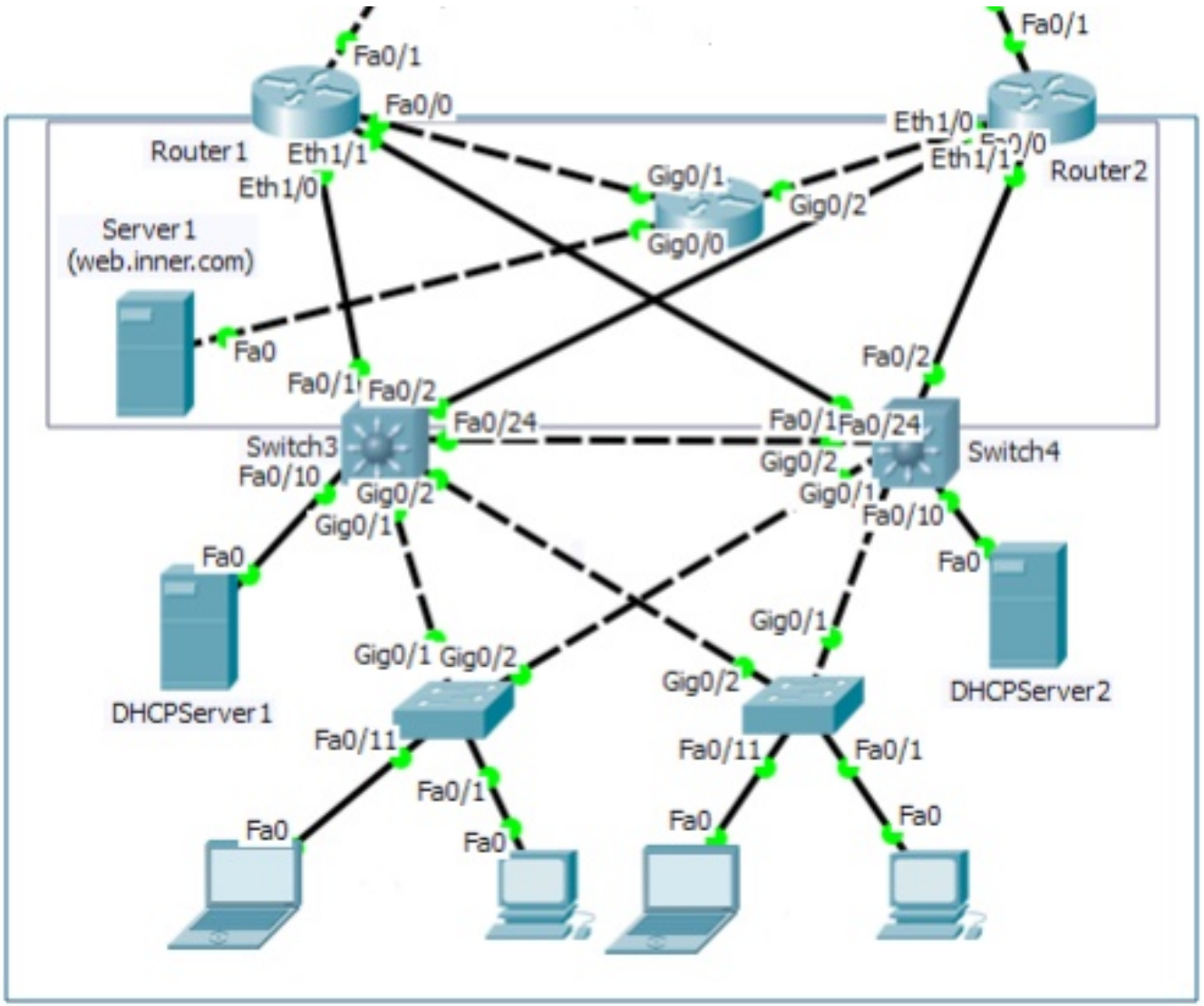
Потенційно небезпечні дії:

- Сканування (визначення версії ОС, зондування)
- Атаки (НСД, DoS)
- Активне перехоплення (ARP-spoofing, ARP-poisoning, ARP - redirect, DNS - spoofing)
- Приховані канали, закладки (Proxy)

Напрямки захисту мережної інфраструктури:
(Протидія моніторингу і перехопленню трафіка - максимальне розмежування потоків)

- Топологія «загальна шина» і використання концентраторів - в минулому
- Сегментація трафіка - віртуальні локальні мережі (VLAN);
- Фільтрація трафіка між VLAN
- Захист мережного обладнання

- Резервування каналів і обладнання, відсутність петель в топології канального рівня - підвищення надійності мережі на канальному рівні
- Резервування маршрутизаторів (HSRP, VRRP, …)



Мережні засоби захисту:

- **Мережні екрани**
- **IDS/IPS**
- **Автентифікація**
- **Layer-2 Security**
- **Захист Wi-Fi**
- **VPN**
- **Нотаризація та SIEM**

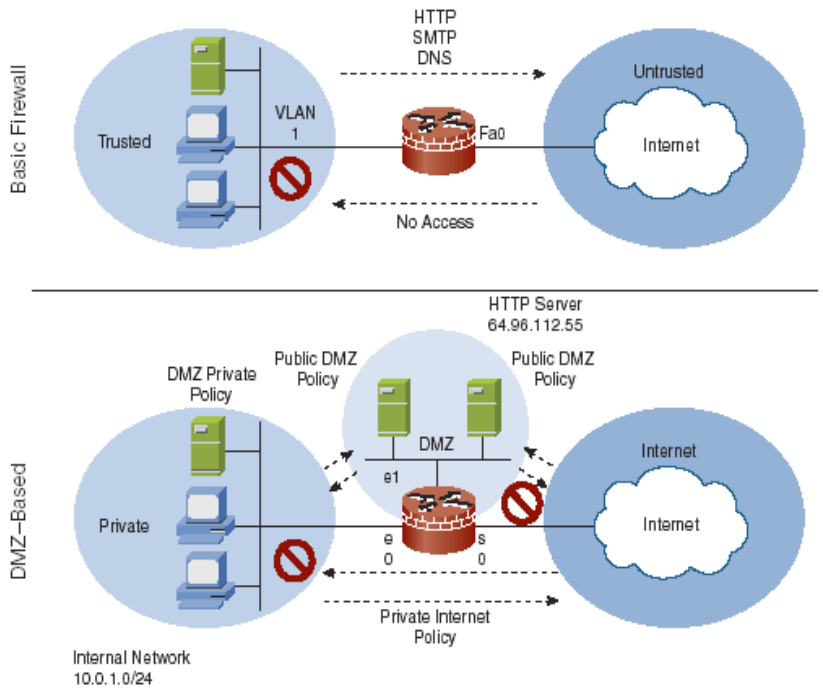
Мережний екран (firewall)
Контроль доступу між мережами (зонами безпеки)

"Жодний окремо взятий застосунок не в змозі забезпечити безпеку самостійно"

Завдання мережних екранів:

- Реалізація політики доступу
- Приховування внутрішньої структури захищуваної мережі
- Захист від DoS - атак та інших небажаних трафіків

Розміщення мережних екранів:



Види мережних екранів:

- Пакетні фільтри:
  - Фільтрація трафіку 2,3,4,7 рівня - послідовність правил у вигляді «регулярних виразів»: шаблон трафіку vs. дія
  - Фільтрація трафіку з урахуванням стану потоків (Stateful protocol inspection)
- Сеансові шлюзи (NAT) - контроль за з'єднанням:
  - NAT (Network Address Translation) - шлюз мережного рівня;
- Шлюзи прикладного рівня:
  - Проксі сервери для протоколів HTTP, FTP, Telnet ... - аналіз прикладних протоколів (перевірка достовірності інформації, фільтрація прикладного рівня, кешування, реєстрація подій):
  - Сервер - посередник (Application layer gateway);

  Приклад: аналіз команд SQL; Apache ModSecurity - захист web-сервера (контроль заголовків, виявлення аномалій); Suhosin - захист PHP (низкорівневий захист та управління доступом).
- Authentication Proxy (посередник автентифікації) - доступ в зовнішні мережі тільки після автентифікації на сервері;
- IPS сенсор (аналіз сигнатур атак);
- VPN шлюз (концентратор).

Проста фільтрація трафіку:

Шаблон трафіку може містити:
Поля заголовків пакетів:

- IP адреси відправника і одержувача
- Тип пакета (протокол)
- Прапори фрагментації
- Номери портів TCP (UDP)
- Прапори SYN, FIN, ...

Дія:

- Пропустити пакет далі
- Вилучити
- Скинути
- Затримати (обробити: шифрування - дешифрування, антивірус, NAT, ...),
- Записати в LOG

Правило за замовчуванням:

- М'яка політика фільтрації (дозволено все що не заборонено)
- Сувора політика фільтрації (заборонено все що не дозволено)

Попередження DoS атак
(Типові параметри налаштування)

Anti DoS thresholds (порогові значення):
-half-opened TCP
-half-opened TCP per interface
-half-opened TCP per host

Anti DoS actions:
-reset oldest connection
-block SYN temporary

Недоліки пакетних фільтрів:

- Перевірка тільки полів заголовків
- Відсутність перевірки цілісності та достовірності пакетів
- Відсутність автентифікації вузлів

Недоліки прикладних шлюзів:

- Блокування трафіку у разі відмови шлюзу
- Складність і ресурсомісткість реалізації
- Не прозоро для користувачів (вимагає налаштування проксі)

Персональні (хостові) мережні екрани

Контроль мережної взаємодії на мережному, транспортному і прикладному рівнях.
Встановлюють на кінцевих вузлах.
Здійснюють контроль вхідного - вихідного трафіка окремого комп'ютера.

- Інтеграція з ОС
- Контроль на рівні програм
- Виявлення типових атак за параметрами або характеристиками трафіку
- Реєстрація подій
- Блокування небажаних сайтів, потоків, пакетів
- Антиспам - фільтрація
- Інтеграція зі шлюзом VPN

Недоліки мережних екранів:

- Не виключають наявність побічних входів в мережу (модеми, бездротові з'єднання, тощо)
- Не захищають від атаки зсередини мережі
- Складність виявлення тунелів в потоках (ICMP, DNS, UDP, ...)
- Можуть самі стати об'єктом атаки
- Можуть мати власні вразливості

Приклад: Налаштування персонального мережного екрана у Windows

Дозволити мережні службы:

- FTP
- Telnet
- HTTPS
- RDP (Remote Desktop – дистанційне керування робочим столом)
- SMTP
- IMAP3 (port220)
- IMAP4 (port 143)
- POP3
- інші (IP address, TCP/UDP, source port, destination port)

Послуги ICMP:

- echo request
- echo request – запит часу
- запит маски
- запит адреси маршрутизатора
- host unreachable
- source quench (вгамовування джерела - управління заторами)
- header error
- time exeeded
- redirect

Винятки:

- Програма, порт
- Область: Internet, LAN, діапазон IP

Дозволено за замовчуванням:

- Діагностика (xpnetdiag.exe)
- Управління робочим столом (TCP port 3389)
- Загальний доступ до файлів і принтерів (TCP 139, TCP 445, UDP 137-138)
- Дистанційний помічник (sessmgr)

Приклади практичних завдань:

- Дозволити доступ до сервера Web з локальної мережі
- Дозволити діагностичні повідомлення ICMP
- Дозволити (заборонити) доступ до деякого зовнішнього хоста
- Дозволити доступ в Internet тільки деякій програмі (наприклад, Web - браузеру)
- Дозволити доступ до файлів і папок на вашому комп'ютері тільки з локальної мережі
- Заборонити доступ до інших служб даного комп'ютера

Системи виявлення/попередження атак

СВА - програмно-апаратна система, яка автоматизує процес аналізу подій в інформаційно - комунікаційної системи, що впливають на її безпеку.
Завдання IDS / IPS сенсора - активний захист від мережних атак

Вся ідеологія виявлення і запобігання вторгнень грунтується на понятті сигнатури.
Сигнатура - "шаблон неправильності" в одному пакеті або потоці.

- Ознаки порушення політики безпеки
- Джерела пошуку порушень
- Методи аналізу інформації

Приклади СВА: Snort, CISCO ASA / ISE, TMG (Threat Management Gteway)

Можливості систем виявлення атак:

- Виявлення підготовки атаки (зондування мережі) і джерела атак
- Реагування на атаку
- Блокування атак (особливо в разі наявності відомих вразливостей)
- Збір інформації та документування загроз
- Контроль політики безпеки і цілісності інформації
- Захист вразливого ПЗ і ОС централізовано

Додаткові можливості IDS / IPS:

- Сканери вразливостей (SATAN, XSpider, Nessus)
- Контроль цілісності систем (md5sum, Tripwire) і аналіз встановлених оновлень
- Honneypot IDS (хост - пастка)
- Антивіруси

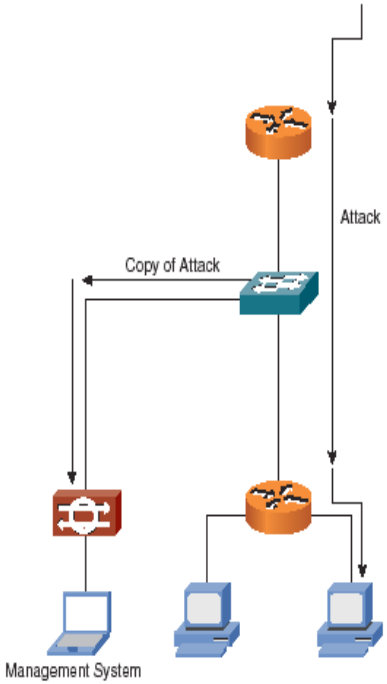
Рівні IDS / IPS:

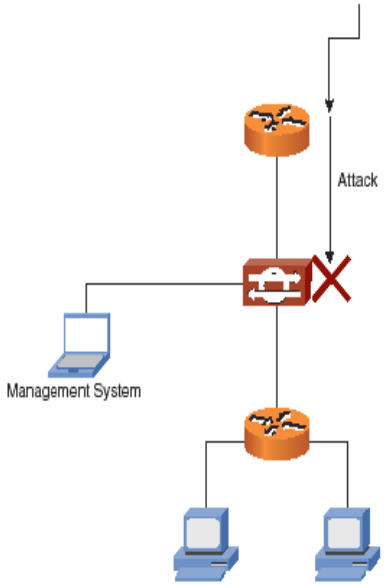
- Мережні (сенсор на кордоні мережі)
- Хостової (персональні, рівня вузлів або прикладних програм: можуть працювати в індивідуальному або розподіленому режимі)

Положення IDS / IPS в мережі:

- Internet - між зовнішнім шлюзом і Internet
- Extranet - між внутрішньою мережею і зовнішнім шлюзом
- Internal - між внутрішніми блоками мережі
- Remote access - захист периметра
- Server farm - захист периметра та host-IPS на серверах

Режими роботи:





Promiscuous mode (IDS) -
сенсор обробляє копію трафіка

Inline mode (IPS) -
потік трафіка проходить через сенсор

Методи аналізу трафіка:

- Виявлення зловживань (Misuse Detection) або порушень політики безпеки: аналіз подій або сигнатур трафіка
- Виявлення аномалій (Anomaly Detection): евристичний метод (створення профілів активності і статистичний аналіз)

або

- Signature based - розпізнавання сигнатур (характерних фрагментів потоку даних)
- Anomaly based (Profile - based): реєстрація відхилень від "нормального" функціонування мережі (аномальна активність). Використовують статистичні і нестатистичні характеристики.
- Policy based: реєструють порушення політики безпеки (небажані трафики)
- Protocol-Analysis bases: глибокий аналіз мережних протоколів (≈Signature Based), *DPI* (Deep Packet Inspection)
- Honeypot: хост — пастка (наживка)

* Anomaly based, Policy Based - більше помилкових спрацьовувань, ніж у Signature based

Дії СВА:

- Збір інформації та генерація звітів
- Сповіщення про атаку
- Зміна оточення (скидання з`єднань, блокування потоків трафіку або адрес)
- Іноді - запуск зустрічної атаки

Приклади параметрів сигнатур

Види сигнатур:

- Exploits
- Connections
- Strings
- DoS

*або vulnerability based, exploit based, policy based.

Групи сигнатур:

- ATOMIC – одиничні пакети
- FLOOD — затоплення трафіком
- SERVICE (DNS, FTP, HTTP, MSSQL, NTP, RPC, SMB, SSH…) - для сервісів
- SRING (ICMP, TCP, UDP) - строкові
- TROJAN - троянці

Важливість події (*Alarm severity)*: high, info, medium, low

Дії (Event Action):

- alarm, LOG, SNMP trap
- denyAttakerInline
- denyFlowInline
- drop
- reset TCP connection

Класифікація спрацьовувань сенсорів:

False Alarms:

- False Positive – хибне спрацьовування
- False Negative – відсутність реакції на атаку

True Alarms:

- True Positive – розпізнавання атаки та реакція на неї
- True Negative – відсутність спрацьовування на безпечний трафік

Труднощі у виявленні атак:

- Змінність сигнатур (перекодування, шифрування ...)
- Фрагментація (наприклад, з видаленням / вставкою фрагментів)
- Переповнення ресурсів сенсора (можливі атаки на сенсор)

- Прозорість мережних IDS
- Мережні IDS не можуть аналізувати зашифрований трафік
- СВА прикладних програм дозволяють глибший аналіз взаємодії програми
- Складність настройки і значне число помилкових спрацьовувань методу виявлення аномалій

ВІДМІННОСТІ IDS/IPS:

IDS	IPS
Promiscuous mode (копії пакетів)	Inline mode (в потоці трафіка)
Реагування після виявлення атаки	Real-time реагування
Зміна оточення (налаштування інших зсобів мережі)	Можливе скидання пакетів (заборона небажаного трафіка)
	Динамічні правила фільтрації

Інтелектуальні функції IDS / IPS

- Визначення версій ОС і ПЗ на атакованих хостах і вибір адекватних засобів захисту
- Система ранжування ризиків
- Віртуалізація (віртуальний сенсор)

Основні завдання адміністрування IDS / IPS:

- Оновлення та налаштування сигнатур атак і статистичних параметрів (зменшення числа false-positive і false-negative спрацьовувань)
- Аналіз повідомлень
- Налаштування точного часу для кореляції подій

Питання по темі “Архітектура мережних засобів захисту. Безпека мережної інфраструктури.”

Призначення і завдання мережних екранів.
Види мережних екранів.
Розміщення мережних екранів.
Принципи фільтрації трафіка (шаблони, дії, правила за замовчуванням).
Заходи запобігання DoS атак.
Недоліки пакетних фільтрів.
Властивості персональних мережних екранів.
Відмінність мережних екранів від персональних.
Недоліки персональних мережних екранів.
Яким загрозам протидіють мережні екрани і засоби виявлення атак.
Відмінності систем запобігання і виявлення атак.
Завдання і можливості систем виявлення атак.
Розміщення систем виявлення атак в мережі.
Режими роботи систем виявлення атак.
Методи аналізу трафіка в системах виявлення атак.
Дії СВА при виявленні сигнатур атаки.
Параметри реагування СВА на сигнатури атак.
Недоліки методів виявлення атак.

Література:

- Грайворонський М.В., Новіков О.М. Безпека інформаційно – комунікаційних систем. – К: Видавнича група BHV, 2009. – 608 с.
- Таненбаум Э., Уэзеролл Д. Компьютерные сети. 5-е изд. - СПб.: Питер, 2012. - 960 с.
- Столлингс В. Основы защиты сетей. Приложения и стандарты. – М.: «Вильямс», 2002. – 432 с.

Захист приватних даних і анонімність

Трекінг і фінгерпрінтінг
Windows, Android, Viber ...
Очищення Windows

Захист приватних (мобільних) даних
Фішинг
Вимагання
Шифрування даних мобільних пристроїв

Безпечне використання «миттєвих повідомлень» і соцмереж
Анонімізація і шифрування
Proxy і VPN
Наскрізне шифрування повідомлень
PGP, S / MIME

ToR ("цибулева" маршрутизація, багаторівневий проксі)
DarkNet (Tor Hidden Services - домен .onion)
I2P ("часникова" маршрутизація - домен .i2p, анонімний Інтернет)

«В Інтернеті ніхто не знає, що ви - Кіт» (так було колись)

Трекінг - відстежування активності користувача

Практично вся інформація доступна великим корпораціям
(ім'я / прізвище, переміщення, адреси, фото, паролі, карти, переваги ...)
Використовується для таргетованої реклами і стеження
Реклама «з'їдає» до 90% часу завантаження сторінок

Джерела трекінгу:

- Cookies
- Банери
- Шріфти Google Fonts
- Web Bugs (об'єкти Google Analytics, Yandex.Metrix, AdSense, JQuery)
- *Телеметрія* (обробляється практично вся інформація, що вводиться)

Де трекери можуть зберігати ідентифікуючу інформацію:

- LSO (Local Shared Object) або Flash cookies
- HTML5 Local Storage
- параметри Etag і LastModifyed в запиті HTTP
- кеш HSTS (HTTP Strict Transport Security)

Мінімізація можливості трекінгу: видалити cookie, кеш браузера, історію відвідувань

Фінгерпрінтінг - набір унікальних ознак, що ідентифікують користувача (пристрій)
Деанонімізація - порушення анонімності за допомогою зіставлення інформації

Джерела інформації:

- IP і MAC адреси, версія системи / браузера (user agent), мови, параметри екрану, % заряду акумулятора, час, часовий пояс, шрифти, інші пристрої (ч-з Flash).
- Особливості відображення шрифтів
- Історія відвідувань (500 сайтів ідентифікують 75% користувачів)

Рекомендації:

- відключити Flash, Java Script
- від деанонімізації через кеш практично захисту немає (часте видалення кеша).
- використовувати Firefox с розширеннями Ghostery (DoNotTrackMe), Black Origin, Request Policy, UserAgentOverride, HTTPS Everywhere, Adblock Plus, No Script (вимикає Flash, JavaScript, Java)
- використовувати ToR

Боротьба з трекінгом робить пристрій більш вразливим до фінгерпрінтінгу!

Мобільні пристрої

Джерела інформації:

- Модель пристрою
- Сенсор: Wi-Fi, NFC, гіроскоп, GPS, термометр, барометр, ...
- Камера, мікрофон
- Особливості виробництва і застосування сенсорів
- Становище, координати, жести
- Інші пристрої (взаємодії)

- Наявність застосунків
- Відстеження переміщень: їзда в машині (на сидінні, в бардачку або в руках), автобусі або велосипеді, ходьба: швидкість, захоплення вібрацій ...
- Натискування клавіш і тривалість (клавіатурний почерк)
- Особливості роботи сенсорів

- Існує багато програм для GPS-трекінгу (в т.ч. «Антизлодій»).
- Існує шкідливий код, що відслідковує активності користувачів у фоновому режимі
- 7 з 10 застосунків передають інформацію користувачів
- Якщо доступ до інформації отримує один застосунок Google - отримують і інші
- Отримання даних з камери і мікрофона: через драйвер (складніше), утіліти віддаленого адміністрування і спостереження (RemCam, DarkComet, ..) - впроваджуються методами соціальної інженерії
- Доступ до камери / мікрофона для web-сайту може зберігатися навіть після закриття сторінки
- Застосунок Android, що одного разу отримав доступ до камери - отримує доступ назавжди
- Сервіси Google (на відміну від Android) мають закритий код
- Для iPhone теж використовуються сервіси Google (пошук, Gmail, ...)
- При відвідуванні ресурсів можливості трекінгу можна мінімізувати, але залишається багато параметрів для фінгерпрінтінгу (в т.ч. неявного трекінгу і деанонімізації).

Безпека сервісів миттєвих повідомлень (Messangers)
ICQ - Skype - Viber, WhatsApp, Telegram

- Передача повідомлень повинна використовувати наскрізне шифрування!
- Використовувати секретні чати.
- Парольна або дактилоскопічна автентифікація при кожному запуску месенджера.
- Виходити з програми по закінченню роботи.
- Для контакту краще давати Nickname, аніж номер телефону.
- Використовувати номер телефону в країні з вискоім рівнем демократії (Німеччина, Голандія, Естонія).
- Не застосовувати месенджери виробництва компаній - гігантів.

Більш захищеними вважаються месенджери Signal і WhatsApp

Безпечне використання публічних Wi-Fi мереж

- Не довіряти мережам без пароля.
- В публічних мережах не використовувати незахищений HTTP для передавання критичних даних.
- Не підключатися до мереж автоматично.
- Відключати Wi-Fi після використання.

Помилки в соціальних мережах:

- Публікувати інформацію про свій навчальний заклад, хобі, захоплення, фото з особистих архівів.
- Разміщувати на своїй сторінці лінки на профілі своїх родичів, їх фото, інформацію про них. Не робіть пости, в яких є вказівки на садочок / школу / ВУЗ вашої дитини.
- Публікувати на сторінці свою адресу, № телефону, email, розміщувати фото квартири, атракцій поруч з будинком.
- Підключати «психологічні тести».
- Додавати незнайомців в списки друзів.
- Відкривати всі надіслані посилання.

- Ніколи не вказуйте свою домашню адресу.
- Не варто розміщувати фотографії і опис будь-яких атракцій, розташованих по сусідству.
- Не публікуйте у відкритому доступі фото своїх цінних речей.
- Не залишайте пости або коментарі в стилі "залишилося 5 днів до від'їзду"!
- Не робіть мітки зі своїм місцезнаходженням під час самого відпочинку.

Захист приватності смартфона

- Отримання прав root
- Заблокувати завантажувач, відключити ADB
- Прибрати застосунки Google (Google Apps)
- Відв'язування від сервісів вендора (не реєструвати обліковий запис)
- Використовувати альтернативний маркет (НЕ Amazon :)
- Емуляція мобільних сервісів
- Альтернативний Dropbox
- Відключення синхронізації
- Обмеження застосунків в повноваженнях (Privacy Guard, SELinux, DroidWall)
- Обфускація особистості
- ToR (Orbot) для анонімних з'єднань і інший браузер для неанонімних
- Блокування реклами
- Пароль на екрані блокування екрану
- Шифрування даних
- Менеджер паролів
- «Антизлодій» з видаленням даних
- Використовувати окремий телефон-дзвонилку :)

Незашифровані дані практично завжди можна витягти з телефону !!!
(Сервісний режим, USB-порт, JTAG-порт).

Фішинг

- Фішингові листи (масові або цільові)
- Повідомлення в messanger

Містять посилання на заражений сайт або інфіковане вкладення або стимулюють до розкриття приватної інформації (заповнити анкету)
Мотивація: виграш (Нігерійській спам), запрошення (квитки на фестиваль) ...

Однотипні листи швидко потрапляють в спам.
Використовуються персоналізовані листи з різних доменів.
Інфопривід - з офіційного сайту (угоди, продукт, заходи ...)
Соціальні мережі як джерело інформації.

Фішинг - як pentest-послуга

Трояни, вимагачі
Копіювання зовнішнього вигляду популярних ресурсів
Мета - розкриття даних акаунтів, паролів, спонукання до платежів ..
Реалізація: через посилання, вікно-накладку

Фактори:
Довіра до застосунку
Уніфікація і легкість API, стекове розміщення активностей (в моб. платформах)
Захист - СКД прикладного рівня, уважність

- Для застосунків на смартфонах двухфакторна автентифікація стає однофакторною.
- Поява нового виду APT атаки - Mobile APT
- Вхід у захищену інфраструктуру через мобільний пристрій

- Не завантажувати з ненадійних ресурсів і не встановлювати неперевірений софт, зокрема утиліти для безкоштовного скачування, перегляду, видалення.
- Уважно ставитися до підозрілих листів, не переходити за вказаними у них посиланнями.
- Вчасно оновлювати антивірусне ПЗ.
- Регулярно проводити повне сканування комп'ютера антивірусом.
- Звертати увагу на роботу камери ноутбука. (Якщо камера вмикається не тільки під час відеодзвінків, слід негайно від'єднати пристрій від інтернету і перевірити налаштування камери.)
- Частіше перевіряти дозволи доступу до камери і мікрофона для різних сайтів. (У Google Chrome - на сторінці налаштувань.)
- Під час важливих переговорів відкласти смартфон і планшет подалі.
- На Android-пристроях зайти в розділ застосунків і в кожному сторонньому застосунку, в "Управлінні дозволами", у функціях "Запис звуку" і "Камера", за бажанням вибрати опцію "Заборонити" або "Завжди запитувати".

Напрямки забезпечення анонімності

1. Захист від ідентифікації IP (VPN, Proxy, ToR, I2P)

2. Шифрування (переданих файлів, наскрізне шифрування пошти, VoIP, video)
 - HTTPS, SSL, PGP ...
* Шифрування групової розсилки або чатів - спеціальні криптопротоколи

3. Вторинні дані
 (Заголовки HTTP, EXIF мітки в .PNG, .JPEG, дані про автора в .DOC, .PDF і ін.)
* Можлива деанонімізація по стеганопідпису при копіюванні даних

4. Особиста інформація (фото, імена, навчальні заклади, адреси, позначки на фото ...)
 * У таємній мережі не може бути реальної інформації

Фактори деанонімізації

- Соціальні
- Технічні

- IP-leaks
- DNS-leaks
- Профілювання трафіку
- MITM на вихідному вузлі
- Деанонімізуюча активність (вхід на сайт, що знає користувача)
- AP (точка доступу) і комутатор бачать MAC клієнта
- Cookies, Adobe Flash, Java, JavaScript
- Фінгерпрінтінг браузера (user agent, ...)
- HTTP-referer (звідки перехід)
- Web bugs - невидимі деталі web-сторінок для моніторингу активності користувача
- Дані «телеметрії» Windows

Анонімність з'єднань

- Proxy - заміна IP-адреси, можлива нормалізація заголовків
  HTTP, SOCKS, CGI (анонимайзер)
  (Звичайний HTTP проксі додає заголовки HTTP_X_FORWARDED_FOR, HTTP_VIA, HTTP_FORWARDED та не приховує IP)
- VPN - захищений тунель (хост-хост, хост-мережа, мережа-мережа)
  (VPN сервіси зберігають анонімність тільки при довірі до провайдера - юрисдикція, зберігання журналів)
  -VPN-leaks - витік трафіку в обхід захищеного тунелю
- SSL / SSH - захист даних в рамках TCP-з'єднання
- PGP - end-to-end (наскрізне) шифрування даних
  -обмін відкритими ключами
  -довіра до сертифіката (каталог)
  -перевірка сертифіката
- Наскрізне шифрування даних повідомлень, телефонії, відео, etc ...
- В основному всі атаки на VPN / SSH зводяться до MITM та підміни сертифіката / ключа

У анонімізації немає однозначного «достатнього» порога!

- ToR - анонімізація з'єднань від спостерігача в мережі
- I2P - мережа анонімних сервісів (передбачається, що всі ноди можуть бути захоплені)
- Сценарії VPN + ToR або ToR + VPN
- Віртуальне середовище (Workstation + Gate)

Деанонімізація ToR:

- Відбиток системи, шрифтів, браузера, мережі, поведінковий аналіз
- Website Fingerprinting
- Пасивний спостерігач - потрібна ферма ToR нод
- Активний спостерігач - впровадження об'єкта в з'єднання

Питання по темі:

Поняття трекінгу, фінгерпрінтінгу і деанонімізації.
Джерела трекінгу. Мінімізація трекінгу.
Джерела інформації для фінгерпрінтінгу.
Протидія фінгерпрінтінгу.
Джерела трекінгу і фінгерпрінтінгу мобільних пристроїв.
Загрози приватності при використанні смартфонів.
Напрямки захисту приватності смартфонів і відповідні технології.
Загрози приватності при використанні соцмереж і служб повідомлень. Заходи захисту.
Фактори деанонімізації користувачів.
Напрями та технології забезпечення анонімності.

Соціальна інженерія

«Покуда есть на свете дураки,
Обманом жить нам, стало быть, с руки.
Какое небо голубое,
Мы не сторонники разбоя:
На дурака не нужен нож,
Ему с три короба наврёшь -
И делай с ним, что хошь!»
(«Пісня Кота та Лиси» («Пригоди Буратино»))

- Цілі атак
- Послідовність атаки
- Сценарії атаки
- Чинники соціальної інженерії
- Методи соціальної інженерії
- Маніпуляції
- Захист від атак соціальної інженерії
- Соціальний пентест

«Хакер - це людина, яка мислить круто, нестандартно і у всьому шукає недокументовані можливості ».

Термін «*соціальна інженерія»* запровадив Кевін Мітник.

Під «*соціальною інженерією*» розуміються нетехнічні засоби отримання критично важливих даних.

Людина часто виявляється найслабшою ланкою системи захисту.

- Введення в оману (обман) - видача себе за іншого, відволікання уваги, нагнітання психологічної напруги.
- Гра на почуттях (любові, ненависті, жадібності, заздрості…)
- Шантаж

…

Цілі атак:

- НСД
- Розкриття інформації (фішинг)
- Впровадження пристрою, запуск вкладення/коду, перехід за посиланням

*Перехід по посиланню через QR-код.

Схема впливу:

1. Визначення мети
2. Збір інформації
3. Створення необхідних умов
4. Примус до дії
5. Отримання результату

«Найбільш складні APT-атаки – з елементами соціальної інженерії »

Послідовність атаки:

1. Збір інформації: соцмережі (LinkedIn, ...), форуми ... (захоплення, місце роботи, постачальники фінансових послуг тощо); проникнення в пошту, інші відкриті джерела (довідники, …)
2. Зачіплення. Мета "зачіпки" - успішно "розвести" об'єкт атаки, вступивши з ним у контакт і створивши привід для взаємодії. Важелі впливу: взаємність, дефіцит, послідовність, вона, влада, соціальні докази.
3. Розведення. (Розкриття інформації, перехід за посиланням, перерахування коштів тощо)
4. Вихід (Якщо необхідно, вихід із гри не викликаючи підозри, уникнення відповідальності.

Соціотехніки – методи соціальної інженерії. З їх допомогою зловмисники намагаються переконати людину, обрану як об'єкт кібератаки, вчинити ту чи іншу дію, що призводить до зараження системи або розкриття цінної інформації.

Соціотехніка - навмисне використання методів, націлених на те, щоб обманним шляхом підштовхнути людину до розкриття інформації або вчинення дій, які можуть призвести до розкриття інформації.

Сценарії «Полювання» та «Тваринництво»

"*Полювання*" (або *Hanting*) передбачає отримання інформації при мінімальній взаємодії з об'єктом атаки.

"*Тваринництво*" (або *Farming*) - передбачає встановлення тривалих відносин з об'єктом атаки з метою його "доїння" (тобто отримання інформації) протягом тривалого періоду часу.

Соціальне програмування (інструмент впливу, що може використовуватися самостійно або як елемент атаки)
Створення ілюзій, PR технології (чутки, оголошення, пости у соцмережах…)

Фактори соціальної інженерії

Атака соціальної інженерії йде в обхід аналітичних інструментів розуму, а діє переважно на рівні емоційної сфери (експлуатує культурні стереотипи).

- Природність
- Самовпевненість, рішучість
- Імпатія, співчуття, розуміння
- Лінь
- Жадібність (виграш та ін. «куля»…) - деякі люди дуже жадібні до грошей
- Поспіх, терміновість, брак часу, створення дефіциту часу
- Надлишок інформації, перевантаження потоком даних, переключення на аналіз другорядної інформації
- Страх (втратити гроші, роботу, репутацію...) та параноя (раніше виявлені проблеми з безпекою...)
- Довіра, статус, авторитет («Людина у формі має незаперечний авторитет») Рефлекси
- Акторська майстерність (уміння видавати себе за іншого персонажа, користуючись раніше отриманими даними)
- Фармакологічний підхід:)

- Психологічний тиск, маніпуляція
- Ображені
- Компромат (брехня, зв'язки,...), шантаж
- Пропозиція роботи
- "Більшість людей негативно залежні від власного почуття значущості", лестощі
- «Люди хочуть, щоб усе хороше, що може статися, сталося б з ними якнайшвидше і без особливих зусиль» (відбувшись мінімальними витратами, можна отримати надприбутки) – мільйони ошуканих вкладників тощо.

Методи соціальної інженерії

- Впровадження трояна через USB-накопичувач
- Проникнення на об'єкт, що охороняється (імпатія, співчуття, розуміння)
- Легенда, папірець із роздруківкою («завдання»), ...
- Розкриття персональних даних по телефону
- Розкриття облікових даних
- Примушення до відкриття вкладення або посилання (фішинг)
- Сприяння змінам налаштувань (створення користувача, права доступу, шлюз, VPN, …)
- «Таджицький вірус»
- Фішингова сторінка
- "Випадково" знайдені диски або USB-пристрої

Зворотна соціальна інженерія (*Reverse SE*) – жертва потрапляє до умов, за яких сама повідомляє необхідні дані (приклад Сноудена)

Доповнюючі методи: Маніпуляції з телефоном, Атака на адміністратора («інформатор» повідомляє про атаку, імітація атаки ...), …

Уникнення відповідальності: підкидання грошей або інших доказів, інформація від «інформатора»

- Проникнення під прикриттям... (прибиральниця, телефоніст, …)
- Акторська майстерність (вжитися в образ)
- Знання предметної галузі (вжитися на роль)
- Продумування дрібниць

- Викрадення ICQ (без primary-email:) - під виглядом заробітку в CEO
- Злом пошти – дізнаємося відповідь на секретне запитання (номер паспорта – пропозиція недорогої покупки, кулі...)
- Злом облікового запису - переконання служби техпідтримки (зміна альтернативного e-mail), + підтвердження з фейкової адреси
- Фішинг (ввести логін-пароль за посиланням, повідомлення від адміністрації, клопотання у сфері інтересів жертви (тренінг...))
- Фармінг (маніпуляція з hosts/DNS за допомогою троянів, джойнерів, скриптів... для перенаправлення на фішинговий сайт для особливо недовірливих;)

- Витік інформації через робочий стіл (отримання попередньої інформації) - «у кого робочий стіл крутіший»
- Корисний софт (крякер, майнер, ...скриншоти)
- Сайти знайомств - ідеальне місце для створення ботнетів
- "Блондинка" (допомога в установці комп'ютера, розібратися з програмою...)
- Дорожнє яблуко (підкидання накопичувачів, що інтригує вміст) - важлива цільова аудиторія
- Тестування бета-версії нової програми
- Архів у .exe, фото у форматі презентації, відео

Зворотна соціальна інженерія (Reverse SE) - людина сама звертається до зловмисника за допомогою.

- Створення іміджу спеціаліста
- Реклама з боку
- Диверсія (створення оборотної проблеми)
- «Допомога»

«Не існує пристрою, що заборонить людям бути ідіотами »

Захист від атак соціальної інженерії:

- Інформування, поінформованість, ...
- Інструктаж та тренінги
- Раптові перевірки
- Критичне мислення

- Правила розкриття інформації та порядок (ієрархія) обробки запитів: (PayPal надає користувачам наступну інструкцію з перевірки автентичності одержуваних електронних повідомлень: «у своїх електронних листах ми ніколи не запитуємо інформацію наступного типу: номери банківських карток, номери банківських рахунків, номери посвідчень водія, адреси електронної пошти, паролі, ваше повне ім'я».)

- Технічні засоби: (Запис телефонних дзвінків, контроль та фільтрація web-трафіку, блокування доступу до шкідливих сайтів, сувора автентифікація, аналіз соц.мереж, система реагування)

Соціальний пентест (зовнішній тест на проникнення):

- Розвідка

- Підготовка (вибір сценарію):
  Електронна пошта
  Телефон
  Підкинуті пристрої
  Соц мережі
  SMS, MMS

  Ціль: розкрадання облікового запису або запуск вкладення
  (перехід за посиланням, введення облікових даних, запуск ПЗ)
  Довіра — схожі адреси, домени фішингу, знайомі прізвища, стиль...
  Підготовка листів
  Підміна адрес електронної пошти
  Макроси в офісних документах

- Розсилання
  Відволікаючий маневр – помилка тощо.
  *Ігноруйте масові розсилки!

- Профіт
  Отримання облікових записів (VPN, пошта, RDP, домен)

Питання по темі:

Що розуміється під "соціальною інженерією".
Чинники, сценарії та методи соціальної інженерії.
Цілі атак соціальної інженерії.
Технічні та організаційні заходи захисту від атак соціальної інженерії.
Сценарій тесту проникнення з елементами соціальної інженерії.